

Комплексна система захисту інформації

# Профіль базових заходів із захисту інформації (155)

# Зміст

## Зміст

|        |                                                                                     |    |
|--------|-------------------------------------------------------------------------------------|----|
| 1      | АС                                                                                  | 13 |
| 1.1    | ПОЛІТИКА ТА ПРОЦЕДУРИ УПРАВЛІННЯ ДОСТУПОМ (АС-1)                                    | 13 |
| 1.2    | УПРАВЛІННЯ ОБЛКОВИМИ ЗАПИСАМИ (АС-2)                                                | 14 |
| 1.2.1  | ДЕАКТИВАЦІЯ ОБЛКОВИХ ЗАПИСІВ (АС-2(3))                                              | 16 |
| 1.2.2  | ВИХІД ІЗ СИСТЕМИ ЗА ВІДСУТНОСТІ АКТИВНОСТІ (АС-2(5))                                | 16 |
| 1.2.3  | ДЕАКТИВАЦІЯ ОБЛКОВИХ ЗАПИСІВ ОСІБ З ВИСОКИМ РІВНЕМ РИЗИКУ (АС-2(13))                | 17 |
| 1.3    | ЗАБЕЗПЕЧЕННЯ ДОСТУПУ (АС-3)                                                         | 17 |
| 1.4    | УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ (АС-4)                                           | 17 |
| 1.5    | РОЗМЕЖУВАННЯ ОBOB'ЯЗКІВ (АС-5)                                                      | 18 |
| 1.6    | МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ (АС-6)                                                      | 18 |
| 1.6.1  | АВТОРИЗОВАНИЙ ДОСТУП ДО ФУНКЦІЙ БЕЗПЕКИ (АС-6(1))                                   | 18 |
| 1.6.2  | НЕПРИВІЛЕЙОВАНИЙ ДОСТУП ДО НЕЗАХИЩЕНИХ ФУНКЦІЙ (АС-6(2))                            | 19 |
| 1.6.3  | ПРИВІЛЕЙОВАНИ ОБЛКОВІ ЗАПИСИ (АС-6(5))                                              | 20 |
| 1.6.4  | ПЕРЕГЛЯД ПОВНОВАЖЕНЬ КОРИСТУВАЧА (АС-6(7))                                          | 20 |
| 1.6.5  | АУДИТ ВИКОРИСТАННЯ ПРИВІЛЕЙОВАНИХ ФУНКЦІЙ (АС-6(9))                                 | 21 |
| 1.6.6  | ЗАБОРОНА НЕПРИВІЛЕЙОВАНИМ КОРИСТУВАЧАМ ВИКОНУВАТИ ПРИВІЛЕЙОВАНИ ФУНКЦІЇ (АС-6(10))  | 21 |
| 1.7    | НЕВДАЛІ СПРОБИ ВХОДУ В СИСТЕМУ (АС-7)                                               | 21 |
| 1.8    | ПОПЕРЕДЖЕННЯ ПРО ВИКОРИСТАННЯ СИСТЕМИ (АС-8)                                        | 22 |
| 1.9    | БЛОКУВАННЯ ПРИСТРОЮ (АС-11)                                                         | 23 |
| 1.9.1  | ПРИХОВАНІ ДИСПЛЕЇ (АС-11(1))                                                        | 24 |
| 1.10   | Припинення сеансу (АС-12)                                                           | 24 |
| 1.11   | ВІДДАЛЕНИЙ ДОСТУП (АС-17)                                                           | 24 |
| 1.11.1 | КЕРОВАНІ ТОЧКИ КОНТРОЛЮ ДОСТУПУ (АС-17(3))                                          | 25 |
| 1.11.2 | ПРИВІЛЕЙОВАНИ КОМАНДИ ТА ДОСТУП (АС-17(4))                                          | 25 |
| 1.12   | БЕЗДРОТОВИЙ ДОСТУП (АС-18)                                                          | 25 |
| 1.12.1 | АВТЕНТИФІКАЦІЯ ТА ШИФРУВАННЯ (АС-18(1))                                             | 26 |
| 1.12.2 | ВІДКЛЮЧЕННЯ БЕЗДРОТОВОЇ МЕРЕЖІ (АС-18(3))                                           | 26 |
| 1.13   | КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ (АС-19)                                    | 26 |
| 1.13.1 | ПОВНЕ ШИФРУВАННЯ ПРИСТРОЇВ ТА СХОВИЩ ІНФОРМАЦІЇ (АС-19(5))                          | 27 |
| 1.14   | ВИКОРИСТАННЯ ЗОВНІШНІХ СИСТЕМ (АС-20)                                               | 27 |
| 1.14.1 | ОБМЕЖЕННЯ НА АВТОРИЗОВАНЕ ВИКОРИСТАННЯ (АС-20(1))                                   | 28 |
| 1.14.2 | ПЕРЕНОСНІ ПРИСТРОЇ ЗБЕРІГАННЯ ДАНИХ (АС-20(2))                                      | 28 |
| 1.15   | ПУБЛІЧНО ДОСТУПНИЙ КОНТЕНТ (АС-22)                                                  | 29 |
| 2      | АТ                                                                                  | 30 |
| 2.1    | ПОЛІТИКА ТА ПРОЦЕДУРИ ПІДВИЩЕННЯ ОБІЗНАНОСТІ ТА НАВЧАННЯ (АТ-1)                     | 30 |
| 2.2    | НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ (АТ-2)                                            | 30 |
| 2.2.1  | НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ   НАВЧАННЯ ЩОДО РОЗПІЗНАВАННЯ ВНУТРІШНЬОЇ ЗАГРОЗИ | 32 |
| 2.2.2  | НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ   НАВЧАННЯ З ПИТАНЬ СОЦІАЛЬНОЇ ІНЖЕНЕРІЇ          | 33 |
| 2.3    | РОЛЬОВЕ НАВЧАННЯ (АТ-3)                                                             | 33 |
| 3      | AU                                                                                  | 35 |
| 3.1    | Політика та процедури аудиту та підзвітності (AU-1)                                 | 35 |
| 3.2    | ПОДІЇ АУДИТУ (AU-2)                                                                 | 37 |
| 3.3    | ЗМІСТ ЗАПИСІВ АУДИТУ (AU-3)                                                         | 38 |

|       |                                                                                                    |    |
|-------|----------------------------------------------------------------------------------------------------|----|
| 3.3.1 | ДОДАТКОВА ІНФОРМАЦІЯ ПРО АУДИТ (AU-3(1)) . . . . .                                                 | 39 |
| 3.4   | РЕАГУВАННЯ НА ВІДМОВИ ОБРОБКИ ДАНИХ АУДИТУ (AU-5) . . . . .                                        | 39 |
| 3.5   | ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ (AU-6) . . . . .                                                  | 40 |
| 3.5.1 | ЗІСТАВЛЯННЯ СХОВИЩ АУДИТУ (AU-6(3)) . . . . .                                                      | 41 |
| 3.6   | СКОРОЧЕННЯ ЗАПИСІВ АУДИТУ ТА ФОРМУВАННЯ ЗВІТУ (AU-7) . . . . .                                     | 41 |
| 3.7   | ПОЗНАЧКА ЧАСУ (AU-8) . . . . .                                                                     | 42 |
| 3.8   | ЗАХИСТ ІНФОРМАЦІЇ АУДИТУ (AU-9) . . . . .                                                          | 42 |
| 3.8.1 | ДОСТУП, ЯКИЙ НАДАЄТЬСЯ ЧЕРЕЗ ЧЛЕНСТВО В ПІДМНОЖИНИ ПРИВІЛЕЙОВАНИХ КОРИСТУВАЧІВ (AU-9(4)) . . . . . | 43 |
| 3.9   | ЗБЕРЕЖЕННЯ ЗАПИСІВ АУДИТУ (AU-11) . . . . .                                                        | 43 |
| 3.10  | ГЕНЕРАЦІЯ ДАНИХ АУДИТУ (AU-12) . . . . .                                                           | 44 |
| 4     | СА . . . . .                                                                                       | 45 |
| 4.1   | ПОЛІТИКА І ПРОЦЕДУРИ ОЦІНЮВАННЯ, АКРЕДИТАЦІЯ ТА МОНІТОРИНГ БЕЗПЕКИ (СА-1) . . . . .                | 45 |
| 4.2   | ОЦІНЮВАННЯ (СА-2) . . . . .                                                                        | 47 |
| 4.3   | ВЗАЄМОДІЯ СИСТЕМ (СА-3) . . . . .                                                                  | 48 |
| 4.4   | ПЛАН УСУНЕННЯ НЕДОЛІКІВ ТА КОНТРОЛЬНІ ПОКАЗНИКИ (СА-5) . . . . .                                   | 50 |
| 4.5   | БЕЗПЕРЕРВНИЙ МОНІТОРИНГ (СА-7) . . . . .                                                           | 50 |
| 5     | СМ . . . . .                                                                                       | 53 |
| 5.1   | Політика та процедури управління конфігурацією (СМ-1) . . . . .                                    | 53 |
| 5.2   | БАЗОВА КОНФІГУРАЦІЯ (СМ-2) . . . . .                                                               | 55 |
| 5.2.1 | КОНФІГУРАЦІЯ СИСТЕМ ТА КОМПОНЕНТІВ ДЛЯ СФЕР З ВИСОКИМ РИЗИКОМ (СМ-2(7)) . . . . .                  | 56 |
| 5.3   | УПРАВЛІННЯ ЗМІНАМИ КОНФІГУРАЦІЇ (СМ-3) . . . . .                                                   | 57 |
| 5.4   | АНАЛІЗ ВПЛИВУ НА БЕЗПЕКУ ТА ПРИВАТНІСТЬ (СМ-4) . . . . .                                           | 58 |
| 5.4.1 | ВЕРИФІКАЦІЯ ФУНКЦІЙ БЕЗПЕКИ ТА ПРИВАТНОСТІ (СМ-4(2)) . . . . .                                     | 59 |
| 5.5   | ОБМЕЖЕННЯ ДОСТУПУ ДО ЗМІНИ (СМ-5) . . . . .                                                        | 60 |
| 5.6   | НАЛАШТУВАННЯ КОНФІГУРАЦІЇ (СМ-6) . . . . .                                                         | 60 |
| 5.7   | МІНІМАЛЬНО НЕОБХІДНА ФУНКЦІОНАЛЬНІСТЬ (СМ-7) . . . . .                                             | 62 |
| 5.7.1 | ПЕРІОДИЧНИЙ ПЕРЕГЛЯД (СМ-7(1)) . . . . .                                                           | 63 |
| 5.7.2 | АВТОРИЗОВАНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ – БІЛИЙ СПИСОК (СМ-7(5)) . . . . .                             | 64 |
| 5.8   | ІНВЕНТАРИЗАЦІЯ КОМПОНЕНТІВ СИСТЕМИ (СМ-8) . . . . .                                                | 65 |
| 5.8.1 | ОНОВЛЕННЯ ПІД ЧАС ВСТАНОВЛЕННЯ ТА ВИДАЛЕННЯ (СМ-8(1)) . . . . .                                    | 66 |
| 5.9   | РОЗТАШУВАННЯ ІНФОРМАЦІЇ (СМ-12) . . . . .                                                          | 67 |
| 6     | СР . . . . .                                                                                       | 67 |
| 6.1   | РЕЗЕРВНЕ КОПЮВАННЯ (СР-9) . . . . .                                                                | 68 |
| 6.1.1 | КРИПТОГРАФІЧНИЙ ЗАХИСТ (СР-9(8)) . . . . .                                                         | 69 |
| 7     | ІА . . . . .                                                                                       | 69 |
| 7.1   | Політика та процедури ідентифікації та автентифікації (ІА-1) . . . . .                             | 70 |
| 7.2   | ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ КОРИСТУВАЧІВ (ІА-2) . . . . .                                      | 71 |
| 7.2.1 | БАГАТОФАКТОРНА АВТЕНТИФІКАЦІЯ ПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ (ІА-2(1)) . . . . .                 | 71 |
| 7.2.2 | БАГАТОФАКТОРНА АВТЕНТИФІКАЦІЯ НЕПРИВІЛЕЙОВАНИХ (ІА-2(2)) . . . . .                                 | 72 |
| 7.2.3 | Доступ до облікових записів — стійкість до відтворення (ІА-2(8)) . . . . .                         | 72 |
| 7.3   | ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ ПРИСТРОЇВ (ІА-3) . . . . .                                         | 72 |
| 7.4   | УПРАВЛІННЯ ІДЕНТИФІКАЦІЄЮ (ІА-4) . . . . .                                                         | 72 |
| 7.4.1 | ІДЕНТИФІКАЦІЯ СТАТУСУ КОРИСТУВАЧА (ІА-4(4)) . . . . .                                              | 73 |
| 7.5   | АВТЕНТИФІКАТОР УПРАВЛІННЯ . . . . .                                                                | 73 |
| 7.5.1 | АВТЕНТИФІКАЦІЯ НА ОСНОВІ ПАРОЛЯ (ІА-5(1)) . . . . .                                                | 75 |
| 7.6   | ПРИХОВУВАННЯ ЗВОРОТНОГО ЗВ'ЯЗКУ АВТЕНТИФІКАТОРА . . . . .                                          | 76 |
| 7.7   | ПОВТОРНА АВТЕНТИФІКАЦІЯ (ІА-11) . . . . .                                                          | 76 |
| 8     | ІР . . . . .                                                                                       | 76 |

|        |                                                                                              |     |
|--------|----------------------------------------------------------------------------------------------|-----|
| 8.1    | Політика та процедури реагування на інциденти (IR-1) . . . . .                               | 77  |
| 8.2    | НАВЧАННЯ З РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-2) . . . . .                                          | 78  |
| 8.3    | ПЕРЕВІРКА РЕАГУВАНЬ НА ІНЦИДЕНТИ (IR-3) . . . . .                                            | 79  |
| 8.4    | Обробка інциденту (IR-4) . . . . .                                                           | 80  |
| 8.5    | Моніторинг інциденту (IR-5) . . . . .                                                        | 81  |
| 8.6    | ЗВІТНІСТЬ ПРО ІНЦИДЕНТИ (IR-6) . . . . .                                                     | 81  |
| 8.7    | ПІДТРИМКА РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-7) . . . . .                                           | 82  |
| 8.8    | План реагування на інциденти (IR-8) . . . . .                                                | 82  |
| 9      | МА . . . . .                                                                                 | 85  |
| 9.1    | ПОЛІТИКА ТА ПРОЦЕДУРИ ТЕХНІЧНОГО ОБСЛУГОВУВАННЯ (МА-1) . . . . .                             | 85  |
| 9.2    | ІНСТРУМЕНТИ ДЛЯ ОБСЛУГОВУВАННЯ (МА-3) . . . . .                                              | 87  |
| 9.2.1  | ПЕРЕВІРКА ІНСТРУМЕНТІВ (МА-3(1)) . . . . .                                                   | 88  |
| 9.2.2  | ПЕРЕВІРКА НОСІВ ІНФОРМАЦІЇ (МА-3(2)) . . . . .                                               | 88  |
| 9.2.3  | ЗАПОБІГАННЯ НЕСАНКЦІОНОВАНОМУ ПЕРЕМІЩЕННЮ (МА-3(3)) . . . . .                                | 88  |
| 9.3    | ВІДДАЛЕНЕ ОБСЛУГОВУВАННЯ (МА-4) . . . . .                                                    | 89  |
| 9.4    | ТЕХНІЧНИЙ ПЕРСОНАЛ (МА-5) . . . . .                                                          | 90  |
| 10     | MP . . . . .                                                                                 | 91  |
| 10.1   | ПОЛІТИКА ТА ПРОЦЕДУРИ ЩОДО ЗАХИСТУ НОСІВ ІНФОРМАЦІЇ (MP-1) . . . . .                         | 91  |
| 10.2   | ДОСТУП ДО НОСІВ ІНФОРМАЦІЇ (MP-2) . . . . .                                                  | 93  |
| 10.3   | МАРКУВАННЯ НОСІВ ІНФОРМАЦІЇ (MP-3) . . . . .                                                 | 93  |
| 10.4   | ЗБЕРІГАННЯ НОСІВ ІНФОРМАЦІЇ (MP-4) . . . . .                                                 | 94  |
| 10.5   | Транспортування носіїв інформації (MP-5) . . . . .                                           | 96  |
| 10.6   | ЗНИЩЕННЯ ІНФОРМАЦІЇ НА НОСІЯХ ІНФОРМАЦІЇ (MP-6) . . . . .                                    | 97  |
| 10.7   | ВИКОРИСТАННЯ НОСІВ ІНФОРМАЦІЇ (MP-7) . . . . .                                               | 98  |
| 11     | PE . . . . .                                                                                 | 99  |
| 11.1   | PE-1 фізичного захисту та захисту робочого середовища Авторизація фізичного (PE-1) . . . . . | 99  |
| 11.2   | PE-2 доступу (PE-2) . . . . .                                                                | 101 |
| 11.3   | ФІЗИЧНИЙ ДОСТУП ДО СИСТЕМИ . . . . .                                                         | 102 |
| 11.4   | PE-4 ліній електроживлення (PE-4) . . . . .                                                  | 104 |
| 11.5   | КОНТРОЛЬ ДОСТУПУ В ПРИМІЩЕННЯ ДЛЯ ВІДОБРАЖЕННЯ ІНФОРМАЦІЇ . . . . .                          | 105 |
| 11.6   | МОНІТОРИНГ ФІЗИЧНОГО ДОСТУПУ . . . . .                                                       | 105 |
| 11.7   | АЛЬТЕРНАТИВНЕ РОБОЧЕ МІСЦЕ (PE-17) . . . . .                                                 | 106 |
| 12     | PL . . . . .                                                                                 | 106 |
| 12.1   | ПОЛІТИКИ ТА ПРОЦЕДУРИ ПЛАНУВАННЯ БЕЗПЕКИ (PL-1) . . . . .                                    | 106 |
| 12.2   | ПЛАНІ ЗАХИСТУ ІНФОРМАЦІЇ ТА ПЕРСОНАЛЬНИХ ДАНИХ (PL-2) . . . . .                              | 107 |
| 12.3   | ПРАВИЛА ПОВЕДІНКИ (PL-4) . . . . .                                                           | 109 |
| 13     | PS . . . . .                                                                                 | 110 |
| 13.1   | Політика та процедури кадрової безпеки (PS-1) . . . . .                                      | 110 |
| 13.2   | Перевірка персоналу (PS-3) . . . . .                                                         | 111 |
| 13.3   | Звільнення персоналу (PS-4) . . . . .                                                        | 112 |
| 13.4   | Переведення персоналу (PS-5) . . . . .                                                       | 112 |
| 14     | RA . . . . .                                                                                 | 113 |
| 14.1   | ПОЛІТИКА ТА ПРОЦЕДУРИ ОЦІНЮВАННЯ РИЗИКУ (RA-1) . . . . .                                     | 113 |
| 14.2   | ОЦІНЮВАННЯ РИЗИКУ (RA-3) . . . . .                                                           | 114 |
| 14.2.1 | ОЦІНЮВАННЯ ПОСТАЧАННЯ (RA-3(1)) . . . . .                                                    | 115 |
| 14.3   | СКАНУВАННЯ ВРАЗЛИВОСТЕЙ (RA-5) . . . . .                                                     | 115 |
| 14.3.1 | Оновлення за частотою, перед новим скануванням або при ідентифікації (RA-5(2)) . . . . .     | 116 |
| 14.4   | РЕАГУВАННЯ НА РИЗИК (RA-7) . . . . .                                                         | 116 |
| 15     | SA . . . . .                                                                                 | 117 |

|         |                                                                     |     |
|---------|---------------------------------------------------------------------|-----|
| 15.1    | ПОЛІТИКИ ТА ПРОЦЕДУРИ ПРИДБАННЯ СИСТЕМ ТА ПОСЛУГ (SA-1)             | 117 |
| 15.2    | БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ ІНЖИНІРИНГУ (SA-8)                 | 118 |
| 15.3    | ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ (SA-9)                                 | 120 |
| 15.4    | КОМПОНЕНТИ СИСТЕМИ, ЩО НЕ ПІДТРИМУЮТЬСЯ (SA-22)                     | 120 |
| 16      | SC                                                                  | 121 |
| 16.1    | ПОЛІТИКА ТА ПРОЦЕДУРИ ЗАХИСТУ СИСТЕМИ ТА КОМУНІКАЦІЙ (SC-1)         | 121 |
| 16.2    | ІНФОРМАЦІЯ В ЗАГАЛЬНИХ СИСТЕМНИХ РЕСУРСАХ (SC-4)                    | 122 |
| 16.3    | ДОСТУПНІСТЬ РЕСУРСІВ (SC-7)                                         | 123 |
| 16.3.1  | ВІДМОВА ЗА ЗАМОВЧУВАННЯМ - ДОЗВІЛ ЗА ВИНЯТКОМ (SC-7(5))             | 123 |
| 16.4    | КОНФІДЕНЦІЙНІСТЬ ТА ЦІЛІСНІСТЬ ПЕРЕДАЧІ (SC-8)                      | 123 |
| 16.4.1  | КОНФІДЕНЦІЙНІСТЬ ТА КРИПТОГРАФІЧНИЙ ЗАХИСТ (SC-8(1))                | 123 |
| 16.5    | ВІДКЛЮЧЕННЯ МЕРЕЖІ (SC-10)                                          | 123 |
| 16.6    | ВСТАНОВЛЕННЯ КЛЮЧАМИ (SC-12)                                        | 124 |
| 16.7    | КРИПТОГРАФІЧНИЙ ЗАХИСТ (SC-13)                                      | 124 |
| 16.8    | СПІЛЬНІ ОБЧИСЛЮВАЛЬНІ ПРИСТРОЇ ТА ЗАСТОСУНКИ (SC-15)                | 125 |
| 16.9    | МОБІЛЬНИЙ КОД (SC-18)                                               | 125 |
| 16.10   | АВТЕНТИФІКАЦІЯ СЕСІЇ (SC-23)                                        | 125 |
| 16.11   | ЗАХИСТ ІНФОРМАЦІЇ В СТАНІ СПОКОЮ (SC-28)                            | 125 |
| 16.11.1 | ЗАХИСТ ІНФОРМАЦІЇ В СТАНІ СПОКОЮ   КРИПТОГРАФІЧНИЙ ЗАХИСТ           | 126 |
| 17      | SI                                                                  | 126 |
| 17.1    | ПОЛІТИКА І ПРОЦЕДУРИ ЦІЛІСНОСТІ ІНФОРМАЦІЇ (SI-1)                   | 126 |
| 17.2    | ВИПРАВЛЕННЯ ДЕФЕКТІВ (SI-2)                                         | 127 |
| 17.3    | ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ (SI-3)                                   | 128 |
| 17.4    | МОНІТОРИНГ СИСТЕМИ (SI-4)                                           | 128 |
| 17.4.1  | МОНІТОРИНГ СИСТЕМИ КОМУНІКАЦІЙ (SI-4(4))                            | 129 |
| 17.5    | ПОПЕРЕДЖЕННЯ, РЕКОМЕНДАЦІЇ ТА ДИРЕКТИВИ З БЕЗПЕКИ (SI-5)            | 129 |
| 17.6    | УПРАВЛІННЯ ТА ЗБЕРЕЖЕННЯ ІНФОРМАЦІЇ (SI-12)                         | 130 |
| 18      | SR                                                                  | 131 |
| 18.1    | ПОЛІТИКА ТА ПРОЦЕДУРИ УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ (SR-1) | 131 |
| 18.2    | ПЛАН УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ (SR-2)                  | 132 |
| 18.3    | КОНТРОЛЬ ЛАНЦЮГА ПОСТАЧАННЯ І ПРОЦЕСІВ (SR-3)                       | 133 |
| 18.4    | СТРАТЕГІЇ ПРИДБАННЯ, ІНСТРУМЕНТИ І МЕТОДИ (SR-5)                    | 134 |
| 18.5    | ОЦІНКА ПОСТАЧАЛЬНИКІВ (SR-6)                                        | 134 |

#### Анотація

Базовий профіль — затверджується Адміністрацією Держспецзв'язку (наказом).

## 1. АС

### Клас заходів захисту АС — УПРАВЛІННЯ ДОСТУПОМ

Цей клас зосереджується на обмеженні доступу до інформаційних систем, ресурсів та функцій лише для авторизованих користувачів, програм і пристроїв.

Перелік заходів захисту: Політика та процедури управління доступом (АС-1); Управління обліковими записами (АС-2); Деактивація облікових записів (АС-2(3)); Вихід із системи за відсутності активності (АС-2(5)); Деактивація облікових записів осіб з високим рівнем ризику (АС-2(13)); Забезпечення доступу (АС-3); Управління інформаційними потоками (АС-4); Розмежування обов'язків (АС-5); Мінімізація повноважень (АС-6); Авторизований доступ до функцій безпеки (АС-6(1)); Непривілейований доступ до незахищених функцій (АС-6(2)); Привілейовані облікові записи (АС-6(5)); Перегляд повноважень користувача (АС-6(7)); Аудит

використання привілейованих функцій (АС-6(9)); Заборона непривілейованим користувачам виконувати привілейовані функції (АС-6(10)); Невдалі спроби входу в систему (АС-7); Попередження про використання системи (АС-8); Блокування пристрою (АС-11); Приховані дисплеї (АС-11(1)); Припинення сеансу (АС-12); Віддалений доступ (АС-17); Керовані точки контролю доступу (АС-17(3)); Привілейовані команди та доступ (АС-17(4)); Бездротовий доступ (АС-18); Автентифікація та шифрування (АС-18(1)); Відключення бездротової мережі (АС-18(3)); Контроль доступу для мобільних пристроїв (АС-19); Повне шифрування пристроїв та сховищ інформації (АС-19(5)); Використання зовнішніх систем (АС-20); Обмеження на авторизоване використання (АС-20(1)); Переносні пристрої зберігання даних (АС-20(2)); Публічно доступний контент (АС-22).

## 1.1. ПОЛІТИКА ТА ПРОЦЕДУРИ УПРАВЛІННЯ ДОСТУПОМ (АС-1)

а. Розробити, задокументувати та поширити [Призначення: серед визначеного організацією персоналу або ролей]:

1. 2. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політики контролю доступу, яка:

(а) містить мету, сферу застосування, ролі, відповідальність, зобов'язання керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliances);  
(б) відповідає чинному законодавству, нормативним документам, директивам, нормам, політикам, стандартам і керівним документам. Процедури, що сприяють реалізації політики управління доступом і відповідних заходів управління доступом.

б. Призначити на посаду [Призначення: визначену організацією посадову особу] для управління, документування і розповсюдження політики та процедур контролю доступу.

с. Переглянути та оновити:

1. поточну політику управління доступом [Призначення: з визначеною організацією частотою] та [Призначення: події, визначені організацією];

2. поточні процедури управління доступом [Призначення: з визначеною організацією частотою] та [Завдання: події, визначені організацією].

No: 1

Name: ac\_1\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на які поширюється політика контролю доступу

No: 2

Name: ac\_1\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на які поширюються процедури контролю доступу

No: 3

Name: ac\_1\_odp\_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 4

Name: ac\_1\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами контролю доступу

No: 5

Name: ac\_1\_odp\_05

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика контролю доступу

No: 6

Name: ac\_1\_odp\_06

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено події, які вимагають перегляду та оновлення поточної політики контролю доступу

No: 7

Name: ac\_1\_odp\_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури контролю доступу

## 1.2. УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ (АС-2)

- a. Визначити та задокументувати типи облікових записів системи, дозволених для використання в ІС для підтримки цілей, завдань, функцій і процесів організації.
- b. Призначити менеджерів облікових записів для управління системними обліковими записами.
- c. Створити умови для групового та рольового членства.
- d. Визначити авторизованих користувачів інформаційної системи, членство в групі та ролі, а також дозволи доступу (наприклад, привілеї) та інші атрибути (за потреби) для кожного облікового запису.
- e. Вимагати схвалення [Призначення: визначеною організацією відповідальною особою або роллю] запитів на створення облікових записів системи.
- f. Створювати, активувати, змінювати, деактивувати та видаляти системні облікові записи відповідно до [Призначення: визначених організацією політики, процедур та умов].
- g. Впровадити моніторинг використання облікових записів системи.
- h. Повідомляти адміністраторів облікових записів у межах [Призначення: визначеного організації часового періоду для кожної ситуації]:
  1. коли облікові записи більше не потрібні;
  2. коли користувачі звільнені чи переведені;
  3. коли використовуються індивідуальні системи або наявні зміни, які потребують нових знань.
- i. Авторизувати доступ до системи на основі:
  1. Дійсної авторизації доступу.
  2. Передбачуваного використання системи.
  3. Інших атрибутів, що вимагаються організацією.
- j. Проводити перегляд облікових записів на відповідність вимогам управління обліковими записами з [Призначення: визначеною організацією частотою].
- k. Впровадити процес повторного випуску облікових даних спільного/групового облікового запису (якщо він буде розгорнутий), коли особи виходять з групи.
- l. Узгодити процеси управління обліковими записами з процесами звільнення та перевodu (передачі повноважень) персоналу.

No: 1

Name: ac\_2\_odp\_09

Type: integer

Default: 24

Визначено передумови та критерії членства в групах і ролях; визначено атрибути (за необхідності) для кожного облікового запису; визначено персонал або ролі, необхідні для затвердження запитів на створення облікових записів; визначено політику, процедури, передумови та критерії створення, активації, зміни, деактивації та видалення облікових записів; визначено персонал або ролі, які мають бути повідомлені; визначено період часу, протягом якого адміністратори облікових записів повинні бути повідомлені про те, що облікові записи більше не потрібні; визначено термін, протягом якого необхідно повідомляти адміністраторів облікових записів про звільнення або переведення користувачів; визначено період часу, протягом якого необхідно повідомляти адміністраторів облікових записів про зміни у використанні системи або необхідність знати про зміни для окремої особи; визначено атрибути, необхідні для авторизації доступу до системи (за потреби); AC-02\_ODP[10] AC-02a.[01] AC-02a.[02] AC-02b AC-02c AC-02d.01 AC-02d.02 AC-02d.03[01] AC-02d.03[02] AC-02e AC-02f.[01] AC-02f.[02] AC-02f.[03] AC-02f.[04] AC-02f.[05] AC-02g AC-02h.01 AC-02h.02 AC-02h.03 AC-02i.01 AC-02i.02 AC-02i.03 визначено періодичність перегляду облікових записів; визначено та задокументовано типи облікових записів, дозволених для використання в системі; визначено та задокументовано типи облікових записів, які заборонено використовувати в системі; призначені менеджери облікових записів; необхідні умови та критерії для членства в групах та ролях; визначено авторизованих користувачів системи; вказано приналежність до групи або ролі; для кожного облікового запису вказуються повноваження доступу (тобто привілеї); атрибути (за необхідності) вказуються для кожного облікового запису; для запитів на створення облікових записів потрібні схвалення від персоналу або ролей; облікові записи створюються відповідно до політики, процедур, передумов та критеріїв; облікові записи активуються відповідно до політики, процедур, передумов та критеріїв; облікові записи змінюються відповідно до політики, процедур, передумов та критеріїв; облікові записи деактивуються відповідно до політики, процедур, передумов та критеріїв; облікові записи видаляються відповідно до політики, процедур, передумов та критеріїв; контролюється використання облікових записів; адміністратори облікових записів та персонал або ролі отримують повідомлення протягом періоду часу, коли облікові записи більше не потрібні; адміністратори облікових записів та персонал або ролі отримують повідомлення протягом періоду часу, коли користувачі звільнені чи переведені; адміністратори облікових записів та персонал або ролі отримують повідомлення протягом періоду часу, коли використовуються індивідуальні системи або наявні зміни, які потребують нових знань. доступ до системи здійснюється на підставі дійсної авторизації доступу; доступ до системи авторизується на основі передбачуваного використання системи; доступ до системи авторизовано на основі атрибутів (за необхідності); AC-02j AC-02k.[01] AC-02k.[02] AC-02l.[01] AC-02l.[02] облікові записи переглядаються на відповідність вимогам управління обліковими записами частота; створено процес повторного випуску облікових даних спільного доступу або групових облікових записів (якщо вони розгорнуті), коли користувачів вилучено з групи; впроваджено процес повторного випуску облікових даних спільного доступу або групових облікових записів (якщо вони розгорнуті), коли користувачів вилучено з групи; процеси управління обліковими записами узгоджуються з процесами звільнення персоналу; процеси управління обліковими записами узгоджуються з процесами переведення персоналу

### 1.2.1. ДЕАКТИВАЦІЯ ОБЛІКОВИХ ЗАПИСІВ (AC-2(3))

Автоматично деактивувати облікові записи коли: а) їх строк дії минув; б) вони більше не пов'язані з користувачем; с) вони порушують організаційну політику; d) вони були неактивними впродовж [Призначення: визначеного організацією періоду часу].

No: 1

Name: ac\_2\_3\_b

Type: list

Default: ["admin", "security\_officer"]

Облікові записи деактивуються протягом часового періоду, коли облікові записи більше не пов'язані з користувачем або фізичною особою

No: 2

Name: ac\_2\_3\_d



Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Облікові записи відключено протягом часового періоду, коли облікові записи порушують політику організації; облікові записи деактивуються протягом , якщо вони були неактивними протягом

No: 3

Name: ac\_2\_3\_odp\_01

Type: integer

Default: 30

Визначено період часу, протягом якого необхідно деактивувати облікові записи

No: 4

Name: ac\_2\_3\_odp\_02

Type: list

Default: ["login", "logout", "failed\_attempt"]

Визначено період часу неактивності, після закінчення якого облікові записи будуть деактивовані; АС-02(03)(а) облікові записи деактивуються протягом часового періоду, коли термін дії облікових записів минув

## 1.2.2. ВИХІД ІЗ СИСТЕМИ ЗА ВІДСУТНОСТІ АКТИВНОСТІ (АС-2(5))

Вимагати від користувачів виходити із системи, коли [Призначення: вичерпано визначений організацією період часу очікування або опис того, коли необхідно вийти із системи].

No: 1

Name: ac\_2\_5\_01

Type: integer

Default: 30

Користувачі повинні виходити з системи, коли період очікуваної бездіяльності або опис часу, коли потрібно вийти з системи

No: 2

Name: ac\_2\_5\_odp

Type: integer

Default: 30

Визначено часовий період очікуваної бездіяльності або опис, коли потрібно вийти з системи

## 1.2.3. ДЕАКТИВАЦІЯ ОБЛІКОВИХ ЗАПИСІВ ОСІБ З ВИСОКИМ РІВНЕМ РИЗИКУ (АС-2(13))

Деактивувати облікові записи користувачів, які становлять значний ризик, у межах [Призначення: визначеного організацією періоду часу] після виявлення ризику.

No: 1

Name: ac\_2\_13\_01

Type: integer

Default: 30

Облікові записи користувачів деактивуються протягом періоду часу з моменту виявлення значних ризиків

No: 2

Name: ac\_2\_13\_odp\_01

Type: integer

Default: 30

Визначено період часу, протягом якого необхідно деактивувати облікові записи фізичних осіб, які становлять значний ризик

No: 3

Name: ac\_2\_13\_odp\_02

Type: string

Default: nil

Визначено значні ризики, що призводять до деактивації облікових записів

### 1.3. ЗАБЕЗПЕЧЕННЯ ДОСТУПУ (АС-3)

Застосовувати затверджені повноваження для логічного доступу до інформації та ресурсів системи відповідно до чинної політики (правил) управління доступом.

No: 1

Name: ac\_3\_01

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Затверджені повноваження на логічний доступ до інформації та ресурсів системи виконуються відповідно до чинних політик(правил) управління доступом

### 1.4. УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ (АС-4)

Застосувати затверджені повноваження для управління потоком інформації всередині системи та між пов'язаними системами на основі [Призначення: визначеними організацією політиками управління інформаційним потоком].

No: 1

Name: ac\_4\_01

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Затверджені повноваження застосовуються для контролю потоку інформації всередині системи та між підключеними системами на основі політики управління інформаційними потоками

No: 2

Name: ac\_4\_odp

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено політики управління інформаційними потоками всередині системи та між підключеними системами

### 1.5. РОЗМЕЖУВАННЯ ОBOB'ЯЗКІВ (АС-5)

а. Розмежувати і документувати [Призначення: визначені організацією обов'язки окремих осіб].

б. Установити правила авторизації доступу для підтримки розмежування обов'язків.

No: 1

Name: ac\_5\_odp

Type: string

Default: nil

Визначено обов'язки осіб, які потребують розмежування; AC-05[a] обов'язки осіб визначені та задокументовані; AC-05[b] визначено права авторизації доступу до системи для підтримки розмежування обов'язків

## 1.6. МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ (AC-6)

Впровадити принцип мінімізації повноважень, який дозволяє користувачам (або процесам, що діють від імені користувачів) здійснювати лише такі авторизовані звернення, які необхідні для виконання визначених завдань відповідно до цілей (призначення, місії) організації та функцій.

No: 1

Name: ac\_6\_01

Type: string

Default: nil

Застосовується принцип мінімізації повноважень, який дозволяє користувачам (або процесам, що діють від імені користувачів) здійснювати лише такі авторизовані звернення, які необхідні для виконання поставлених завдань організації

### 1.6.1. АВТОРИЗОВАНИЙ ДОСТУП ДО ФУНКЦІЙ БЕЗПЕКИ (AC-6(1))

No: 1

Name: ac\_6\_1\_a\_01

Type: string

Default: nil

Авторизовано доступ для осіб та ролей до функцій безпеки (розгорнуті на апаратному забезпеченні)

No: 2

Name: ac\_6\_1\_a\_02

Type: string

Default: nil

Авторизовано доступ для осіб та ролей до функцій безпеки (розгорнуті на програмному забезпеченні)

No: 3

Name: ac\_6\_1\_a\_03

Type: string

Default: nil

Авторизовано доступ для осіб та ролей до функцій безпеки (розгорнуті на мікропрограмному забезпеченні)

No: 4

Name: ac\_6\_1\_b

Type: string

Default: nil

Авторизовано доступ для осіб та ролей до інформації

No: 5

Name: ac\_6\_1\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначені особи або ролі з авторизованим доступом до функцій безпеки та інформації, що має відношення до безпеки

No: 6  
 Name: ac\_6\_1\_odp\_02  
 Type: string  
 Default: nil

Визначені функції безпеки (розгорнуті в апаратному забезпеченні) для авторизованого доступу

No: 7  
 Name: ac\_6\_1\_odp\_03  
 Type: string  
 Default: nil

Визначені функції безпеки (розгорнуті в програмному забезпеченні) для авторизованого доступу

No: 8  
 Name: ac\_6\_1\_odp\_04  
 Type: string  
 Default: nil

Визначені функції безпеки (розгорнуті в мікропрограмному забезпеченні) для авторизованого доступу

No: 9  
 Name: ac\_6\_1\_odp\_05  
 Type: string  
 Default: nil

Визначено інформацію, важливу для забезпечення безпеки, для авторизованого доступу

## 1.6.2. НЕПРИВІЛЕЙОВАНИЙ ДОСТУП ДО НЕЗАХИЩЕНИХ ФУНКЦІЙ (АС-6(2))

Вимагати від користувачів облікових записів системи або ролей, які мають доступ до [Призначення: визначених організацією функцій безпеки або інформації, що стосується безпеки], використовувати непривілейовані облікові записи чи ролі під час доступу до незахищених функцій.

No: 1  
 Name: ac\_6\_2\_01  
 Type: list  
 Default: ["admin", "security\_officer"]

Користувачі облікових записів (або ролей) системи з доступом до функцій безпеки або інформації, що стосується безпеки, повинні використовувати непривілейовані облікові записи або ролі під час доступу до незахищених функцій

No: 2  
 Name: ac\_6\_2\_odp  
 Type: string  
 Default: nil

Визначені функції безпеки або інформація, що стосується безпеки

## 1.6.3. ПРИВІЛЕЙОВАНИ ОБЛІКОВІ ЗАПИСИ (АС-6(5))

Обмежити привілейовані облікові записи в системі згідно з [Призначення: визначеним організацією персоналом або ролями].

No: 1  
 Name: ac\_6\_5\_01  
 Type: list  
 Default: ["admin", "security\_officer"]

Привілейовані облікові записи в системі обмежено персонал або ролі

No: 2  
 Name: ac\_6\_5\_odp  
 Type: list  
 Default: ["admin", "security\_officer"]

Визначено персонал або ролі, яким мають бути обмежені привілейовані облікові записи в системі

#### 1.6.4. ПЕРЕГЛЯД ПОВНОВАЖЕНЬ КОРИСТУВАЧА (АС-6(7))

а) Переглядати [Призначення: з визначеною організацією частотою] повноваження призначених для [Призначення: визначених організацією посад або класів користувачів] для перевірки необхідності таких повноважень; б) За необхідності перепризначити або зняти повноваження, правильного відображення цілей (місії) організації та потреб організації. для

No: 1  
 Name: ac\_6\_7\_a  
 Type: integer  
 Default: 30

Повноваження, призначені ролям і класам, переглядаються з частотою для перевірки необхідності таких повноважень

No: 2  
 Name: ac\_6\_7\_b  
 Type: string  
 Default: nil

Привілеї перепризначаються або знімаються, якщо це необхідно, для правильного відображення місії організації та потреб

No: 3  
 Name: ac\_6\_7\_odp\_01  
 Type: integer  
 Default: 30

Визначено частоту перегляду повноважень, призначених ролям або класам користувачів

No: 4  
 Name: ac\_6\_7\_odp\_02  
 Type: list  
 Default: ["admin", "security\_officer"]

Визначено ролі або класи користувачів, яким призначено повноваження

#### 1.6.5. АУДИТ ВИКОРИСТАННЯ ПРИВІЛЕЙОВАНИХ ФУНКЦІЙ (АС-6(9))

Реєструвати виконання привілейованих функцій.

No: 1  
 Name: ac\_6\_9\_01  
 Type: string  
 Default: nil

Проводиться аудит виконання привілейованих функцій

### 1.6.6. ЗАБОРОНА НЕПРИВІЛЕЙОВАНИМ КОРИСТУВАЧАМ ВИКОНУВАТИ ПРИВІЛЕЙОВАНІ ФУНКЦІЇ (АС-6(10))

Вжити заходи для запобігання можливості виконувати привілейовані функції непривілейованими користувачами.

No: 1

Name: ac\_6\_10\_01

Type: string

Default: nil

МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ - ЗАБОРОНА НЕПРИВІЛЕЙОВАНИМ КОРИСТУВАЧАМ ВИКОНУВАТИ ПРИВІЛЕЙОВАНІ ФУНКЦІЇ МЕТА ОЦІНКИ: Визначити, чи:

## 1.7. НЕВДАЛІ СПРОБИ ВХОДУ В СИСТЕМУ (АС-7)

а. Встановити обмеження на [Призначення: визначену організацією кількість] послідовних неуспішних спроб входу користувача в систему впродовж [Призначення: визначеного організацією часового періоду].

б. Автоматично виконати [Вибір (один або декілька): блокування облікового запису/вузла на [Призначення: визначений організацією часовий період]; блокування облікового запису/вузла, доки він не буде розблокований адміністратором; затримання наступної команди входу в систему за [Надання: визначеним організацією алгоритмом затримки]; виконати [Призначення: визначені організацією дії]], коли перевищено максимальну кількість невдалих спроб входу в систему.

No: 1

Name: ac\_7\_a

Type: integer

Default: 30

Застосовано обмеження на кількість послідовних неуспішних спроб входу користувача протягом періоду часу

No: 2

Name: ac\_7\_odp\_01

Type: integer

Default: 30

Визначається кількість послідовних неуспішних спроб входу користувача, дозволених протягом певного періоду часу

No: 3

Name: ac\_7\_odp\_02

Type: integer

Default: 30

Визначено період часу, яким обмежується кількість послідовних неуспішних спроб входу користувача

No: 4

Name: ac\_7\_odp\_03

Type: string

Default: "AES-256-GCM"

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {заблокувати обліковий запис або вузол на період часу; заблокувати обліковий запис або вузол до зняття адміністратором; затримати наступний запит на

вхід за алгоритмом затримки; повідомити системного адміністратора; виконати іншу дію}

No: 5

Name: ac\_7\_odp\_04

Type: integer

Default: 30

Період часу, на який буде заблоковано обліковий запис або вузол (якщо вибрано)

No: 6

Name: ac\_7\_odp\_05

Type: string

Default: "AES-256-GCM"

Визначено алгоритм затримки наступного запиту на вхід (якщо вибрано)

No: 7

Name: ac\_7\_odp\_06

Type: integer

Default: 3

Інша дія, яка буде виконана після перевищення максимальної кількості невдалих спроб (якщо вибрано)

## 1.8. ПОПЕРЕДЖЕННЯ ПРО ВИКОРИСТАННЯ СИСТЕМИ (АС-8)

a.

b. Демонструвати користувачам [Призначення: визначене організацією сповіщення або банер про використання системи] перед тим, як надавати доступ до системи, що забезпечує безпеку та приватність відповідно до чинних законів, нормативних документів, наказів, директив, політик, правил, стандартів і керівних принципів, які зазначають, що:

1. користувачі здійснюють доступ до урядової системи;
2. використання системи може контролюватися, реєструватися та підлягати аудиту;
3. несанкціоноване використання системи забороняється та приводить до кримінальної та цивільної відповідальності;
4. використання системи означає згоду на моніторинг і запис дій користувача. Зберігати сповіщення або банер на екрані, доки користувачі не визнають умови використання та не приймуть явних дій для входу в систему або подальшого доступу до системи.

c. Для загальнодоступних систем:

1. демонструвати інформацію про умови використання системи [Призначення: визначені організацією умови], перш ніж надавати подальший доступ до загальнодоступної системи;
2. демонструвати посилання, якщо такі є, на моніторинг, запис або аудит, які узгоджуються з акомодациєю приватності для таких систем, які зазвичай забороняють такі дії;
3. мати опис авторизованого використання системи.

No: 1

Name: ac\_8\_c\_02

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначається сповіщення або банер про використання системи, який система буде показувати користувачам перед наданням доступу до системи; визначено умови використання системи, які система відображатиме перед наданням подальшого доступу; повідомлення про використання системи відображається користувачам перед наданням доступу до системи, яке містить повідомлення про конфіденційність і безпеку, що відповідають чинним законам, нормативним документам, наказам, директивам, політикам, правилам, стандартам і керівним принципам; у повідомленні про використання системи зазначено, що користувачі отримують доступ до урядової системи; у повідомленні про використання системи зазначено, що використання системи може контролюватися,

реєструватися та підлягати аудиту; у повідомленні про використання системи зазначено, що несанкціоноване використання системи заборонено і тягне за собою кримінальну та цивільну відповідальність; у повідомленні про використання системи зазначено, що використання системи означає згоду на моніторинг і запис дій; сповіщення або банер залишається на екрані до тих пір, поки користувачі не визнають умови використання та не приймуть явні дії для входу в систему або подальшого доступу до неї; для загальнодоступних систем інформація про використання системи умови відображається перед наданням подальшого доступу до загальнодоступної системи; для загальнодоступних систем відображаються будь-які посилання на моніторинг, запис або аудит, які узгоджуються з положеннями про конфіденційність таких систем, що зазвичай забороняють ці види діяльності; для загальнодоступних систем додається опис авторизованого використання системи

## 1.9. БЛОКУВАННЯ ПРИСТРОЮ (АС-11)

- a. Заборонити подальший доступ до системи шляхом ініціювання блокування пристрою після [Призначення: визначеного організацією періоду] бездіяльності або після отримання запиту від користувача.
- b. Зберігати блокування пристрою, поки користувач не відновить доступ, використовуючи встановлені процедури ідентифікації та автентифікації.

No: 1

Name: ac\_11\_b

Type: string

Default: nil

Блокування пристрою зберігається доти, доки користувач не відновить доступ за допомогою встановлених процедур ідентифікації та автентифікації

No: 2

Name: ac\_11\_odp\_01

Type: integer

Default: 30

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {ініціювання блокування пристрою після періоду неактивності; вимога до користувача ініціювати блокування пристрою перед тим, як залишити систему без нагляду}

No: 3

Name: ac\_11\_odp\_02

Type: integer

Default: 30

Часовий проміжок бездіяльності, після якого ініціюється блокування пристрою (якщо вибрано)

### 1.9.1. ПРИХОВАНІ ДИСПЛЕЇ (АС-11(1))

No: 1

Name: ac\_11\_1\_01

Type: string

Default: nil

Система приховує (через блокування сеансу) інформацію, попередньо видиму на дисплеї, загальнодоступним зображенням



## 1.10. Припинення сеансу (АС-12)

Сеанс користувача має завершуватися автоматично після [Призначення: визначених організацією умов або тригерних подій, що вимагають припинення сеансу].

No: 1  
Name: ac\_12\_01  
Type: string  
Default: nil

Сеанс користувача автоматично завершується після виконання умов або подій

No: 2  
Name: ac\_12\_odp  
Type: list  
Default: ["login", "logout", "failed\_attempt"]

Визначено умови або події, що вимагають припинення сеансу

## 1.11. ВІДДАЛЕНИЙ ДОСТУП (АС-17)

a. Встановити та задокументувати обмеження на використання, вимоги до конфігурації/підключення та рекомендації щодо здійснення кожного типу віддаленого доступу.

b. Авторизувати віддалений доступ до системи, перш ніж будуть дозволені такі підключення.

No: 1  
Name: ac\_17\_a\_02  
Type: string  
Default: nil

Для кожного типу дозволеного віддаленого доступу встановлені та задокументовані вимоги до конфігурації/підключення

No: 2  
Name: ac\_17\_a\_03  
Type: string  
Default: nil

Для кожного типу дозволеного віддаленого доступу встановлені та задокументовані рекомендації

No: 3  
Name: ac\_17\_b  
Type: string  
Default: nil

Кожен тип віддаленого доступу до системи авторизується перед тим, як дозволити такі підключення

### 1.11.1. КЕРОВАНІ ТОЧКИ КОНТРОЛЮ ДОСТУПУ (АС-17(3))

No: 1  
Name: ac\_17\_3\_01  
Type: string  
Default: nil

Віддалений доступ маршрутизується через авторизовані та керовані точки контролю доступу до мережі

## 1.11.2. ПРИВІЛЕЙОВАНІ КОМАНДИ ТА ДОСТУП (АС-17(4))

No: 1

Name: ac\_17\_4\_a\_01

Type: string

Default: nil

Виконання привілейованих команд за допомогою віддаленого доступу дозволено лише для наступних потреб: потреби

No: 2

Name: ac\_17\_4\_a\_02

Type: string

Default: nil

Доступ до інформації, важливої для безпеки, за допомогою віддаленого доступу дозволяється лише для наступних потреб: потреби

No: 3

Name: ac\_17\_4\_b

Type: string

Default: nil

Обґрунтування віддаленого доступу задокументовано в плані захисту інформації

No: 4

Name: ac\_17\_4\_odp\_01

Type: string

Default: nil

Визначено потреби, що потребують виконання привілейованих команд за допомогою віддаленого доступу; АС-17(04)\_ODP[02] визначено потреби, що вимагають доступу до інформації, що стосується безпеки, за допомогою віддаленого доступу

## 1.12. БЕЗДРОТОВИЙ ДОСТУП (АС-18)

- а. Установити обмеження на використання, вимоги до конфігурації/підключення та рекомендації щодо здійснення бездротового доступу.
- б. Авторизувати бездротовий доступ до системи, перш ніж будуть дозволені такі підключення.

No: 1

Name: ac\_18\_a\_01

Type: string

Default: nil

Встановлено обмеження на використання щодо здійснення бездротового доступу

No: 2

Name: ac\_18\_a\_02

Type: string

Default: nil

Встановлено вимоги до конфігурації або підключення щодо здійснення бездротового доступу

No: 3

Name: ac\_18\_a\_03

Type: string

Default: nil

Встановлено доступу

No: 4  
Name: ac\_18\_b  
Type: string  
Default: nil

Авторизується бездротовий доступ до системи перед тим, як дозволяти такі з'єднання. рекомендації щодо здійснення бездротового

### 1.12.1. АВТЕНТИФІКАЦІЯ ТА ШИФРУВАННЯ (АС-18(1))

No: 1  
Name: ac\_18\_1\_02  
Type: string  
Default: "AES-256-GCM"

Бездротовий доступ до системи захищений за допомогою шифрування

### 1.12.2. ВІДКЛЮЧЕННЯ БЕЗДРОТОВОЇ МЕРЕЖІ (АС-18(3))

No: 1  
Name: ac\_18\_3\_01  
Type: string  
Default: nil

Відключено, у разі відсутності необхідності у використанні, вбудовані в компоненти системи можливості бездротових мереж до їх виклику та розгортання

## 1.13. КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ (АС-19)

- а. Встановити обмеження на використання, вимоги до конфігурації, вимоги до підключення і рекомендації щодо впровадження мобільних пристроїв, контрольованих організацією.
- б. Авторизувати підключення мобільних пристроїв до систем, які експлуатуються організацією.

No: 1  
Name: ac\_19\_a\_01  
Type: string  
Default: nil

Встановлено вимоги до конфігурації мобільних пристроїв, що контролюються організацією, в тому числі, коли такі пристрої перебувають за межами контрольованої території

No: 2  
Name: ac\_19\_a\_02  
Type: string  
Default: nil

Встановлюються вимоги до підключення для мобільних пристроїв, що контролюються організацією, в тому числі, коли такі пристрої знаходяться за межами контрольованої території

No: 3  
Name: ac\_19\_a\_03  
Type: string  
Default: nil

Розроблено рекомендації щодо впровадження для мобільних пристроїв, які контролюються організацією, в тому числі, коли такі пристрої перебувають за межами контрольованої території

No: 4

Name: ac\_19\_b

Type: string

Default: nil

Авторизовано підключення мобільних пристроїв до систем організації

### 1.13.1. ПОВНЕ ШИФРУВАННЯ ПРИСТРОЇВ ТА СХОВИЩ ІН- ФОРМАЦІЇ (АС-19(5))

Немає параметрів для цього контролю.

## 1.14. ВИКОРИСТАННЯ ЗОВНІШНІХ СИСТЕМ (АС- 20)

а. [Вибір (один або кілька): Встановить [Призначення: умови, визначені організацією]; Визначте [Призначення: визначені організацією засоби контролю, які, як стверджується, будуть реалізовані на зовнішніх системах]], узгоджені з довірчими відносинами, встановленими з іншими організаціями, які володіють, експлуатують та/або обслуговують зовнішні системи, дозволяючи уповноваженим особам:

1. доступ до системи із зовнішніх систем;

2. обробляти, зберігати або передавати керовану організацією інформацію за допомогою зовнішніх систем;

б. Заборонити використання [Призначення: організаційно-визначені типи зовнішніх систем].

No: 1

Name: ac\_20\_odp\_01

Type: list

Default: []

Вибрано одне або більше з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {встановити умови та положення; визначити заходи захисту}

No: 2

Name: ac\_20\_odp\_02

Type: list

Default: []

Визначено умови та положення, що відповідають довірчим відносинам, встановленим з іншими організаціями, які володіють, експлуатують та/або обслуговують зовнішні системи (якщо вибрано)

No: 3

Name: ac\_20\_odp\_03

Type: string

Default: nil

Визначено заходи захисту, які мають бути застосовані до зовнішніх систем відповідно до довірчих відносин, встановлених з іншими організаціями, що володіють, експлуатують та/або обслуговують зовнішні системи (якщо обрано)

No: 4

Name: ac\_20\_odp\_04

Type: string

Default: nil

Визначено типи зовнішніх систем, заборонених до використання

### 1.14.1. ОБМЕЖЕННЯ НА АВТОРИЗОВАНЕ ВИКОРИСТАННЯ (АС-20(1))

No: 1

Name: ac\_20\_1\_a

Type: list

Default: ["admin", "security\_officer"]

Авторизовані особи мають право використовувати зовнішню систему для доступу до системи або для обробки, зберігання чи передачі інформації, що контролюється організацією, лише після перевірки виконання заходів безпеки та конфіденційності, зазначених у політиці безпеки та конфіденційності організації, а також планів безпеки та конфіденційності (якщо такі застосовуються)

No: 2

Name: ac\_20\_1\_b

Type: list

Default: ["admin", "security\_officer"]

Авторизовані особи мають право використовувати зовнішню систему для доступу до системи або для обробки, зберігання чи передачі інформації, що контролюється організацією, лише після збереження погоджених угод про підключення або обробку системи з структурою організації, на якій розміщена зовнішня система

### 1.14.2. ПЕРЕНОСНІ ПРИСТРОЇ ЗБЕРІГАННЯ ДАНИХ (АС-20(2))

No: 1

Name: ac\_20\_2\_01

Type: list

Default: ["admin", "security\_officer"]

Використання портативних пристроїв носіїв інформації уповноваженими особами обмежено у зовнішніх системах за допомогою обмеження

No: 2

Name: ac\_20\_2\_odp

Type: list

Default: ["admin", "security\_officer"]

Визначено обмеження на використання авторизованими особами портативних носіїв інформації у зовнішніх системах

## 1.15. ПУБЛІЧНО ДОСТУПНИЙ КОНТЕНТ (АС-22)

- a. Призначити осіб, що уповноважені на розміщення інформації в загальнодоступній системі.
- b. Навчати уповноважених осіб тому, щоб загальнодоступна інформація не містила інформацію з обмеженим доступом.
- c. Переглядати запропонований зміст інформації до публікації в загальнодоступній системі, щоб гарантувати, що там не міститься інформація з обмеженим доступом.
- d. Переглядати вміст загальнодоступної системи на предмет наявності там інформації з обмеженим доступом з [Призначення: визначеною організацією частотою]; така інформація має бути видалена в разі її виявлення.

No: 1

Name: ac\_22\_a

Type: list

Default: ["admin", "security\_officer"]

Визначені особи уповноважені на розміщення інформації в загальнодоступній системі

No: 2

Name: ac\_22\_b

Type: list

Default: ["admin", "security\_officer"]

Уповноважені особи проходять навчання, щоб гарантувати, що загальнодоступна інформація не містить інформацію з обмеженим доступом

No: 3

Name: ac\_22\_c

Type: string

Default: nil

Запропонований зміст інформації перевіряється до публікації в загальнодоступній системі, щоб гарантувати, що там не міститься інформація з обмеженим доступом

No: 4

Name: ac\_22\_d\_01

Type: integer

Default: 30

Зміст у загальнодоступній системі перевіряється на наявність інформації з обмеженим доступом з частотою

No: 5

Name: ac\_22\_d\_02

Type: string

Default: nil

Інформація з обмеженим доступом видаляється з загальнодоступної системи, якщо її виявлено

No: 6

Name: ac\_22\_odp

Type: integer

Default: 30

Визначено частоту, з якою слід переглядати вміст загальнодоступної системи на предмет наявності там інформації з обмеженим доступом

## 2. АТ

### Клас заходів захисту АТ — ОБІЗНАНІСТЬ ТА НАВЧАННЯ

Цей клас спрямований на забезпечення належного рівня знань персоналу щодо загроз інформаційній безпеці та їхніх обов'язків у цій сфері.

Перелік заходів захисту: Політика та процедури підвищення обізнаності та навчання (АТ-1); Навчання з підвищення обізнаності (АТ-2); НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ | НАВЧАННЯ ЩОДО РОЗПІЗНАВАННЯ ВНУТРІШНЬОЇ ЗАГРОЗИ; НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ | НАВЧАННЯ З ПИТАНЬ СОЦІАЛЬНОЇ ІНЖЕНЕРІЇ; Рольове навчання (АТ-3).

## 2.1. ПОЛІТИКА ТА ПРОЦЕДУРИ ПІДВИЩЕННЯ ОБІЗНАНОСТІ ТА НАВЧАННЯ (АТ-1)

а. Розробити, задокументувати та поширити [Призначення: серед визначеного організацією персоналу або ролей]:

1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політики обізнаності та навчання у сфері забезпечення безпеки та приватності, яка:

(а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance);

(b) відповідає чинним законам, нормативним документам, директивам, нормам, політикам, стандартам та керівним документам.

2. Процедури, що сприяють реалізації політики підвищення обізнаності та професійної підготовки в галузі безпеки, приватності, а також пов'язаних з ними заходів захисту інформації та персональних даних.

б. Призначити [Призначення: визначену організацією посадову особу] для управління політикою та процедурами підвищення обізнаності та навчання у сфері забезпечення безпеки та приватності.

с. Переглядати та оновлювати:

1. Поточну політику [Призначення: частота, визначена організацією] і наступне [Призначення: події, визначені організацією];

2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією].

Немає параметрів для цього контролю.

## 2.2. НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ (АТ-2)

Впровадити базові тренінги з підвищення обізнаності у сфері безпеки та приватності для користувачів системи (включно з менеджерами, керівниками компаній і підрядниками):

а. Забезпечити навчання грамотності з питань безпеки та конфіденційності для користувачів системи (включаючи менеджерів, керівників вищої ланки та підрядників):

1. як частину початкового навчання для нових користувачів і [Призначення: частота, визначена організацією] після цього;

2. якщо цього потребують системні зміни або наступні [Призначення: події, визначені організацією].

б. Використовувати наведені нижче методи, щоб підвищити рівень безпеки та конфіденційності користувачів системи [Завдання: визначені організацією методи поінформованості];

с. Оновлювати навчання грамотності та зміст обізнаності [Завдання: частота, визначена організацією] і наступні [Завдання: події, визначені організацією];

д. Включити уроки, отримані з внутрішніх або зовнішніх інцидентів безпеки або порушень, у навчання грамотності та методи підвищення обізнаності.

No: 1

Name: at\_2\_b

Type: string

Default: nil

Методи застосовуються для підвищення обізнаності користувачів системи щодо безпеки та конфіденційності

No: 2

Name: at\_2\_c\_01

Type: integer

Default: 30

Оновлюється зміст навчання грамотності та підвищення обізнаності з частотою

No: 3

Name: at\_2\_c\_02

Type: string

Default: nil

Оновлюється зміст навчання грамотності та підвищення обізнаності після подій

No: 4

Name: at\_2\_d

Type: string

Default: nil

Уроки, отримані в результаті внутрішніх або зовнішніх інцидентів або порушень безпеки, включені в методи навчання та підвищення обізнаності

No: 5

Name: at\_2\_odp\_01

Type: string

Default: "щорічно"

Визначено періодичність проведення навчання грамотності з питань безпеки для користувачів системи (в тому числі менеджерів, вищого керівництва та підрядників) після початкового тренінгу

No: 6

Name: at\_2\_odp\_02

Type: string

Default: "щорічно"

Визначено періодичність проведення навчання грамотності з питань конфіденційності для користувачів системи (в тому числі менеджерів, вищого керівництва та підрядників) після початкового тренінгу

No: 7

Name: at\_2\_odp\_03

Type: list

Default: ["login", "logout", "failed\_attempt"]

Визначено події, які потребують навчання користувачів системи грамотності з питань безпеки

No: 8

Name: at\_2\_odp\_05

Type: string

Default: nil

Визначено методи, які слід застосовувати для підвищення обізнаності користувачів системи щодо безпеки та конфіденційності

No: 9

Name: at\_2\_odp\_06

Type: list

Default: ["login", "logout", "failed\_attempt"]

Визначено частоту оновлення навчання грамотності та змісту обізнаності; АТ-02\_ODP[07] визначено події після яких необхідне оновлення навчання грамотності та змісту обізнаності; АТ-02(a)[01][01] навчання з грамотності з питань безпеки надається користувачам системи (включаючи менеджерів, керівників вищої ланки та підрядників) як частина початкового навчання для нових користувачів; АТ-02(a)[01][02] навчання з грамотності з питань конфіденційності надається користувачам системи (включаючи менеджерів, керівників вищої ланки та підрядників) як частина початкового навчання для нових користувачів; АТ-02(a)[01][03] для користувачів системи (включно з менеджерами, вищим керівництвом та підрядниками) проводиться навчання



з безпеки з періодичністю після цього; AT-02(a)[01][04] для користувачів системи (включно з менеджерами, вищим керівництвом та підрядниками) проводиться навчання з конфіденційності з періодичністю після цього; AT-02(a)[02][01] тренінги з грамотності з питань безпеки проводяться для користувачів системи (включаючи менеджерів, керівників вищої ланки та підрядників), коли цього вимагають зміни в системі або після подій; AT-02(a)[02][02] тренінги з грамотності з питань конфіденційності проводяться для користувачів системи (включаючи менеджерів, керівників вищої ланки та підрядників), коли цього вимагають зміни в системі або після подій

No: 10

Name: at\_2\_odp\_4

Type: list

Default: ["login", "logout", "failed\_attempt"]

Визначено події, які потребують навчання користувачів системи грамотності з питань конфіденційності

### 2.2.1. НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ | НАВЧАННЯ ЩОДО РОЗПІЗНАВАННЯ ВНУТРІШНЬОЇ ЗАГРОЗИ

Ввести до програми навчання вправи з розпізнавання та виявлення потенційних індикаторів внутрішніх загроз.

No: 1

Name: at\_2\_2\_01

Type: string

Default: nil

Введено до програми навчання вправи з розпізнавання потенційних індикаторів внутрішніх загроз

No: 2

Name: at\_2\_2\_02

Type: string

Default: nil

Введено до програми навчання вправи з виявлення потенційних індикаторів внутрішніх загроз

### 2.2.2. НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ | НАВЧАННЯ З ПИТАНЬ СОЦІАЛЬНОЇ ІНЖЕНЕРІЇ

Ввести до програми навчання вправи з підвищення обізнаності щодо розпізнавання та повідомлення про потенційні та фактичні атаки, з використанням методів соціальної інженерії та інтелектуального аналізу соціальних даних.

No: 1

Name: at\_2\_3\_01

Type: string

Default: nil

До програми навчання введено вправи з розпізнавання потенційних та фактичних випадків соціального інжинірингу

No: 2

Name: at\_2\_3\_02

Type: string

Default: nil

До програми навчання введено вправи з повідомлення про потенційні та фактичні випадки соціального інжинірингу

No: 3

Name: at\_2\_3\_03

Type: string

Default: nil

До програми навчання введено вправи з розпізнавання потенційних та фактичних випадків інтелектуального аналізу соціальних даних

No: 4

Name: at\_2\_3\_04

Type: string

Default: nil

До програми навчання введено вправи з повідомлення про потенційні та фактичні випадки інтелектуального аналізу соціальних даних

## 2.3. РОЛЬОВЕ НАВЧАННЯ (АТ-3)

- а. Забезпечити проведення навчання з питань безпеки та приватності на основі ролей для працівників з ролями та обов'язками: [Призначення: визначені організацією ролі та обов'язки]:
1. перед авторизацією доступу до системи, інформації або виконанням призначених обов'язків і [Призначення: частота, визначена організацією] після цього;
  2. коли цього потребують системні зміни.
- б. Оновити навчальний контент на основі ролей [Призначення: частота, визначена організацією] і наступні [Призначення: події, визначені організацією];
- с. Включіть у рольове навчання, інформацію, отриману з внутрішніх або зовнішніх інцидентів та порушень безпеки.

No: 1

Name: at\_3\_b\_01

Type: integer

Default: 30

Оновлюється вміст навчання на основі ролей з частотою

No: 2

Name: at\_3\_b\_02

Type: string

Default: nil

Оновлюється вміст навчання на основі ролей після подій

No: 3

Name: at\_3\_c

Type: string

Default: nil

Інформація отримана з внутрішніх чи зовнішніх інцидентів або порушень безпеки, включається в навчання на основі ролей

No: 4

Name: at\_3\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено ролі та обов'язки для тренінгів з безпеки на основі ролей

No: 5

Name: at\_3\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено ролі та обов'язки для тренінгів з конфіденційності на основі ролей

No: 6

Name: at\_3\_odp\_03

Type: list

Default: ["admin", "security\_officer"]

Визначено частоту проведення тренінгів на основі ролей з безпеки та конфіденційності для призначеного персоналу після початкової підготовки

No: 7

Name: at\_3\_odp\_04

Type: integer

Default: 30

Визначено частоту оновлення змісту навчання на основі ролей

No: 8

Name: at\_3\_odp\_05

Type: list

Default: ["admin", "security\_officer"]

Визначено події, які потребують оновлення змісту навчання на основі ролей; AT-03(a)[01][01] навчання з безпеки на основі ролей проводиться для ролей та обов'язків перед авторизацією доступу до системи, інформації або виконанням призначених обов'язків; AT-03(a)[01][02] навчання з конфіденційності на основі ролей проводиться для ролей та обов'язків перед авторизацією доступу до системи, інформації або виконанням призначених обов'язків; AT-03(a)[01][03] навчання з безпеки на основі ролей проводиться для ролей та обов'язків з частотою після цього; AT-03(a)[01][04] навчання з конфіденційності на основі ролей проводиться для ролей та обов'язків з частотою після цього; AT-03(a)[02][01] навчання з питань безпеки на основі ролей проводиться для персоналу, який виконує певні ролі та обов'язки у сфері безпеки, коли цього вимагають зміни в системі; AT-03(a)[02][02] навчання з питань конфіденційності на основі ролей проводиться для персоналу, який виконує певні ролі та обов'язки у сфері безпеки, коли цього вимагають зміни в системі

## 3. AU

Клас заходів захисту AU — АУДИТ ТА ПІДЗВІТНІСТЬ

Цей клас забезпечує можливість відстеження дій у системі, генерування, захист та аналіз записів аудиту для виявлення порушень політики безпеки.

Перелік заходів захисту: Політика та процедури аудиту та підзвітності (AU-1); Події аудиту (AU-2); Зміст записів аудиту (AU-3); Додаткова інформація про аудит (AU-3(1)); Реагування на відмови обробки даних аудиту (AU-5); Огляд, аналіз і звітність аудиту (AU-6); Зіставлення сховищ аудиту (AU-6(3)); Скорочення записів аудиту та формування звіту (AU-7); Позначка часу (AU-8); Захист інформації аудиту (AU-9); Доступ, який надається через членство в підмножини привілейованих користувачів (AU-9(4)); Збереження записів аудиту (AU-11); Генерація даних аудиту (AU-12).

### 3.1. Політика та процедури аудиту та підзвітності (AU-1)

а. Розробити, задокументувати та поширити [Призначення: серед персоналу або ролей, що їх визначила організація]:

1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи]

політика аудиту та підзвітності, яка:

- (a) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance);
- (b) відповідає чинним законам, нормативним документам, директивам, нормам, політикам, стандартам та керівним документам.

2. Процедури, що сприяють здійсненню політики аудиту та підзвітності, а також пов'язані з ними заходи аудиту та підзвітності.

b. Призначити [Призначення: визначену організацією старшу посадову особу] для управління політикою та процедурами аудиту та підзвітності.

c. Переглядати та оновлювати поточний аудит та підзвітність:

- 1. політику [Призначення: частота, визначена організацією] та наступне [Призначення: події, визначені організацією];
- 2. процедури аудиту [Призначення: визначеною організацією частотою] та [Завдання: події, визначені організацією].

No: 1

Name: au\_1\_a\_01

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Розроблено та задокументовано політику аудиту та підзвітності

No: 2

Name: au\_1\_a\_02

Type: list

Default: ["admin", "security\_officer"]

Політика аудиту та підзвітності доведена до персоналу або ролі

No: 3

Name: au\_1\_a\_03

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Розроблені та задокументовані процедури аудиту та підзвітності, що сприяють впровадженню політики аудиту та підзвітності, а також відповідні заходи контролю аудиту та підзвітності

No: 4

Name: au\_1\_b

Type: list

Default: ["admin", "security\_officer"]

Посадова особа призначається для управління політикою та процедурами аудиту та підзвітності AU-01(c)[01][01] переглядається та оновлюється поточна політика аудиту та підзвітності з частотою; AU-01(c)[01][02] переглядається та оновлюється поточна політика аудиту та підзвітності після подій; AU-01(c)[02][01] переглядається та оновлюється поточні процедури аудиту та підзвітності з частотою; AU-01(c)[02][02] переглядається та оновлюється поточні процедури аудиту та підзвітності після подій

No: 5

Name: au\_1\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, до яких має бути доведена політика аудиту та підзвітності

No: 6

Name: au\_1\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на які поширюються процедури аудиту та підзвітності

No: 7

Name: au\_1\_odp\_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 8

Name: au\_1\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Визначено посадову особу, яка управлятиме політикою та процедурами аудиту та підзвітності

No: 9

Name: au\_1\_odp\_05

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика аудиту та підзвітності

No: 10

Name: au\_1\_odp\_06

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено події, які потребують перегляду та оновлення поточної політики аудиту та підзвітності

No: 11

Name: au\_1\_odp\_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури аудиту та підзвітності

No: 12

Name: au\_1\_odp\_08

Type: list

Default: ["login", "logout", "failed\_attempt"]

Визначено події, які потребують перегляду та оновлення поточної процедури аудиту та підзвітності

## 3.2. ПОДІЇ АУДИТУ (AU-2)

- a. Визначити типи подій, які система може реєструвати для підтримки функції аудиту: [Призначення: типи подій, визначені організацією, які система здатна реєструвати];
- b. Координувати функції аудиту безпеки з іншими організаційними підрозділами, які вимагають інформації, пов'язаної з аудитом, для посилення взаємної підтримки та допомоги у виборі типів подій, що перевіряються;
- c. Визначити, які типи подій підлягають аудиту: [Призначення: визначені організацією події, що підлягають аудиту (підмножина подій, що підлягають аудиту, визначених в AU-2 а.), а також частота (або ситуація, що вимагає) проведення аудиту для кожної ідентифікованої події];
- d. Обґрунтувати, чому типи подій, що перевіряються, вважаються достатніми для підтримки розслідувань інцидентів (постфактум), пов'язаних з безпекою та приватністю;
- e. Перегляньте й оновіть типи подій, вибрані для журналювання [Призначення: частота, визначена організацією].

No: 1

Name: au\_2\_a

Type: string

Default: nil

Типи подій, які система здатна реєструвати, визначено для підтримки функції аудиту

No: 2

Name: au\_2\_b

Type: string

Default: nil

Функція аудиту безпеки координується з іншими підрозділами організації, які вимагають інформації, пов'язаної з аудитом, для посилення взаємної підтримки та допомоги у виборі типів подій, що перевіряються

No: 3

Name: au\_2\_c\_01

Type: string

Default: nil

Типи подій (підмножина 02\_ODP[01]) визначаються для реєстрації у системі; AU-

No: 4

Name: au\_2\_c\_02

Type: string

Default: "щорічно"

Зазначені типи подій реєструються 02\_ODP[03] частота або ситуація>; <AU-

No: 5

Name: au\_2\_d

Type: string

Default: nil

Надається обґрунтування, чому типи подій, що перевіряються, вважаються достатніми для підтримки розслідувань інцидентів (постфактум), пов'язаних з безпекою та конфіденційністю

No: 6

Name: au\_2\_e

Type: string

Default: "щорічно"

Переглядаються та оновлюються типи подій, вибрані для реєстрації, частота, у системі

No: 7

Name: au\_2\_odp\_01

Type: string

Default: nil

Визначено типи подій, які система може реєструвати для підтримки функції аудиту

No: 8

Name: au\_2\_odp\_02

Type: string

Default: nil

Визначено типи подій (підмножина AU-02\_ODP[01]) що підлягають аудиту у системі

No: 9

Name: au\_2\_odp\_03

Type: list

Default: ["login", "logout", "failed\_attempt"]

Визначено частоту або ситуацію, що вимагає проведення аудиту для кожної ідентифікованої події

No: 10

Name: au\_2\_odp\_04

Type: string

Default: "щорічно"

Частота перегляду та оновлення типів подій, обраних для журналювання

### 3.3. ЗМІСТ ЗАПИСІВ АУДИТУ (AU-3)

Переконайтеся, що записи аудиту містять інформацію, яка встановлює наступне:

- a. який тип події стався;
- b. коли відбулася подія;
- c. де відбулася подія;
- d. джерело події;
- e. наслідки події;
- f. результат події та ідентифікатор будь-яких осіб або суб'єктів, пов'язаних з подією.

No: 1

Name: au\_3\_a

Type: list

Default: ["login", "logout", "failed\_attempt"]

Записи аудиту містять інформацію, яка встановлює який тип події стався

No: 2

Name: au\_3\_b

Type: string

Default: nil

Записи аудиту містять інформацію, яка встановлює коли подія сталася

No: 3

Name: au\_3\_c

Type: string

Default: nil

Записи аудиту містять інформацію, яка встановлює де відбулася подія

No: 4

Name: au\_3\_d

Type: list

Default: ["login", "logout", "failed\_attempt"]

Записи аудиту містять інформацію, яка встановлює джерело події

No: 5

Name: au\_3\_e

Type: list

Default: ["login", "logout", "failed\_attempt"]

Записи аудиту містять інформацію, яка встановлює наслідки події

No: 6

Name: au\_3\_f

Type: list

Default: ["login", "logout", "failed\_attempt"]

Записи аудиту містять інформацію, яка встановлює результат події та ідентифікатор будь-яких осіб або суб'єктів, пов'язаних з подією

### 3.3.1. ДОДАТКОВА ІНФОРМАЦІЯ ПРО АУДИТ (AU-3(1))

No: 1

Name: au\_3\_1\_01

Type: string

Default: nil

ЗМІСТ ЗАПИСІВ АУДИТУ - ДОДАТКОВА ІНФОРМАЦІЯ ПРО АУДИТ МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: au\_3\_1\_odp

Type: string

Default: nil

Визначено додаткову інформацію, яка має бути включена до записів аудиту

## 3.4. РЕАГУВАННЯ НА ВІДМОВИ ОБРОБКИ ДАНИХ АУДИТУ (AU-5)

а. Сповіщати [Призначення: визначені організацією персонал або посади] у разі збою обробки даних аудиту в [Призначення: визначений організацією період часу].

б. Виконати наступні додаткові дії: [Призначення: визначені організацією дії, які необхідно зробити].

No: 1

Name: au\_5\_a

Type: list

Default: ["admin", "security\_officer"]

Персонал або ролі отримують сповіщення у разі збою процесу обробки даних аудиту періоду часу

No: 2

Name: au\_5\_b

Type: list

Default: ["login", "logout", "failed\_attempt"]

Додаткові дії виконуються у разі збою процесу обробки даних аудиту

No: 3

Name: au\_5\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, які отримують сповіщення про збої в процесі обробки даних аудиту

No: 4

Name: au\_5\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено період часу, протягом якого персонал або ролі отримують сповіщення про збої в процесі обробки даних аудиту

No: 5

Name: au\_5\_odp\_03

Type: list

Default: ["login", "logout", "failed\_attempt"]

Визначено додаткові дії, яких слід вжити у випадку збою в процесі обробки даних аудиту



### 3.5. ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ (AU-6)

- a. Переглядати та аналізувати записи системного аудиту [Призначення: з визначеною організацією частотою] для виявлення [Призначення: визначеної організацією неналежної або незвичайної діяльності].
- b. Відправляти звіт про аудит [Призначення: визначеним організацією персоналу або посадам].
- c. Налаштувати рівні огляду аудиту, аналізу та звітності в рамках системи, коли змінюється рівень ризику на основі інформації від правоохоронних органів, розвідувальної інформації або від інших достовірних джерел інформації.

No: 1

Name: au\_6\_01

Type: string

Default: nil

ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: au\_6\_a

Type: string

Default: "щотижня"

Записи аудиту системи переглядаються та аналізуються частота для виявлення ознак неналежної або незвичної діяльності та потенційного впливу неналежної або незвичної діяльності

No: 3

Name: au\_6\_b

Type: list

Default: ["admin", "security\_officer"]

Звіт аудиту відправляється персоналу або ролям

No: 4

Name: au\_6\_c

Type: string

Default: nil

Рівень перевірки, аналізу та звітування записів аудиту в системі коригується у разі зміни ризиків на основі інформації правоохоронних органів, розвідувальної інформації або інших достовірних джерел інформації

No: 5

Name: au\_6\_odp\_01

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та аналізуються записи аудиту системи

No: 6

Name: au\_6\_odp\_02

Type: string

Default: nil

Визначена неналежна або незвична діяльність

No: 7

Name: au\_6\_odp\_03

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі які отримують результати оглядів та аналізів системних записів

### 3.5.1. ЗІСТАВЛЯННЯ СХОВИЩ АУДИТУ (AU-6(3))

Аналізувати та зіставляти записи аудиту в різних сховищах задля забезпечення ситуативної обізнаності в масштабах організації.

No: 1

Name: au\_6\_3\_01

Type: string

Default: nil

Аналізуються та зіставляються записи аудиту в різних сховищах, задля забезпечення ситуативної обізнаності в масштабах організації

## 3.6. СКОРОЧЕННЯ ЗАПИСІВ АУДИТУ ТА ФОРМУВАННЯ ЗВІТУ (AU-7)

Забезпечити та реалізувати можливості скорочення записів перевірок аудитом і звітів, до рівня, який:

- a. підтримує перевірку, аналіз і звітність аудиту на вимогу та розслідування (постфактум) інцидентів безпеки;
- b. не змінює оригінальний вміст або час упорядкування записів аудиту.

No: 1

Name: au\_7\_a\_02

Type: string

Default: nil

Реалізовано можливість скорочення записів перевірок аудитом та звітів, до рівня що підтримує перевірку, аналіз і звітність аудиту на вимогу та розслідування (постфактум) інцидентів безпеки

No: 2

Name: au\_7\_b\_01

Type: integer

Default: 30

Забезпечено можливість скорочення записів перевірок аудитом та звітів, які не змінюють оригінальний вміст або час упорядкування записів аудиту

No: 3

Name: au\_7\_b\_02

Type: integer

Default: 30

Реалізовано можливість скорочення записів перевірок аудитом та звітів, які не змінюють оригінальний вміст або час упорядкування записів аудиту

## 3.7. ПОЗНАЧКА ЧАСУ (AU-8)

a. Використовувати внутрішньосистемний годинник для створення позначок часу для записів аудиту.

b. Застосовувати позначки часу, які відповідають [Призначення: деталізація вимірювання часу, визначена організацією] і використовують всесвітній координований час, мають фіксоване зміщення місцевого часу відносно всесвітнього координованого часу або включають зміщення місцевого часу як частину позначки часу.

No: 1  
 Name: au\_8\_a  
 Type: integer  
 Default: 30

Внутрішній системний годинник використовується для створення позначок часу для записів аудиту

No: 2  
 Name: au\_8\_b  
 Type: integer  
 Default: 30

Позначки часу застосовуються для записів аудиту, які відповідають деталізації вимірювання часу і які використовують всесвітній координований час, мають фіксоване місцеве зміщення місцевого часу від всесвітнього координованого часу або включають зміщення місцевого часу як частину позначки часу

No: 3  
 Name: au\_8\_odp  
 Type: integer  
 Default: 30

Визначено деталізацію вимірювання часу для часових позначок записів аудиту

## 3.8. ЗАХИСТ ІНФОРМАЦІЇ АУДИТУ (AU-9)

- a. Захист інформації аудиту та інструментів несанкціонованого доступу, зміни та видалення; журналювання аудиту від
- b. Сповіднення [Призначення: персонал або ролі, визначені організацією] у разі виявлення несанкціонованого доступу, зміни або видалення інформації аудиту.

No: 1  
 Name: au\_9\_01  
 Type: string  
 Default: nil

ЗАХИСТ ІНФОРМАЦІЇ АУДИТУ МЕТА ОЦІНКИ: Визначити, чи:

No: 2  
 Name: au\_9\_a  
 Type: string  
 Default: nil

Інформація про аудит та інструменти журналювання аудиту захищені від несанкціонованого доступу, зміни та видалення

No: 3  
 Name: au\_9\_b  
 Type: list  
 Default: ["admin", "security\_officer"]

Персонал або ролі отримують сповіщення при виявленні несанкціонованого доступу, зміни або видалення інформації аудиту

No: 4  
 Name: au\_9\_odp  
 Type: list  
 Default: ["admin", "security\_officer"]

Визначено персонал або ролі, які мають бути сповіщені при виявленні несанкціонованого доступу, зміни або видалення інформації аудиту

### 3.8.1. ДОСТУП, ЯКИЙ НАДАЄТЬСЯ ЧЕРЕЗ ЧЛЕНСТВО В ПІДМНОЖИНИ ПРИВІЛЕЙОВАНИХ КОРИСТУВАЧІВ (AU-9(4))

Авторизувати доступ до управління функціональністю аудиту тільки для [Призначення: визначеної організацією підмножини привілейованих користувачів].

No: 1

Name: au\_9\_4\_01

Type: string

Default: nil

Авторизувати доступ до управління функціональністю аудиту тільки для підмножини привілейованих користувачів

No: 2

Name: au\_9\_4\_odp

Type: string

Default: nil

Визначено підмножину привілейованих користувачів

## 3.9. ЗБЕРЕЖЕННЯ ЗАПИСІВ АУДИТУ (AU-11)

Зберігати записи аудиту впродовж [Призначення: визначеного організацією періоду часу, відповідно політиці зберігання записів], щоб забезпечити підтримку розслідувань (постфактум) інцидентів безпеки та приватності, а також для задоволення вимог нормативних і документів організації щодо збереження даних аудиту.

No: 1

Name: au\_11\_01

Type: integer

Default: 30

Записи аудиту зберігаються впродовж періоду часу, щоб забезпечити підтримку розслідування (постфактум) інцидентів безпеки та конфіденційності, а також відповідати нормативним та вимогам організації щодо збереження даних аудиту

No: 2

Name: au\_11\_odp

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено період часу для зберігання записів аудиту, який узгоджується з політикою зберігання записів

## 3.10. ГЕНЕРАЦІЯ ДАНИХ АУДИТУ (AU-12)

a. Забезпечити генерацію даних аудиту для типів подій, що перевіряються в AU-2a в [Призначення: визначених організацією компонентах системи].

b. Дозволити [Призначення: визначеному організацією персоналу або посадам] вибирати, які типи подій, що перевіряються, повинні перевірятися окремими компонентами системи;

c. Генерувати записи аудиту для типів подій, визначених в AU-2c. з вмістом згідно з AU-3.

No: 1

Name: au\_12\_a

Type: string

Default: nil

Можливість генерації записів аудиту для типів подій, які система здатна перевіряти (визначених у AU-02\_ODP[01]), забезпечується компонентами системи

No: 2

Name: au\_12\_b

Type: list

Default: ["admin", "security\_officer"]

Персонал або ролі може/можуть вибирати типи подій, які будуть реєструватися певними компонентами системи; AU-12(c) згенеровано записи аудиту для типів подій, визначених у AU02\_ODP[02], які включають вміст записів аудиту, визначений у AU03

No: 3

Name: au\_12\_odp\_01

Type: string

Default: nil

Визначено компоненти системи, які забезпечують можливість генерації записів аудиту для типів подій (визначених у AU02\_ODP[02])

No: 4

Name: au\_12\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, яким дозволено обирати типи подій, що мають реєструватися певними компонентами системи

## 4. СА

Клас заходів захисту СА — ОЦІНЮВАННЯ,

Цей клас регламентує процеси перевірки ефективності заходів захисту, авторизації систем та їх безперервного моніторингу.

Перелік заходів захисту: Політика і процедури оцінювання, акредитація та моніторинг безпеки (СА-1); Оцінювання (СА-2); Взаємодія систем (СА-3); План усунення недоліків та контрольні показники (СА-5); Безперервний моніторинг (СА-7).

### 4.1. ПОЛІТИКА І ПРОЦЕДУРИ ОЦІНЮВАННЯ, АКРЕДИТАЦІЯ ТА МОНІТОРИНГ БЕЗПЕКИ (СА-1)

а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або посад]:

1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політика оцінювання, авторизації та моніторингу, яка:

- (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance);
- (б) відповідає чинним законам, нормативним документам, наказам, положенням, політиці, стандартам і керівним принципам.

2. Процедури, що сприяють реалізації політики оцінювання, авторизації та моніторингу безпеки та приватності, а також пов'язаних з ними заходів оцінювання, авторизації та моніторингу безпеки та приватності.

b. Призначити [Призначення: посадова особа, визначена організацією] для управління розробкою, документуванням і розповсюдженням політики та процедур оцінювання, авторизації та моніторингу;

c. Переглядати та оновлювати поточне оцінювання, авторизацію та моніторинг:

1. Політику [Призначення: частота, визначена організацією] та наступне [Призначення: події, визначені організацією];

2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією].

No: 1

Name: ca\_1\_a\_01

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Розроблено та задокументовано політику оцінювання, авторизації та моніторингу

No: 2

Name: ca\_1\_a\_02

Type: list

Default: ["admin", "security\_officer"]

Політика оцінювання, авторизації та моніторингу поширюється серед персоналу або ролей

No: 3

Name: ca\_1\_a\_03

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Розроблені та задокументовані процедури оцінювання, авторизації та моніторингу, що сприяють впровадженню політики оцінювання, авторизації та моніторингу, а також пов'язані з ними засоби контролю оцінювання, авторизації та моніторингу

No: 4

Name: ca\_1\_b

Type: list

Default: ["admin", "security\_officer"]

Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур оцінювання, авторизації та моніторингу; CA-01(c)[01][01] переглядається та оновлюється поточна політика оцінки, авторизації та моніторингу з частотою; CA-01(c)[01][02] переглядається та оновлюється поточна політика оцінки, авторизації та моніторингу після подій; CA-01(c)[02][01] переглядаються та оновлюються поточні процедури оцінки, авторизації та моніторингу з частотою; CA-01(c)[02][02] переглядаються та оновлюються поточні процедури оцінки, авторизації та моніторингу після подій; ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

No: 5

Name: ca\_1\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, серед яких має бути поширена політика оцінювання, авторизації та моніторингу

No: 6

Name: ca\_1\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, серед яких мають бути поширені процедури оцінювання, авторизації та моніторингу

No: 7

Name: ca\_1\_odp\_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 8

Name: ca\_1\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Визначено посадову особу, яка управлятиме розробкою, документуванням і розповсюдженням політики та процедур оцінювання, авторизації та моніторингу

No: 9

Name: ca\_1\_odp\_05

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика оцінювання, авторизації та моніторингу

No: 10

Name: ca\_1\_odp\_06

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено події, які потребують перегляду та оновлення поточної політики оцінки, авторизації та моніторингу

No: 11

Name: ca\_1\_odp\_07

Type: integer

Default: 30

Визначено частоту, з якою переглядається та оновлюється поточні процедури оцінювання, авторизації та моніторингу

No: 12

Name: ca\_1\_odp\_08

Type: list

Default: ["login", "logout", "failed\_attempt"]

Визначено події, які потребують перегляду та оновлення поточні процедури оцінки, авторизації та моніторингу

## 4.2. ОЦІНЮВАННЯ (CA-2)

a. Виберіть відповідного оцінювача або команду з оцінки для типу оцінювання, яке буде проводитися;

b. Розробіть план контрольної оцінки, який описує обсяг оцінки, в тому числі:

1. заходи захисту та посилені заходи, що підлягають оцінюванню;
2. процедури оцінювання, ефективності заходів; які використовуватимуться для визначення
3. середовище оцінювання, групу оцінювання, ролі й обов'язки з оцінювання.

c. Забезпечити розгляд і затвердження плану оцінювання уповноваженою офіційною особою або призначеним для проведення оцінювання представником;

d. Оцінити заходи захисту в системі та в її середовищі функціонування з [Призначення:

визначеною організацією частотою] для визначення, наскільки коректно реалізовані заходи безпеки і чи працюють вони за призначенням і дають бажаний результат щодо дотримання встановлених вимог безпеки та приватності;

е. Підготувати звіт оцінювання безпеки, який документує результати оцінювання;

ф. Надати результати оцінювання з безпеки [Призначення: особам або ролям, визначеним організацією].

No: 1

Name: ca\_2\_a

Type: string

Default: nil

Обрано відповідного оцінювача або команду оцінювачів для проведення оцінювання

No: 2

Name: ca\_2\_b\_01

Type: list

Default: ["admin", "security\_officer"]

Розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи заходи захисту та посилені заходи, що підлягають оцінюванню. CA-02(b)[02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи процедури оцінювання, які використовуватимуться для визначення ефективності заходів. CA-02(b)[03][01] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи середовище оцінювання. CA-02(b)[03][02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи групу оцінювання. CA-02(b)[03][03] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи ролі й обов'язки з оцінювання

No: 3

Name: ca\_2\_b\_02

Type: list

Default: ["admin", "security\_officer"]

Розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи процедури оцінювання, які використовуватимуться для визначення ефективності заходів. CA-02(b)[03][01] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи середовище оцінювання. CA-02(b)[03][02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи групу оцінювання. CA-02(b)[03][03] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи ролі й обов'язки з оцінювання

No: 4

Name: ca\_2\_c

Type: list

Default: ["admin", "security\_officer"]

План оцінки заходів захисту розглядається та затверджується уповноваженою посадовою особою або призначеним представником перед проведенням оцінки

No: 5

Name: ca\_2\_d\_01

Type: string

Default: "щорічно"

Заходи захисту оцінюються в системі та середовищі її функціонування частота оцінки, щоб визначити, наскільки коректно реалізовані заходи захисту, чи працюють вони за призначенням і чи дають бажаний результат щодо дотримання встановлених вимог до безпеки

No: 6

Name: ca\_2\_d\_02

Type: string

Default: "щорічно"



Заходи захисту оцінюються в системі та середовищі її функціонування частота оцінки, щоб визначити, наскільки коректно реалізовані заходи захисту, чи працюють вони за призначенням і чи дають бажаний результат щодо дотримання встановлених вимог до конфіденційності; СА-02(е) готується звіт оцінювання

No: 7

Name: ca\_2\_f

Type: list

Default: ["admin", "security\_officer"]

Результати оцінювання з безпеки надаються особам або ролям. оцінювання, який документує результати

No: 8

Name: ca\_2\_odp\_01

Type: integer

Default: 30

Визначено частоту, з якою слід оцінювати засоби контролю в системі та середовищі її функціонування

No: 9

Name: ca\_2\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначені особи або ролі, яким мають бути надані результати оцінювання з безпеки

## 4.3. ВЗАЄМОДІЯ СИСТЕМ (СА-3)

а. схвалити та керувати обміном інформацією між системою та іншими системами за допомогою [Вибір (один або кілька): угоди безпеки взаємозв'язку; договори безпеки обміну інформацією; меморандуми про взаєморозуміння; угоди про рівень обслуговування; угоди користувача; угоди про нерозголошення; [Доручення: тип договору, визначений організацією]];

б. документувати, як частину угоди про обмін, характеристики інтерфейсу, вимоги до безпеки та приватності, засоби контролю та відповідальність для кожної системи, а також характер переданої інформації;

с. здійснювати перегляд та оновлення угод з [Призначення: визначеною організацією частотою].

No: 1

Name: ca\_3\_b\_01

Type: integer

Default: 30

Характеристики інтерфейсу задокументовані як частина кожної угоди про обмін

No: 2

Name: ca\_3\_b\_02

Type: integer

Default: 30

Вимоги до безпеки задокументовані як частина кожної угоди про обмін

No: 3

Name: ca\_3\_b\_03

Type: integer

Default: 30

Вимоги щодо конфіденційності задокументовані як частина кожної угоди про обмін

No: 4

Name: ca\_3\_b\_04

Type: integer

Default: 30

Заходи захисту задокументовані як частина кожної угоди про обмін

No: 5

Name: ca\_3\_b\_05

Type: integer

Default: 30

Відповідальність за кожну систему задокументована як частина кожної угоди про обмін

No: 6

Name: ca\_3\_b\_06

Type: integer

Default: 30

Характер переданої інформації документується як частина кожної угоди про обмін

No: 7

Name: ca\_3\_c

Type: string

Default: "щорічно"

Угоди переглядаються та оновлюються частота

No: 8

Name: ca\_3\_odp\_01

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {}: угоди безпеки взаємозв'язку; договори безпеки обміну інформацією; меморандуми про взаєморозуміння; угоди про рівень обслуговування; угоди користувача; угоди про нерозголошення; тип угоди}

No: 9

Name: ca\_3\_odp\_02

Type: string

Default: nil

Визначено тип угоди, який використовується для схвалення та керування обміном інформацією (якщо вибрано)

No: 10

Name: ca\_3\_odp\_03

Type: integer

Default: 30

Визначено частоту, з якою необхідно переглядати та оновлювати угоди

## 4.4. ПЛАН УСУНЕННЯ НЕДОЛІКІВ ТА КОНТРОЛЬНІ ПОКАЗНИКИ (СА-5)

а. Розробити для системи план усунення недоліків та контрольні показники з метою документування запланованих коригувальних дій організації для усунення недоліків і зауважень, які виявлені в ході оцінювання заходів захисту, а також для зменшення або усунення відомих вразливостей у системі.

б. Оновлювати чинний план усунення недоліків та контрольні показники з [Призначення: визначеною організацією частотою] на основі результатів оцінювання заходів, незалежних аудитів та постійного моніторингу.

No: 1

Name: ca\_5\_a

Type: list

Default: ["login", "logout", "failed\_attempt"]

Розроблено план усунення недоліків та контрольні показники для системи, та задокументовано заплановані дії організації з коригування, спрямовані на усунення недоліків та зауважень, виявлених під час оцінки заходів захисту, а також на зменшення або усунення відомих вразливостей в системі

No: 2

Name: ca\_5\_b

Type: string

Default: "щорічно"

Існуючий план оновлюється частота на основі результатів оцінювання заходів, незалежних аудитів та постійного моніторингу

No: 3

Name: ca\_5\_odp

Type: integer

Default: 30

Визначено частоту оновлення чинного плану усунення недоліків та контрольних показників на основі результатів оцінювання заходів захисту, незалежних аудитів та постійного моніторингу

## 4.5. БЕЗПЕРЕРВНИЙ МОНІТОРИНГ (СА-7)

Розробити стратегію безперервного моніторингу безпеки та приватності й упровадити програму безперервного моніторингу безпеки та приватності, яка охоплює:

- a. встановлення показників безпеки та приватності, які необхідно відстежувати: [Призначення: визначені організацією метрики];
- b. встановлення [Призначення: визначена організацією частота] для моніторингу та [Призначення: визначена організацією частота] для безперервного оцінювання ефективності заходів захисту;
- c. поточні оцінювання заходів захисту відповідно до стратегії безперервного моніторингу організації;
- d. постійний моніторинг стану безпеки та приватності відповідно до встановлених організацією метрик і відповідно до стратегії безперервного моніторингу організації;
- e. зіставлення та аналіз інформації, отриманої в результаті оцінювання та моніторингу безпеки та приватності;
- f. дії реагування за результатами аналізу інформації, пов'язаної з безпекою та приватністю;
- g. повідомлення про статус безпеки та приватності системи [Призначення: визначені організацією персонал або ролі] з [Призначення: визначеною організацією частотою].

No: 1

Name: ca\_7\_01

Type: string

Default: nil

Розроблено стратегію безперервного моніторингу на системному рівні; СА-07[02] безперервний моніторинг на рівні системи здійснюється відповідно до стратегії безперервного моніторингу на рівні організації

No: 2

Name: ca\_7\_a

Type: string

Default: nil

Безперервний моніторинг на рівні системи включає встановлення наступних метрик на рівні системи, які підлягають моніторингу: метрики системного рівня

No: 3

Name: ca\_7\_b\_01

Type: integer

Default: 30

Безперервний моніторинг на рівні системи включає встановлені частоти для моніторингу ефективності заходів захисту

No: 4

Name: ca\_7\_b\_02

Type: integer

Default: 30

Безперервний моніторинг на рівні системи включає встановлені частоти для оцінки ефективності заходів захисту

No: 5

Name: ca\_7\_c

Type: string

Default: nil

Безперервний моніторинг на рівні системи включає поточні контрольні оцінки відповідно до стратегії безперервного моніторингу

No: 6

Name: ca\_7\_d

Type: string

Default: nil

Безперервний моніторинг на рівні системи включає постійний моніторинг визначених системою та організацією показників відповідно до стратегії безперервного моніторингу

No: 7

Name: ca\_7\_e

Type: string

Default: nil

Безперервний моніторинг на рівні системи включає зіставлення та аналіз інформації, отриманої в результаті оцінювання та моніторингу

No: 8

Name: ca\_7\_f

Type: list

Default: ["login", "logout", "failed\_attempt"]

Безперервний моніторинг на рівні системи включає в себе дії з реагування на результати аналізу інформації, пов'язаної з безпекою та приватністю

No: 9

Name: ca\_7\_g\_01

Type: list

Default: ["admin", "security\_officer"]

Безперервний моніторинг на рівні системи включає повідомлення про статус безпеки системи для персоналу або ролей частота

No: 10

Name: ca\_7\_g\_02

Type: list

Default: ["admin", "security\_officer"]

Безперервний моніторинг на рівні системи включає повідомлення про стан конфіденційності системи персоналу або ролям частота

No: 11  
 Name: ca\_7\_odp\_01  
 Type: string  
 Default: nil

Визначено метрики системного рівня, які підлягають моніторингу

No: 12  
 Name: ca\_7\_odp\_02  
 Type: integer  
 Default: 30

Визначено частоту, з якою слід моніторити ефективність заходів захисту

No: 13  
 Name: ca\_7\_odp\_03  
 Type: integer  
 Default: 30

Визначено частоту, з якою слід оцінювати ефективність заходів захисту

No: 14  
 Name: ca\_7\_odp\_04  
 Type: list  
 Default: ["admin", "security\_officer"]

Визначено персонал або ролі, яким повідомляється про стан безпеки системи

No: 15  
 Name: ca\_7\_odp\_05  
 Type: integer  
 Default: 30

Визначено частоту, з якою повідомляється про стан безпеки системи

No: 16  
 Name: ca\_7\_odp\_06  
 Type: list  
 Default: ["admin", "security\_officer"]

Визначено персонал або ролі, яким повідомляється про стан конфіденційності системи

No: 17  
 Name: ca\_7\_odp\_07  
 Type: integer  
 Default: 30

Визначено частоту, з якою повідомляється про стан конфіденційності системи

## 5. СМ

Клас заходів захисту СМ — УПРАВЛІННЯ КОНФІГУРАЦІЄЮ

Цей клас гарантує створення та підтримання базових налаштувань системи, а також строгий контроль за змінами в апаратному та програмному забезпеченні.

Перелік заходів захисту: Політика та процедури управління конфігурацією (СМ-1); Базова конфігурація (СМ-2); Конфігурація систем та компонентів для сфер з високим ризиком (СМ-2(7)); Управління змінами конфігурації (СМ-3); Аналіз впливу на безпеку та приватність (СМ-4); Верифікація функцій безпеки та приватності (СМ-4(2)); Обмеження доступу до зміни (СМ-5); Налаштування конфігурації (СМ-6); Мінімально необхідна функціональність (СМ-7); Періодичний перегляд (СМ-7(1)); Авторизоване програмне забезпечення – білий список (СМ-7(5)); Інвентаризація компонентів системи (СМ-8); Оновлення під час встановлення та видалення (СМ-8(1)); Розташування інформації (СМ-12).

## 5.1. Політика та процедури управління конфігурацією (СМ-1)

а. Розробити, задокументувати та поширити серед [Призначення: визначених організацією персоналу або ролей]:

1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політики управління конфігурацією, яка:

2.

(a) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance);

(b) відповідає чинним законам, нормативним документам, наказам, положенням, політикам, стандартам і керівним принципам; процедури, що сприяють реалізації політики управління конфігурацією та пов'язаних з нею заходів управління конфігурацією.

b. Призначити [Призначення: посадова особа, визначена організацією] для управління розробкою, документуванням і розповсюдженням політики та процедур керування конфігурацією.

c. Переглядати та оновлювати поточну політику управління конфігурацією:

1. Політика [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією];

2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією].

No: 1

Name: cm\_1\_a\_01

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Розроблено та задокументовано політику управління конфігурацією

No: 2

Name: cm\_1\_a\_02

Type: list

Default: ["admin", "security\_officer"]

Політика управління конфігурацією поширюється на персонал або ролі

No: 3

Name: cm\_1\_a\_03

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Розроблені та задокументовані процедури управління, що сприяють реалізації політики управління конфігурацією та пов'язаних з нею заходів управління конфігурацією

No: 4

Name: cm\_1\_b

Type: list

Default: ["admin", "security\_officer"]

Посадова особа призначається для управління розробкою, документуванням і розповсюдженням політики та процедур керування конфігурацією; CM-01(c)[01][01] переглядається та оновлюється поточна політика управління конфігурацією частота; CM-01(c)[01][02] переглядається та оновлюється поточна політика управління конфігурацією після події; CM-01(c)[02][01] переглядаються та оновлюються поточні процедури управління конфігурацією частота; CM-01(c)[02][02] переглядаються та оновлюються поточні процедури управління конфігурацією після події; ЗНАЧЕННЯ конфігурацією

No: 5

Name: cm\_1\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на яких поширюється політика управління конфігурацією

No: 6

Name: cm\_1\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на яких поширюється процедури управління конфігурацією

No: 7

Name: cm\_1\_odp\_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 8

Name: cm\_1\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Визначено посадову особу, яка управляє розробкою, документуванням і розповсюдженням політики та процедур керування конфігурацією

No: 9

Name: cm\_1\_odp\_05

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика управління конфігурацією

No: 10

Name: cm\_1\_odp\_06

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено події, після яких переглядається та оновлюється поточна політика управління конфігурацією

No: 11

Name: cm\_1\_odp\_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури управління конфігурацією

No: 12

Name: cm\_1\_odp\_08

Type: list

Default: ["login", "logout", "failed\_attempt"]

Визначено події, після яких переглядаються та оновлюються поточні процедури управління конфігурацією

## 5.2. БАЗОВА КОНФІГУРАЦІЯ (СМ-2)

а. Розробити, задокументувати та підтримувати за допомогою заходів конфігурації поточні базові налаштування системи.

б. Переглядати та оновлювати базові налаштування системи:

1. з [Призначення: визначеною організацією частотою];
2. за потреби внаслідок [Призначення: визначених організацією обставин];
3. коли встановлені нові або оновлені компоненти системи.

No: 1

Name: cm\_2\_a\_01

Type: string

Default: nil

Розроблено та задокументовано поточні базові налаштування системи

No: 2

Name: cm\_2\_a\_02

Type: string

Default: nil

Поточні базові налаштування системи підтримуються за допомогою заходів конфігурації

No: 3

Name: cm\_2\_b\_01

Type: string

Default: "щорічно"

Переглядаються та оновлюються базові налаштування системи частота

No: 4

Name: cm\_2\_b\_02

Type: string

Default: nil

Переглядаються та оновлюються базові налаштування системи після подій

No: 5

Name: cm\_2\_b\_03

Type: string

Default: nil

Переглядаються та оновлюються базові налаштування системи коли встановлюються або модернізуються компоненти системи

No: 6

Name: cm\_2\_odp\_01

Type: integer

Default: 30

Визначено частоту налаштувань; перегляду та оновлення базових

No: 7

Name: cm\_2\_odp\_02

Type: string

Default: nil

Визначено обставини, що вимагають перегляду та оновлення базових налаштувань



### 5.2.1. КОНФІГУРАЦІЯ СИСТЕМ ТА КОМПОНЕНТІВ ДЛЯ СФЕР З ВИСОКИМ РИЗИКОМ (СМ-2(7))

- (а) Видавати [Призначення: визначених організацією систем або компонентів систем] з [Призначенням: визначеними організацією конфігураціями] особам, що перебувають у місцях, які організація вважає місцями зі значним ризиком;
- (б) Застосувати [Призначення: визначені організацією запобіжні заходи безпеки] до компонентів, коли особи повертаються з поїздки.

No: 1

Name: cm\_2\_7\_a

Type: list

Default: ["admin", "security\_officer"]

Системи або компоненти системи з конфігураціями видаються особам, що перебувають у місцях, які організація вважає, становлять значний ризик

No: 2

Name: cm\_2\_7\_b

Type: list

Default: ["admin", "security\_officer"]

Заходи безпеки застосовуються до систем або компонентів системи, коли особи повертаються з поїздки

No: 3

Name: cm\_2\_7\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено системи або компоненти систем, які мають видаватися особам, що перебувають у місцях зі значним ризиком

### 5.3. УПРАВЛІННЯ ЗМІНАМИ КОНФІГУРАЦІЇ (СМ-3)

- Визначити типи змін у системі, які контролюються конфігурацією.
- Переглядати запропоновані зміни в конфігурації, контрольовані системою, і схвалити або відхилити ці зміни з явним урахуванням аналізу наслідків безпеки.
- Документувати рішення зі зміни конфігурації системи.
- Впровадити схвалені зміни конфігурації в систему.
- Зберігати записи змін конфігурації системи впродовж [Призначення: певного періоду часу, визначеного організацією].
- Здійснювати моніторинг і аналіз дій, пов'язаних зі змінами конфігурації системи.
- Координувати та впроваджувати нагляд за діяльністю з управління змінами конфігурації за допомогою [Призначення: елементу управління змінами конфігурації, визначеного організацією], який викликається [Вибір (один або кілька): [Призначення: з визначеною організацією частотою]; [Призначення: визначені організацією умови зміни конфігурації]].

No: 1

Name: cm\_3\_b\_01

Type: string

Default: nil

Розглядаються запропоновані зміни в конфігурації, що контролюються системою

No: 2

Name: cm\_3\_b\_02

Type: string

Default: nil

Запропоновані зміни в конфігурації, що контролюються системою, схвалюються або відхиляються з урахуванням аналізу наслідків безпеки

No: 3

Name: cm\_3\_c

Type: string

Default: nil

Рішення про зміну конфігурації системи документуються

No: 4

Name: cm\_3\_d

Type: string

Default: nil

Впроваджуються схвалені зміни до конфігурації в систему

No: 5

Name: cm\_3\_e

Type: integer

Default: 30

Записи про зміни конфігурації у системі зберігаються протягом <період часу CM-03\_ODP[01]>

No: 6

Name: cm\_3\_f\_01

Type: string

Default: nil

Здійснюється моніторинг конфігурації системи

No: 7

Name: cm\_3\_f\_02

Type: string

Default: nil

Здійснюється аналіз дій, пов'язаних зі змінами конфігурації системи

No: 8

Name: cm\_3\_g\_01

Type: string

Default: nil

Діяльність з управління змінами конфігурації координується та контролюється елемент управління

No: 9

Name: cm\_3\_odp\_01

Type: integer

Default: 30

Визначено період часу, протягом якого зберігатимуться записи про зміни конфігурації

No: 10

Name: cm\_3\_odp\_02

Type: string

Default: nil

Визначено елементи управління змінами конфігурації, відповідальні за координацію та нагляд за діяльністю з управління змінами

No: 11

Name: cm\_3\_odp\_03

Type: list

Default: []

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {частота; коли умови}

No: 12

Name: cm\_3\_odp\_04

Type: integer

Default: 30

Визначено частоту, з якою викликаються елементи управління змінами конфігурації (якщо вибрано)

No: 13

Name: cm\_3\_odp\_05

Type: list

Default: []

Визначено умови, за яких викликаються елементи управління змінами конфігурації (якщо вибрано); CM-03(a) визначено та задокументовано типи змін до системи, які контролюються конфігурацією

## 5.4. АНАЛІЗ ВПЛИВУ НА БЕЗПЕКУ ТА ПРИВАТНІСТЬ (CM-4)

Аналізувати зміни в системі, щоб визначити потенційну загрозу безпеці та приватності перед реалізацією змін.

No: 1

Name: cm\_4\_01

Type: string

Default: nil

Аналізуються зміни в системі, щоб визначити потенційну загрозу безпеці перед реалізацією змін

No: 2

Name: cm\_4\_02

Type: string

Default: nil

Аналізуються зміни в системі, щоб визначити потенційну загрозу конфіденційності перед реалізацією змін

### 5.4.1. ВЕРИФІКАЦІЯ ФУНКЦІЙ БЕЗПЕКИ ТА ПРИВАТНОСТІ (CM-4(2))

Після змін у системі переконайтеся, що відповідні заходи захисту реалізовано правильно і вони функціонують належним чином та дають бажаний результат щодо дотримання вимог безпеки та приватності для системи.

No: 1

Name: cm\_4\_2\_01

Type: string

Default: nil

Заходи захисту, на які було здійснено вплив, реалізовані правильно з точки зору відповідності вимогам безпеки системи після внесення змін до системи

No: 2

Name: cm\_4\_2\_02

Type: string

Default: nil

Заходи захисту, на які було здійснено вплив, реалізовані правильно з точки зору відповідності вимогам конфіденційності системи після внесення змін до системи

No: 3

Name: cm\_4\_2\_03

Type: string

Default: nil

Заходи захисту, на які було здійснено вплив, функціонують належним чином з точки зору відповідності вимогам безпеки системи після внесення змін до системи

No: 4

Name: cm\_4\_2\_04

Type: string

Default: nil

Заходи захисту, на які було здійснено вплив, функціонують належним чином з точки зору відповідності вимогам конфіденційності системи після внесення змін до системи

No: 5

Name: cm\_4\_2\_05

Type: string

Default: nil

Заходи захисту, на які було здійснено вплив, дають бажаний результат з точки зору відповідності вимогам безпеки системи після внесення змін до системи

No: 6

Name: cm\_4\_2\_06

Type: string

Default: nil

Заходи захисту, на які було здійснено вплив, дають бажаний результат з точки зору відповідності вимогам конфіденційності системи після внесення змін до системи; ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

## 5.5. ОБМЕЖЕННЯ ДОСТУПУ ДО ЗМІНИ (СМ-5)

Визначити, задокументувати, затвердити та забезпечити застосування фізичних і логічних обмежень доступу, пов'язаних зі змінами в системі.

No: 1

Name: cm\_5\_01

Type: string

Default: nil

Визначені та задокументовані фізичні обмеження доступу, пов'язані зі змінами в системі

No: 2

Name: cm\_5\_02

Type: string

Default: nil

Затверджені фізичні обмеження доступу, пов'язані зі змінами в системі

No: 3

Name: cm\_5\_03

Type: string

Default: nil

Застосовуються фізичні обмеження доступу, пов'язані зі змінами в системі

No: 4  
Name: cm\_5\_04  
Type: string  
Default: nil

Визначені та задокументовані логічні обмеження доступу, пов'язані зі змінами в системі

No: 5  
Name: cm\_5\_05  
Type: string  
Default: nil

Затверджені логічні обмеження доступу, пов'язані зі змінами в системі

No: 6  
Name: cm\_5\_06  
Type: string  
Default: nil

Застосовуються логічні обмеження доступу, пов'язані зі змінами в системі

## 5.6. НАЛАШТУВАННЯ КОНФІГУРАЦІЇ (СМ-6)

- a. Встановити та задокументувати параметри конфігурації компонентів, які застосовуються в системі, які відображають найбільш обмежений режим, що відповідає експлуатаційним вимогам, використовуючи [Призначення: визначені організацією загальні безпечні конфігурації].
- b. Реалізувати конфігураційні установки.
- c. Визначити, задокументувати та затвердити будь-які відхилення від встановлених конфігураційних параметрів конфігурації для [Призначення: визначених організацією компонентів системи] на основі [Призначення: визначених організацією експлуатаційних вимог].
- d. Відстежувати та керувати змінами конфігураційних параметрів відповідно до організаційної політики та процедур.

No: 1  
Name: cm\_6\_a  
Type: string  
Default: nil

Налаштування конфігурації, які відображають найбільш обмежувальний режим, що відповідає експлуатаційним вимогам, встановлені та задокументовані для компонентів, що застосовуються в системі з використанням безпечні конфігурації

No: 2  
Name: cm\_6\_b  
Type: string  
Default: nil

Реалізовано установки конфігурації, задокументовані в СМ-06a

No: 3  
Name: cm\_6\_c\_01  
Type: string  
Default: nil

Будь-які відхилення від встановлених параметрів конфігурації для компонентів системи визначаються та документуються на основі експлуатаційних вимог

No: 4

Name: cm\_6\_c\_02

Type: string

Default: nil

Будь-які відхилення від встановлених налаштувань конфігурації для компонентів системи затверджуються

No: 5

Name: cm\_6\_d\_01

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Зміни в налаштуваннях конфігурації відстежуються відповідно до політики та процедур організації

No: 6

Name: cm\_6\_d\_02

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Зміни налаштувань конфігурації керуються відповідно до політики та процедур організації

No: 7

Name: cm\_6\_odp\_01

Type: string

Default: nil

Визначено загальні безпечні конфігурації для встановлення та документування параметрів конфігурації компонентів, які застосовуються в системі; CM-06\_ODP[02] визначено компоненти системи, для яких необхідно затвердити відхилення

No: 8

Name: cm\_6\_odp\_03

Type: string

Default: nil

Визначені експлуатаційні вимоги, що вимагають затвердження відхилень

## 5.7. МІНІМАЛЬНО НЕОБХІДНА ФУНКЦІОНАЛЬНІСТЬ (CM-7)

a. Налаштуйте систему для забезпечення лише [Призначення: основні функції, визначені організацією для місії];

b. Заборонити або обмежити використання таких функцій, портів, протоколів, програмного забезпечення та/або служб: [Призначення: визначені організацією заборонені або обмежені функції, системні порти, протоколи, програмне забезпечення та/або служби].

No: 1

Name: cm\_7\_a

Type: string

Default: nil

Система налаштована на забезпечення лише основні функції системи

No: 2

Name: cm\_7\_b\_01

Type: string

Default: nil

Використання функцій заборонено або обмежено

No: 3  
Name: cm\_7\_b\_02  
Type: string  
Default: nil

Використання порти заборонено або обмежено

No: 4  
Name: cm\_7\_b\_03  
Type: string  
Default: "TLS 1.3"

Використання протоколи заборонено або обмежено

No: 5  
Name: cm\_7\_b\_04  
Type: string  
Default: nil

Використання програмне забезпечення заборонено або обмежено

No: 6  
Name: cm\_7\_b\_05  
Type: string  
Default: nil

Використання служби заборонено або обмежено

No: 7  
Name: cm\_7\_odp\_01  
Type: string  
Default: nil

Визначено основні функції системи, необхідні для виконання місії

No: 8  
Name: cm\_7\_odp\_02  
Type: string  
Default: nil

Визначено функції, які необхідно заборонити або обмежити

No: 9  
Name: cm\_7\_odp\_03  
Type: string  
Default: nil

Визначено системні порти, які необхідно заборонити або обмежити

No: 10  
Name: cm\_7\_odp\_04  
Type: string  
Default: "TLS 1.3"

Визначено протоколи, які необхідно заборонити або обмежити; CM-07\_ODP[05] визначено програмне забезпечення, яке необхідно заборонити або обмежити

No: 11  
Name: cm\_7\_odp\_06  
Type: string  
Default: nil

Визначено служби, які необхідно заборонити або обмежити

### 5.7.1. ПЕРІОДИЧНИЙ ПЕРЕГЛЯД (СМ-7(1))

No: 1

Name: cm\_7\_1\_a

Type: string

Default: "TLS 1.3"

Система переглядається частота для виявлення непотрібних та/або незахищених функцій, портів, протоколів і послуг

No: 2

Name: cm\_7\_1\_b\_01

Type: string

Default: nil

Функції, які вважаються непотрібними та/або незахищеними, вимкнено

No: 3

Name: cm\_7\_1\_b\_02

Type: string

Default: nil

Порти, які вважаються непотрібними та/або незахищеними, вимкнено

No: 4

Name: cm\_7\_1\_b\_03

Type: string

Default: "TLS 1.3"

Протоколи, які вважаються непотрібними та/або незахищеними, вимкнено

No: 5

Name: cm\_7\_1\_b\_04

Type: string

Default: nil

Послуги, які вважаються непотрібними та/або незахищеними, вимкнено

No: 6

Name: cm\_7\_1\_odp\_01

Type: string

Default: "TLS 1.3"

Визначено частоту, з якою слід переглядати систему для виявлення непотрібних та/або незахищених функцій, портів, протоколів і послуг

No: 7

Name: cm\_7\_1\_odp\_02

Type: string

Default: nil

Визначено функції, які слід вимкнути, якщо вони вважаються непотрібними або незахищеними; CM-07(01)\_ODP[03] визначено порти, які слід вимкнути, якщо вони вважаються непотрібними або незахищеними

No: 8

Name: cm\_7\_1\_odp\_04

Type: string

Default: "TLS 1.3"

Визначено протоколи, які слід вимкнути, якщо вони вважаються непотрібними або незахищеними

No: 9

Name: cm\_7\_1\_odp\_05



Type: string

Default: nil

Визначено послуги, які слід вимкнути, якщо вони вважаються непотрібними або незахищеними

## 5.7.2. АВТОРИЗОВАНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ – БІЛИЙ СПИСОК (СМ-7(5))

(a) Визначити [Призначення: визначені організацією програмне забезпечення, яке авторизовано виконується в системі]

(b) Впровадити політику «заборони всього, за винятком деяких», щоб дозволити виконання авторизованих програм у системі.

(c) Переглядати та оновлювати список авторизованих програм [Призначення: з визначеною організацією частотою].

No: 1

Name: cm\_7\_5\_a

Type: string

Default: nil

Визначено програмне забезпечення

No: 2

Name: cm\_7\_5\_b

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Політика "заборонити все, дозволити за винятком" застосовується, щоб дозволити виконання авторизованих програм у системі

No: 3

Name: cm\_7\_5\_c

Type: list

Default: []

Переглядається та оновлюється список авторизованих програм частота

No: 4

Name: cm\_7\_5\_odp\_01

Type: string

Default: nil

Визначено програмне забезпечення, яке авторизовано для виконання в системі

No: 5

Name: cm\_7\_5\_odp\_02

Type: integer

Default: 30

Визначено частоту перегляду та оновлення списку авторизованих програм

## 5.8. ІНВЕНТАРИЗАЦІЯ КОМПОНЕНТІВ СИСТЕМИ (СМ-8)

a.

b. Розробити та задокументувати процес інвентаризації компонентів системи, який:

1. точно описує поточну систему;
2. охоплює всі компоненти в межах акредитації системи;

3. не включає повторний облік компонентів або компонентів, будь-якої іншої системи;  
 4. визначає рівень деталізації, який є необхідним для відстеження та звітування;  
 5. включає інформацію для досягнення підзвітності компонентів системи: [Призначення: визначена організацією інформація, необхідна для досягнення ефективної підзвітності компонентів системи]. Переглядати та оновлювати опис компонентів системи з [Призначення: визначеною організацією частотою].

No: 1

Name: cm\_8\_a\_01

Type: string

Default: nil

Розроблено та задокументовано процес інвентаризації компонентів системи, який точно описує поточну систему

No: 2

Name: cm\_8\_a\_02

Type: string

Default: nil

Розроблено та задокументовано процес інвентаризації компонентів системи, який охоплює всі компоненти в межах акредитації системи

No: 3

Name: cm\_8\_a\_03

Type: string

Default: nil

Розроблено та задокументовано процес інвентаризації компонентів системи, який не включає повторний облік компонентів або компонентів, будь-якої іншої системи

No: 4

Name: cm\_8\_a\_04

Type: string

Default: nil

Розроблено та задокументовано процес інвентаризації компонентів системи, який визначає рівень деталізації, який є необхідним для відстеження та звітування

No: 5

Name: cm\_8\_a\_05

Type: string

Default: nil

Розроблено та задокументовано процес інвентаризації компонентів системи, який включає інформацію

No: 6

Name: cm\_8\_b

Type: string

Default: "щорічно"

Переглядається та оновлюється опис компонентів системи частота

No: 7

Name: cm\_8\_odp\_01

Type: string

Default: nil

Визначено інформацію, яка вважається необхідною для досягнення ефективної підзвітності компонентів системи

No: 8

Name: cm\_8\_odp\_02

Type: integer

Default: 30

Визначено частоту перегляду та оновлення опису компонентів системи

### 5.8.1. ОНОВЛЕННЯ ПІД ЧАС ВСТАНОВЛЕННЯ ТА ВИДАЛЕННЯ (СМ-8(1))

No: 1

Name: cm\_8\_1\_01

Type: string

Default: nil

Інвентаризація компонентів системи оновлюється в рамках інсталяцій компонентів системи

No: 2

Name: cm\_8\_1\_02

Type: string

Default: nil

Інвентаризація компонентів системи оновлюється в рамках видалення компонентів системи

No: 3

Name: cm\_8\_1\_03

Type: string

Default: nil

Інвентаризація компонентів системи оновлюється в рамках оновлення компонентів системи

## 5.9. РОЗТАШУВАННЯ ІНФОРМАЦІЇ (СМ-12)

No: 1

Name: cm\_12\_a\_01

Type: string

Default: nil

Місцезнаходження інформація визначено та задокументовано

No: 2

Name: cm\_12\_a\_02

Type: string

Default: nil

Визначено та задокументовано конкретні компоненти системи, на яких обробляється інформація

No: 3

Name: cm\_12\_a\_03

Type: string

Default: nil

Визначено та задокументовано конкретні компоненти системи, на яких зберігається інформація

No: 4

Name: cm\_12\_b\_01

Type: string

Default: nil

Визначено та задокументовано користувачів, які мають доступ до системи та компонентів системи, де обробляється інформація

No: 5  
 Name: cm\_12\_b\_02  
 Type: string  
 Default: nil

Визначено та задокументовано користувачів, які мають доступ до системи та компонентів системи, де зберігається інформація; CM-12(c)[01] задокументовано зміни розташування (наприклад, системи або компонентів системи), де обробляється інформація

No: 6  
 Name: cm\_12\_c\_02  
 Type: string  
 Default: nil

Задокументовано зміни розташування (наприклад, системи або компонентів системи), де зберігається інформація

No: 7  
 Name: cm\_12\_odp  
 Type: string  
 Default: nil

Визначено інформацію, місцезнаходження якої має бути визначено та задокументовано

## 6. СР

Клас заходів захисту СР — ПЛАНУВАННЯ БЕЗПЕРЕРВНОЇ РОБОТИ

Цей клас описує заходи для відновлення функціонування інформаційної системи та забезпечення її безперебійної роботи у разі надзвичайних ситуацій.

Перелік заходів захисту: Резервне копіювання (СР-9); Криптографічний захист (СР-9(8)).

### 6.1. РЕЗЕРВНЕ КОПІЮВАННЯ (СР-9)

No: 1  
 Name: cp\_9\_01  
 Type: string  
 Default: nil

РЕЗЕРВНЕ КОПІЮВАННЯ МЕТА ОЦІНКИ: Визначити, чи:

No: 2  
 Name: cp\_9\_a  
 Type: string  
 Default: "щорічно"

Резервне копіювання інформації користувача, що міститься в компонентах системи, здійснюється частота

No: 3  
 Name: cp\_9\_b  
 Type: string  
 Default: "щорічно"

Виконується резервне копіювання інформації системи, що міститься в системі частота; СР-09(c) створюються резервні копії документації системи, включаючи документацію, пов'язану з безпекою та конфіденційністю

частота

No: 4

Name: cp\_9\_d\_01

Type: string

Default: nil

Конфіденційність резервних копій інформації захищена

No: 5

Name: cp\_9\_d\_02

Type: string

Default: nil

Цілісність резервних копій інформації захищена

No: 6

Name: cp\_9\_d\_03

Type: string

Default: nil

Доступність резервних копій інформації захищена

No: 7

Name: cp\_9\_odp\_01

Type: string

Default: nil

Визначено компоненти системи, для яких необхідно проводити резервне копіювання інформації користувачів

No: 8

Name: cp\_9\_odp\_02

Type: integer

Default: 30

Визначено частоту, з якою слід проводити резервне копіювання інформації користувача відповідно до часу відновлення та цілей відновлення

No: 9

Name: cp\_9\_odp\_03

Type: integer

Default: 30

Визначено частоту проведення резервного копіювання інформації системи, що відповідає завдань відновлення і встановлених цілей відновлення

No: 10

Name: cp\_9\_odp\_04

Type: integer

Default: 30

Визначено частоту, з якою слід проводити резервне копіювання документації системи відповідно до часу відновлення та цілей точки відновлення

### 6.1.1. КРИПТОГРАФІЧНИЙ ЗАХИСТ (CP-9(8))

No: 1

Name: cp\_9\_8\_01

Type: string

Default: "AES-256-GCM"

Реалізовано криптографічні механізми для запобігання несанкціонованому розкриттю та зміні резервної інформації

No: 2  
 Name: cp\_9\_8\_odp  
 Type: string  
 Default: nil

Визначено резервні копії інформації для захисту від несанкціонованого розкриття та змін

## 7. ІА

### Клас заходів захисту ІА — ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ

Цей клас відповідає за однозначне розпізнавання користувачів або пристроїв та підтвердження їхньої справжності перед наданням доступу до системи.

Перелік заходів захисту: Політика та процедури ідентифікації та автентифікації (ІА-1); Ідентифікація та автентифікація користувачів (ІА-2); Багатофакторна автентифікація привілейованих облікових записів (ІА-2(1)); Багатофакторна автентифікація непривілейованих (ІА-2(2)); Доступ до облікових записів — стійкість до відтворення (ІА-2(8)); Ідентифікація та автентифікація пристроїв (ІА-3); Управління ідентифікацією (ІА-4); Ідентифікація статусу користувача (ІА-4(4)); АВТЕНТИФІКАТОР УПРАВЛІННЯ; Автентифікація на основі пароля (ІА-5(1)); ПРИХОВУВАННЯ ЗВОРОТНОГО ЗВ'ЯЗКУ АВТЕНТИФІКАТОРА; Повторна автентифікація (ІА-11).

### 7.1. Політика та процедури ідентифікації та автентифікації (ІА-1)

No: 1  
 Name: ia\_1\_a\_01  
 Type: list  
 Default: ["default\_deny\_rule", "abac\_rule\_1"]

Розроблено та задокументовано політику ідентифікації та автентифікації

No: 2  
 Name: ia\_1\_a\_02  
 Type: list  
 Default: ["admin", "security\_officer"]

Політика ідентифікації та автентифікації поширюється на персонал або ролі

No: 3  
 Name: ia\_1\_a\_03  
 Type: list  
 Default: ["default\_deny\_rule", "abac\_rule\_1"]

Розроблені та задокументовані процедури ідентифікації та автентифікації, що сприяють впровадженню політики ідентифікації та автентифікації, а також відповідні заходи ідентифікації та перевірки автентичності

No: 4  
 Name: ia\_1\_b  
 Type: list  
 Default: ["admin", "security\_officer"]

Посадова особа призначається для управління політикою та процедурами ідентифікації та автентифікації; ІА-01(c)[01][01] переглядається та оновлюється поточна політика ідентифікації та автентифікації частота;

IA-01(c)[01][02] переглядається та оновлюється поточна політика ідентифікації та автентифікації після подій;  
 IA-01(c)[02][01] переглядаються та оновлюються поточні процедури ідентифікації та автентифікації частота;  
 IA-01(c)[02][02] переглядаються та оновлюються поточні процедури ідентифікації та автентифікації після подій

No: 5

Name: ia\_1\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на які поширюється політика ідентифікації та автентифікації

No: 6

Name: ia\_1\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на які поширюються процедури ідентифікації та автентифікації

No: 7

Name: ia\_1\_odp\_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесів; рівень системи}

No: 8

Name: ia\_1\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Визначено посадову особу, яка управляє політикою та процедурами ідентифікації та автентифікації

No: 9

Name: ia\_1\_odp\_05

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика ідентифікації та автентифікації

No: 10

Name: ia\_1\_odp\_06

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено події, які потребують перегляду та оновлення поточної політики ідентифікації та автентифікації

No: 11

Name: ia\_1\_odp\_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури ідентифікації та автентифікації

No: 12

Name: ia\_1\_odp\_08

Type: list

Default: ["login", "logout", "failed\_attempt"]

Визначено події, які потребують перегляду та оновлення процедур ідентифікації та автентифікації

## 7.2. ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ КОРИСТУВАЧІВ (ІА-2)

No: 1

Name: ia\_2\_01

Type: string

Default: nil

ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: ia\_2\_02

Type: string

Default: nil

Процеси що діють від імені користувачів унікально ідентифіковані та автентифіковані

### 7.2.1. БАГАТОФАКТОРНА АВТЕНТИФІКАЦІЯ ПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ (ІА-2(1))

No: 1

Name: ia\_2\_1\_01

Type: string

Default: nil

Реалізовано багатофакторну автентифікацію для доступу до привілейованих облікових записів

### 7.2.2. БАГАТОФАКТОРНА АВТЕНТИФІКАЦІЯ НЕПРИВІЛЕЙОВАНИХ (ІА-2(2))

No: 1

Name: ia\_2\_2\_01

Type: string

Default: nil

Реалізовано багатофакторну автентифікацію для доступу до непривілейованих облікових записів

### 7.2.3. Доступ до облікових записів — стійкість до відтворення (ІА-2(8))

No: 1

Name: ia\_2\_8\_odp

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {привілейовані облікові записи; непривілейовані облікові записи}



## 7.3. ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ ПРИСТРОЇВ (IA-3)

No: 1

Name: ia\_3\_odp\_01

Type: string

Default: nil

Визначені пристрої та/або типи пристроїв, які повинні бути унікально ідентифіковані та автентифіковані перед установкою підключення

No: 2

Name: ia\_3\_odp\_02

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {локальний; віддалений; мережевий}

## 7.4. УПРАВЛІННЯ ІДЕНТИФІКАЦІЄЮ (IA-4)

No: 1

Name: ia\_4\_a

Type: list

Default: ["admin", "security\_officer"]

Управління ідентифікаторами здійснюється шляхом отримання дозволу від персоналу або ролей на призначення ідентифікатора особі, групі, ролі або пристрою

No: 2

Name: ia\_4\_b

Type: list

Default: ["admin", "security\_officer"]

Управління ідентифікаторами здійснюється шляхом вибору ідентифікатора, який ідентифікує окрему особу, групу, ролі або пристрій

No: 3

Name: ia\_4\_c

Type: list

Default: ["admin", "security\_officer"]

Управління ідентифікаторами здійснюється шляхом призначення ідентифікатора особі, групі, ролі або пристрою; IA-04(d) ідентифікатори управляються шляхом запобігання повторному використанню ідентифікаторів впродовж період часу

No: 4

Name: ia\_4\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, від яких необхідно отримати дозвіл на призначення ідентифікатора

No: 5

Name: ia\_4\_odp\_02

Type: integer

Default: 30

Визначено період часу для запобігання повторному використанню ідентифікаторів

### 7.4.1. ІДЕНТИФІКАЦІЯ СТАТУСУ КОРИСТУВАЧА (IA-4(4))

No: 1

Name: ia\_4\_4\_01

Type: string

Default: nil

Управління індивідуальними ідентифікаторами, однозначно ідентифікуючи кожного індивідуума ознака, що ідентифікує індивідуальний статус

No: 2

Name: ia\_4\_4\_odp

Type: string

Default: nil

Визначено ознаку, що ідентифікує індивідуальний статус

## 7.5. АВТЕНТИФІКАТОР УПРАВЛІННЯ

No: 1

Name: ia\_5\_a

Type: list

Default: ["admin", "security\_officer"]

Управління системними автентифікаторами здійснюється шляхом перевірки, як частини початкового розподілу автентифікатора, особи, групи, ролі або пристрою, який отримує автентифікатор

No: 2

Name: ia\_5\_b

Type: string

Default: nil

Управління системними автентифікаторами здійснюється шляхом створення вихідного вмісту автентифікатора для будь-яких автентифікаторів, виданих організацією

No: 3

Name: ia\_5\_c

Type: string

Default: nil

Управління системними автентифікаторами здійснюється шляхом забезпечення того, щоб автентифікатори мали достатню стійкість механізму для їх використання за призначенням; IA-05(d) управління системними автентифікаторами здійснюється шляхом створення та реалізація адміністративних процедур для первинного розповсюдження автентифікаторів, для втрачених/скомпрометованих або пошкоджених автентифікаторів, а також для відкликання автентифікаторів

No: 4

Name: ia\_5\_e

Type: string

Default: nil

Управління системними автентифікаторами здійснюється шляхом зміни типових автентифікаторів перед першим використанням

No: 5

Name: ia\_5\_f

Type: list

Default: ["login", "logout", "failed\_attempt"]

Управління системними автентифікаторами здійснюється шляхом зміни/оновлення автентифікаторів у встановлений період часу або коли відбуваються події

No: 6  
Name: ia\_5\_g  
Type: string  
Default: nil

Управління системними автентифікаторами здійснюється шляхом захисту вмісту автентифікатора від несанкціонованого розкриття та модифікацій

No: 7  
Name: ia\_5\_h  
Type: string  
Default: nil

Управління системними автентифікаторами здійснюється шляхом вимоги до осіб, які використовують пристрої, використовувати спеціальні заходи безпеки для захисту автентифікаторів

No: 8  
Name: ia\_5\_i  
Type: string  
Default: nil

Управління системними автентифікаторами здійснюється шляхом вимоги змінювати автентифікатори для облікових записів груп/ролей при зміні членства в цих облікових записах

No: 9  
Name: ia\_5\_odp\_01  
Type: integer  
Default: 30

Визначено період часу для зміни або оновлення автентифікаторів за типом автентифікатора

## 7.5.1. АВТЕНТИФІКАЦІЯ НА ОСНОВІ ПАРОЛЯ (IA-5(1))

No: 1  
Name: ia\_5\_1\_a  
Type: list  
Default: ["admin", "security\_officer"]

Для автентифікації на основі паролів підтримується та оновлюється список часто використовуваних, очікуваних або скомпрометованих паролів частота, а також коли є підозра, що паролі організації були скомпрометовані прямо чи опосередковано

No: 2  
Name: ia\_5\_1\_b  
Type: list  
Default: ["admin", "security\_officer"]

Для автентифікації на основі паролів, коли паролі створюються або оновлюються користувачами, паролі перевіряються на відсутність у списку загальноновживаних, очікуваних або скомпрометованих паролів в IA-05(01)(a)

No: 3  
Name: ia\_5\_1\_c  
Type: list  
Default: ["admin", "security\_officer"]

Для автентифікації на основі паролів, паролі передаються лише криптографічно захищеними каналами

No: 4

Name: ia\_5\_1\_d

Type: list

Default: ["admin", "security\_officer"]

Для автентифікації на основі паролів паролі зберігаються за допомогою затвердженого алгоритму гешування, переважно використовуючи ключову геш-функцію

No: 5

Name: ia\_5\_1\_e

Type: string

Default: nil

Для автентифікації на основі пароля після відновлення облікового запису потрібно негайно вибрати новий пароль

No: 6

Name: ia\_5\_1\_f

Type: list

Default: ["admin", "security\_officer"]

Для автентифікації на основі пароля дозволяється вибір користувачем довгих паролів і фраз, що включають пробіли та всі друковані символи

No: 7

Name: ia\_5\_1\_g

Type: list

Default: ["admin", "security\_officer"]

Для автентифікації на основі пароля використовуються автоматизовані інструменти, які допомагають користувачеві у виборі надійних автентифікаторів паролів

No: 8

Name: ia\_5\_1\_h

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Для автентифікації на основі пароля застосовуються склад та правила складності

No: 9

Name: ia\_5\_1\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено частоту оновлення списку часто використовуваних, очікуваних або скомпрометованих паролів

No: 10

Name: ia\_5\_1\_odp\_02

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено склад та правила складності автентифікатора

## 7.6. ПРИХОВУВАННЯ ЗВОРОТНОГО ЗВ'ЯЗКУ АВТЕНТИФІКАТОРА

No: 1

Name: ia\_6\_01

Type: list

Default: ["admin", "security\_officer"]

Забезпечити приховану зворотню передачу інформації автентифікації в процесі автентифікації для забезпечення захисту інформації від можливої експлуатації та використання неавторизованими особами

## 7.7. ПОВТОРНА АВТЕНТИФІКАЦІЯ (IA-11)

No: 1

Name: ia\_11\_01

Type: string

Default: nil

Користувачі повинні повторно автентифікуватися, коли обставини або ситуації

No: 2

Name: ia\_11\_odp

Type: string

Default: nil

Визначено обставини або ситуації, що вимагають повторної автентифікації

## 8. IR

Клас заходів захисту IR — РЕАГУВАННЯ НА ІНЦИДЕНТИ

Цей клас визначає процедури виявлення, аналізу, локалізації та усунення наслідків інцидентів інформаційної безпеки.

Перелік заходів захисту: Політика та процедури реагування на інциденти (IR-1); Навчання з реагування на інциденти (IR-2); Перевірка реагувань на інциденти (IR-3); Обробка інциденту (IR-4); Моніторинг інциденту (IR-5); Звітність про інциденти (IR-6); Підтримка реагування на інциденти (IR-7); План реагування на інциденти (IR-8).

### 8.1. Політика та процедури реагування на інциденти (IR-1)

No: 1

Name: ir\_1\_a\_01

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Розроблено та задокументовано політику реагування на інциденти

No: 2

Name: ir\_1\_a\_02

Type: list

Default: ["admin", "security\_officer"]

Політика реагування на інциденти поширюється серед персоналу або ролей

No: 3

Name: ir\_1\_a\_03

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Розроблені та задокументовані процедури реагування на інциденти, що сприяють впровадженню політики реагування на інциденти та пов'язаних з нею заходів захисту з реагування на інциденти

No: 4

Name: ir\_1\_b

Type: list

Default: ["admin", "security\_officer"]

Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур реагування на інциденти; IR-01(c)[01][01] переглядається та оновлюється поточна політика реагування на інциденти частота; IR-01(c)[01][02] поточна політика реагування на інциденти переглядається та оновлюється після подій; IR-01(c)[02][01] переглядаються та оновлюються поточні процедури реагування на інциденти частота; IR-01(c)[02][02] поточні процедури реагування на інциденти переглядаються та оновлюються після подій

No: 5

Name: ir\_1\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, до яких має бути доведена політика реагування на інциденти

No: 6

Name: ir\_1\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, до яких мають бути доведені процедури реагування на інциденти

No: 7

Name: ir\_1\_odp\_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 8

Name: ir\_1\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами реагування на інциденти

No: 9

Name: ir\_1\_odp\_05

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика реагування на інциденти

No: 10

Name: ir\_1\_odp\_06

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначаються події, які потребують перегляду та оновлення поточної політики реагування на інциденти

No: 11

Name: ir\_1\_odp\_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури реагування на інциденти

No: 12

Name: ir\_1\_odp\_08

Type: list

Default: ["login", "logout", "failed\_attempt"]

Визначено події, які потребують перегляду та оновлення процедур реагування на інциденти

## 8.2. НАВЧАННЯ З РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-2)

No: 1

Name: ir\_2\_a\_01

Type: list

Default: ["admin", "security\_officer"]

Навчання з реагування на інциденти надається користувачам системи відповідно до призначених ролей та обов'язків протягом періоду часу з моменту прийняття на себе ролі або обов'язків з реагування на інциденти або отримання доступу до системи

No: 2

Name: ir\_2\_a\_02

Type: string

Default: nil

Навчання з реагування на інциденти надається користувачам системи відповідно до призначених ролей та обов'язків, коли цього вимагають зміни в системі

No: 3

Name: ir\_2\_a\_03

Type: string

Default: "щорічно"

Користувачам системи надається навчання з реагування на інциденти відповідно до призначених ролей та обов'язків частота

No: 4

Name: ir\_2\_b\_01

Type: string

Default: "щорічно"

Зміст навчання з реагування на інциденти переглядається та оновлюється частота

No: 5

Name: ir\_2\_b\_02

Type: string

Default: nil

Зміст навчання з реагування на інциденти переглядається та оновлюється після подій

No: 6

Name: ir\_2\_odp\_02

Type: integer

Default: 30

Визначено частоту, з якою користувачі повинні проходити навчання з реагування на інциденти

No: 7  
 Name: ir\_2\_odp\_03  
 Type: integer  
 Default: 30

Визначено частоту перегляду та оновлення змісту навчання з реагування на інциденти

No: 8  
 Name: ir\_2\_odp\_04  
 Type: list  
 Default: ["login", "logout", "failed\_attempt"]

Визначено події, які ініціюють перегляд змісту навчання з реагування на інциденти

### 8.3. ПЕРЕВІРКА РЕАГУВАНЬ НА ІНЦИДЕНТИ (IR-3)

No: 1  
 Name: ir\_3\_01  
 Type: string  
 Default: "щорічно"

Ефективність реагування системи на інциденти перевіряється частота за допомогою тестів

No: 2  
 Name: ir\_3\_odp\_01  
 Type: integer  
 Default: 30

Визначено частоту, з якою необхідно перевіряти ефективність реагування системи на інциденти

No: 3  
 Name: ir\_3\_odp\_02  
 Type: string  
 Default: nil

Визначено тести, що використовуються для перевірки ефективності реагування на інциденти в системі

### 8.4. Обробка інциденту (IR-4)

No: 1  
 Name: ir\_4\_a\_02  
 Type: string  
 Default: nil

Впроваджено можливість обробки інцидентів безпеки включно з виявленням

No: 2  
 Name: ir\_4\_a\_03  
 Type: string  
 Default: nil

Впроваджено можливість обробки інцидентів безпеки включно з аналізом

No: 3  
 Name: ir\_4\_a\_04  
 Type: string  
 Default: nil



Впроваджено можливість обробки інцидентів безпеки включно з локалізацією

No: 4

Name: ir\_4\_a\_05

Type: string

Default: nil

Впроваджено можливість обробки інцидентів безпеки включно з ліквідацією

No: 5

Name: ir\_4\_a\_06

Type: string

Default: nil

Впроваджено можливість обробки інцидентів безпеки включно з відновленням

No: 6

Name: ir\_4\_b

Type: string

Default: nil

Діяльність з обробки інцидентів координується із заходами із забезпечення безперервності функціонування

No: 7

Name: ir\_4\_c\_01

Type: string

Default: nil

Уроки, отримані з поточних дій з обробки інцидентів, включаються в процедури реагування на інциденти, навчання та тестування

No: 8

Name: ir\_4\_c\_02

Type: string

Default: nil

Зміни, що впливають відповідним чином

No: 9

Name: ir\_4\_d\_01

Type: string

Default: nil

Строгість заходів з обробки інцидентів передбачуваною в межах всієї організації

No: 10

Name: ir\_4\_d\_02

Type: string

Default: nil

Інтенсивність заходів з обробки інцидентів є порівнянною та передбачуваною в межах всієї організації

No: 11

Name: ir\_4\_d\_03

Type: string

Default: nil

Обсяг заходів з обробки інцидентів є порівнянною та передбачуваною в межах всієї організації

No: 12

Name: ir\_4\_d\_04

Type: string

Default: nil

Результати діяльності заходів з обробки інцидентів є порівнянною та передбачуваною в межах всієї організації; з отриманих уроків, є впроваджуються порівнянною

## 8.5. Моніторинг інциденту (IR-5)

No: 1

Name: ir\_5\_01

Type: string

Default: nil

Відстежуються інциденти безпеки та приватності

No: 2

Name: ir\_5\_02

Type: string

Default: nil

Документуються інциденти безпеки та приватності. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

## 8.6. ЗВІТНІСТЬ ПРО ІНЦИДЕНТИ (IR-6)

No: 1

Name: ir\_6\_a

Type: list

Default: ["admin", "security\_officer"]

Персонал зобов'язаний повідомляти про підозрілі інциденти протягом періоду часу

No: 2

Name: ir\_6\_b

Type: string

Default: nil

Інформацію про інцидент повідомляється органам

No: 3

Name: ir\_6\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено період часу, протягом якого персонал повинен повідомляти про підозрілі інциденти до уповноваженого органу

No: 4

Name: ir\_6\_odp\_02

Type: string

Default: nil

Визначені органи, до яких слід повідомляти інформацію про інцидент

## 8.7. ПІДТРИМКА РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-7)

No: 1

Name: ir\_7\_01

Type: string

Default: nil

Ресурс підтримки реагування на інциденти містить поради та допомогу користувачам системи для обробки та формування звітності про інциденти

## 8.8. План реагування на інциденти (IR-8)

No: 1

Name: ir\_8\_a\_01

Type: string

Default: nil

Розроблено план реагування на інциденти, який надає організації дорожню карту для впровадження її можливостей реагування на інциденти

No: 2

Name: ir\_8\_a\_02

Type: string

Default: nil

Розроблено план реагування на інциденти, який описує структуру та організацію спроможності реагування на інциденти

No: 3

Name: ir\_8\_a\_03

Type: string

Default: nil

Розроблено план реагування на інциденти, який надає високорівневий підхід до того, як здатність реагування на інциденти вписується в загальну практику організації

No: 4

Name: ir\_8\_a\_04

Type: string

Default: nil

Розроблено план реагування на інциденти, який відповідає унікальним вимогам організації, які пов'язані із завданнями, розміром, структурою і функціями

No: 5

Name: ir\_8\_a\_05

Type: string

Default: nil

Розроблено план реагування на інциденти, який визначає підзвітні інциденти

No: 6

Name: ir\_8\_a\_06

Type: string

Default: nil

Розроблено план реагування на інциденти, який надає показники для вимірювання можливостей реагування на інциденти всередині організації

No: 7

Name: ir\_8\_a\_07

Type: string

Default: nil

Розроблено план реагування на інциденти, який визначає ресурси та управлінську підтримку, необхідну для ефективної підтримки та розвитку можливостей реагування на інциденти

No: 8  
 Name: ir\_8\_a\_08  
 Type: string  
 Default: nil

Розроблено план реагування на інциденти, який вирішує питання обміну інформацією про інциденти

No: 9  
 Name: ir\_8\_a\_09  
 Type: list  
 Default: ["admin", "security\_officer"]

Розроблено план реагування на інцидент, який розглядається та затверджується персоналом або ролями частота

No: 10  
 Name: ir\_8\_a\_10  
 Type: list  
 Default: ["admin", "security\_officer"]

Розроблено план реагування на інциденти, в якому чітко визначено відповідальність за реагування на інциденти для організацій, персоналу або ролей

No: 11  
 Name: ir\_8\_b\_01  
 Type: list  
 Default: ["admin", "security\_officer"]

Копії плану реагування на інцидент розповсюджуються серед <IR- 08\_ODP[04] персоналу з реагування на інциденти>

No: 12  
 Name: ir\_8\_b\_02  
 Type: string  
 Default: nil

Копії плану реагування на інцидент розповсюджуються серед елементів організації

No: 13  
 Name: ir\_8\_c  
 Type: integer  
 Default: 30

План реагування на інциденти оновлюється з урахуванням змін у системі та організації або проблем, що виникають під час впровадження, виконання або тестування плану

No: 14  
 Name: ir\_8\_d\_01  
 Type: list  
 Default: ["admin", "security\_officer"]

Зміни в плані реагування на інцидент повідомляються персоналу з реагування на інциденти

No: 15  
 Name: ir\_8\_d\_02  
 Type: string  
 Default: nil

Зміни в плані реагування на інциденти надсилаються до елементів організації

No: 16

Name: ir\_8\_e\_01

Type: string

Default: nil

План реагування на інциденти захищений від несанкціонованого розкриття

No: 17

Name: ir\_8\_e\_02

Type: string

Default: nil

План реагування на інциденти захищений від несанкціонованої модифікації

No: 18

Name: ir\_8\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, які переглядають та затверджують план реагування на інциденти

No: 19

Name: ir\_8\_odp\_02

Type: string

Default: "щорічно"

Визначено періодичність перегляду та затвердження плану реагування на інциденти

No: 20

Name: ir\_8\_odp\_03

Type: list

Default: ["admin", "security\_officer"]

Визначені організації, персонал або ролі, які несуть відповідальність за реагування на інциденти; IR-08\_ODP[04] визначено персонал з реагування на інцидент (ідентифікований за іменами та/або за ролями), якому мають бути роздані копії плану реагування на інцидент

No: 21

Name: ir\_8\_odp\_05

Type: string

Default: nil

Визначено елементи організації, серед яких мають розповсюджені копії плану реагування на інцидент; бути

No: 22

Name: ir\_8\_odp\_06

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал з реагування на інцидент (ідентифікований за іменами та/або ролями), якому повідомляються зміни до плану реагування на інцидент

No: 23

Name: ir\_8\_odp\_07

Type: string

Default: nil

Визначено елементи організації, яким повідомляється про зміни в плані реагування на інцидент

## 9. МА

### Клас заходів захисту МА — ТЕХНІЧНЕ ОБСЛУГОВУВАННЯ

Цей клас регулює процеси планового та позапланового технічного обслуговування компонентів системи для запобігання збоям.

Перелік заходів захисту: Політика та процедури технічного обслуговування (МА-1); Інструменти для обслуговування (МА-3); Перевірка інструментів (МА-3(1)); Перевірка носіїв інформації (МА-3(2)); Запобігання несанкціонованому переміщенню (МА-3(3)); Віддалене обслуговування (МА-4); Технічний персонал (МА-5).

### 9.1. ПОЛІТИКА ТА ПРОЦЕДУРИ ТЕХНІЧНОГО ОБСЛУГОВУВАННЯ (МА-1)

- a. Планувати, документувати та переглядати записи з технічного обслуговування, ремонту або заміни компонентів системи відповідно до вимог виробника та постачальників та/або вимог організації.
- b. Затвердити та здійснювати моніторинг усіх заходів з технічного обслуговування, незалежно від того, виконуються вони на місці або віддалено, а також чи обслуговуються системи або системні компоненти на місці, чи переміщуються в інше місце.
- c. Вимагати, щоб [Призначення: визначені організацією персонал чи ролі] явно схвалили видалення системи або компонента системи з організаційного обладнання для технічного обслуговування, ремонту чи заміни поза об'єктами експлуатації.
- d. Очищати обладнання з погляду видалення всієї інформації з носіїв до вилучення обладнання організації для технічного обслуговування, ремонту чи заміни поза об'єктами експлуатації.
- e. Перевірити всі потенційно порушені заходи захисту, щоб переконатися, що вони, як і раніше, працюють належним чином після дій з обслуговування, ремонту або заміни.
- f. Вносити [Призначення: визначену організацією інформацію, пов'язану з технічним обслуговуванням] до записів з технічного обслуговування.

No: 1

Name: ma\_1\_a\_01

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Розроблено та задокументовано політику технічного обслуговування

No: 2

Name: ma\_1\_a\_02

Type: list

Default: ["admin", "security\_officer"]

Політика технічного обслуговування поширюється на персонал або ролі

No: 3

Name: ma\_1\_a\_03

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Розроблені та задокументовані процедури технічного обслуговування, що сприяють впровадженню політики технічного обслуговування та пов'язаних з нею заходів технічного обслуговування

No: 4

Name: ma\_1\_b

Type: list

Default: ["admin", "security\_officer"]

Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур технічного обслуговування; МА-01(с)[01][01] переглядається та оновлюється поточна політика обслуговування частота; МА-01(с)[01][02] переглядається та оновлюється поточна політика обслуговування після подій; МА-01(с)[02][01] переглядаються та оновлюються поточні процедури технічного обслуговування частота; МА-01(с)[02][02] переглядаються та оновлюються поточні процедури технічного обслуговування після подій

No: 5

Name: ma\_1\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на які поширюється політика технічного обслуговування

No: 6

Name: ma\_1\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на які поширюються процедури технічного обслуговування

No: 7

Name: ma\_1\_odp\_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 8

Name: ma\_1\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами технічного обслуговування

No: 9

Name: ma\_1\_odp\_05

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика технічного обслуговування

No: 10

Name: ma\_1\_odp\_06

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено події, які потребують перегляду та оновлення поточної політики технічного обслуговування

No: 11

Name: ma\_1\_odp\_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури технічного обслуговування

No: 12

Name: ma\_1\_odp\_08

Type: list

Default: ["login", "logout", "failed\_attempt"]

Визначено події, які потребують перегляду та оновлення процедур технічного обслуговування

## 9.2. ІНСТРУМЕНТИ ДЛЯ ОБСЛУГОВУВАННЯ (МА-3)

а. Затвердити, контролювати та відстежувати використання засобів технічного обслуговування.

б. Переглядати раніше затверджені інструменти технічного [Призначення: з частотою, визначеною організацією]. обслуговування

No: 1

Name: ma\_3\_a\_01

Type: string

Default: nil

Використання засобів технічного обслуговування затверджено

No: 2

Name: ma\_3\_a\_02

Type: string

Default: nil

Використання засобів технічного обслуговування контролюється

No: 3

Name: ma\_3\_a\_03

Type: string

Default: nil

Використання засобів технічного обслуговування відстажуються

No: 4

Name: ma\_3\_b

Type: string

Default: "щорічно"

Переглядаються раніше затверджені інструменти технічного обслуговування частота

No: 5

Name: ma\_3\_odp

Type: integer

Default: 30

Визначено частоту, з якою слід переглядати раніше затверджені інструменти технічного обслуговування

### 9.2.1. ПЕРЕВІРКА ІНСТРУМЕНТІВ (МА-3(1))

No: 1

Name: ma\_3\_1\_01

Type: list

Default: ["admin", "security\_officer"]

Оглядаються інструменти для технічного обслуговування, які доставлені на об'єкт обслуговуючим персоналом, на предмет неправильних або несанкціонованих модифікацій



### 9.2.2. ПЕРЕВІРКА НОСІЇВ ІНФОРМАЦІЇ (МА-3(2))

Перед використанням носіїв у системі перевірити носії, що містять діагностичні та тестові програми на наявність шкідливого коду.

No: 1

Name: ma\_3\_2\_01

Type: string

Default: nil

Перед використанням носіїв у системі перевіряються носії, що містять діагностичні та тестові програми на наявність шкідливого коду

### 9.2.3. ЗАПОБІГАННЯ НЕСАНКЦІОНОВАНОМУ ПЕРЕМІЩЕННЮ (МА-3(3))

Запобігти переміщенню обладнання для технічного обслуговування, що містить організаційну інформацію, шляхом:

- (a) перевірки відсутності організаційної інформації, розміщеної на обладнанні;
- (b) очищення або знищення обладнання;
- (c) утримання обладнання на об'єкті;
- (d) отримання дозволу від [Призначення: визначених організацією персоналу чи ролей], які явно дозволяють переміщення обладнання з об'єкта.

No: 1

Name: ma\_3\_3\_a

Type: string

Default: nil

Переміщення обладнання для технічного обслуговування, що містить інформацію організації, запобігається шляхом перевірки того, що на обладнанні не міститься ніякої інформації організації; або

No: 2

Name: ma\_3\_3\_b

Type: string

Default: nil

Переміщення обладнання для технічного обслуговування, що містить інформацію організації, запобігається шляхом очищення або знищення обладнання; або

No: 3

Name: ma\_3\_3\_c

Type: string

Default: nil

Переміщення обладнання для технічного обслуговування, що містить інформацію організації, запобігається шляхом утримання обладнання на об'єкті; або

No: 4

Name: ma\_3\_3\_d

Type: list

Default: ["admin", "security\_officer"]

Переміщення обладнання для технічного обслуговування, що містить інформацію організації, запобігається шляхом отримання дозволу від персоналу або ролі

No: 5

Name: ma\_3\_3\_odp

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, які можуть надавати дозвіл на переміщення обладнання з об'єкту

### 9.3. ВІДДАЛЕНЕ ОБСЛУГОВУВАННЯ (МА-4)

No: 1

Name: ma\_4\_a\_01

Type: list

Default: ["login", "logout", "failed\_attempt"]

Впроваджено віддалені дії з обслуговування та діагностики

No: 2

Name: ma\_4\_a\_02

Type: list

Default: ["login", "logout", "failed\_attempt"]

Відстежуються віддалені дії з обслуговування та діагностики

No: 3

Name: ma\_4\_b\_01

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Використання віддалених засобів технічного обслуговування та діагностики дозволено лише відповідно до політики організації

No: 4

Name: ma\_4\_b\_02

Type: string

Default: nil

Використання віддалених засобів технічного обслуговування та діагностики задокументовано в плані захисту інформації

No: 5

Name: ma\_4\_c

Type: string

Default: nil

Надійна автентифікація використовується при встановленні віддалених технічних та діагностичних сеансів

No: 6

Name: ma\_4\_d

Type: string

Default: nil

Ведеться облік віддалених дій з обслуговування та діагностики

No: 7

Name: ma\_4\_e\_01

Type: string

Default: nil

Сесія припиняється, коли завершено віддалене обслуговування

No: 8

Name: ma\_4\_e\_02

Type: string

Default: nil

Мережеве з'єднання припиняється, коли завершено віддалене обслуговування

## 9.4. ТЕХНІЧНИЙ ПЕРСОНАЛ (МА-5)

a. Встановити процедуру авторизації технічного персоналу та вести перелік авторизованих організацій технічного обслуговування або персоналу.

b. Перевіряти, що персонал, який не супроводжується та виконує технічне обслуговування в системі, має необхідні дозволи на доступ.

c. Визначити персонал організації з необхідними повноваженнями щодо доступу та технічною компетенцією для нагляду за персоналом з технічного обслуговування, який не має необхідних дозволів на доступ.

No: 1

Name: ma\_5\_a\_01

Type: list

Default: ["admin", "security\_officer"]

Запроваджено процес авторизації технічного персоналу

No: 2

Name: ma\_5\_a\_02

Type: list

Default: ["admin", "security\_officer"]

Ведеться перелік авторизованих організацій або персоналу з технічного обслуговування

No: 3

Name: ma\_5\_b

Type: list

Default: ["admin", "security\_officer"]

Персонал без супроводу, який виконує технічне обслуговування системи, має необхідні дозволи на доступ

No: 4

Name: ma\_5\_c

Type: list

Default: ["admin", "security\_officer"]

Персонал організації з необхідними повноваженнями доступу та технічною компетентністю призначений/призначені для нагляду за діяльністю з технічного обслуговування персоналу, який не має необхідних дозволів на доступ

## 10. МР

### Клас заходів захисту МР — ЗАХИСТ НОСІЇВ ІНФОРМАЦІЇ

Цей клас спрямований на безпечне зберігання, транспортування, використання та знищення як цифрових, так і паперових носіїв інформації.

Перелік заходів захисту: Політика та процедури щодо захисту носіїв інформації (МР-1); Доступ до носіїв інформації (МР-2); Маркування носіїв інформації (МР-3); Зберігання носіїв інформації (МР-4); Транспортування носіїв інформації (МР-5); Знищення інформації на носіях інформації (МР-6); Використання носіїв інформації (МР-7).

## 10.1. ПОЛІТИКА ТА ПРОЦЕДУРИ ЩОДО ЗАХИСТУ НОСІЇВ ІНФОРМАЦІЇ (MP-1)

а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або посад]:

1. 2. політику захисту носіїв інформації, яка:

(а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance);

(б) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам та керівним принципам; процедури, які сприяють здійсненню політики та заходів захисту носіїв інформації.

б. Призначити [Призначення: визначену організацією посадову особу] для управління розробкою, документуванням, та розповсюдженням політики та процедурами захисту носіїв інформації.

с. Переглядати та оновлювати чинну систему захисту носіїв інформації:

1. поточну політику захисту носіїв інформації [Призначення: з визначеною організацією частотою];

2. поточні процедури захисту носіїв інформації [Призначення: з визначеною організацією частотою].

No: 1

Name: mp\_1\_a\_01

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Розроблено та задокументовано політику захисту носіїв інформації

No: 2

Name: mp\_1\_a\_02

Type: list

Default: ["admin", "security\_officer"]

Політика захисту носіїв інформації поширюється на персонал або ролі

No: 3

Name: mp\_1\_a\_03

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Розроблено та задокументовано процедури захисту носіїв інформації, що сприятимуть реалізації політики захисту носіїв інформації та заходів захисту носіїв інформації

No: 4

Name: mp\_1\_b

Type: list

Default: ["admin", "security\_officer"]

Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур захисту носіїв інформації. MP-01(c)[01][01] переглядається та оновлюється поточна політика захисту носіїв інформації частота; MP-01(c)[01][02] переглядається та оновлюється поточна політика захисту носіїв інформації після подій; MP-01(c)[02][01] переглядаються та оновлюються поточні процедури захисту носіїв інформації частота; MP-01(c)[02][02] переглядаються та оновлюються поточні процедури захисту носіїв інформації після подій

No: 5

Name: mp\_1\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, серед яких має бути поширена політика захисту носіїв інформації

No: 6

Name: mp\_1\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, серед яких мають бути поширені процедури захисту носіїв інформації

No: 7

Name: mp\_1\_odp\_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 8

Name: mp\_1\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами захисту носіїв інформації

No: 9

Name: mp\_1\_odp\_05

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика захисту носіїв інформації

No: 10

Name: mp\_1\_odp\_06

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено події, які потребують перегляду та оновлення чинної політики захисту носіїв інформації

No: 11

Name: mp\_1\_odp\_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються чинні процедури захисту носіїв інформації

No: 12

Name: mp\_1\_odp\_08

Type: list

Default: ["login", "logout", "failed\_attempt"]

Визначено події, які потребують перегляду та оновлення процедур захисту носіїв інформації

## 10.2. ДОСТУП ДО НОСІЇВ ІНФОРМАЦІЇ (MP-2)

Обмежити доступ до [Призначення: визначених організацією типів цифрових та/або нецифрових носіїв інформації] [Призначення: визначеним організацією персоналом або ролями].

No: 1

Name: mp\_2\_01

Type: list

Default: ["admin", "security\_officer"]

Доступ до типів цифрових носіїв інформації обмежено для персоналу або ролей

No: 2

Name: mp\_2\_02

Type: list

Default: ["admin", "security\_officer"]

Доступ до типів нецифрових носіїв інформації обмежено для персоналу або ролей

No: 3

Name: mp\_2\_odp\_01

Type: string

Default: nil

Визначено типи цифрових носіїв інформації, доступ до яких обмежено

No: 4

Name: mp\_2\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, уповноважені на доступ до цифрових носіїв інформації

No: 5

Name: mp\_2\_odp\_03

Type: string

Default: nil

Визначено типи нецифрових носіїв інформації, доступ до яких обмежено

No: 6

Name: mp\_2\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, уповноважені на доступ до нецифрових носіїв інформації

## 10.3. МАРКУВАННЯ НОСІЇВ ІНФОРМАЦІЇ (МР-3)

a. Наносити на носії інформації маркування, що вказують на обмеження поширення, обробки, а також застереження та відповідні мітки безпеки (якщо такі є) інформації.

b. Звільнити [Призначення: визначені організацією типи носіїв системи] від маркування, якщо носії залишаються в межах [Призначення: визначених організацією контрольованих зон].

No: 1

Name: mp\_3\_01

Type: string

Default: nil

МАРКУВАННЯ НОСІЇВ ІНФОРМАЦІЇ МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: mp\_3\_a

Type: string

Default: nil

Носії інформації маркуються, щоб вказати на обмеження поширення, обробки, а також застереження та відповідні мітки безпеки (якщо такі є) інформації

No: 3

Name: mp\_3\_b

Type: string

Default: nil

Типи носіїв інформації залишаються в межах контрольованих зон

No: 4

Name: mp\_3\_odp\_01

Type: integer

Default: 30

Визначено типи носіїв інформації, які звільняються від маркування під час перебування на контрольованих зонах

No: 5

Name: mp\_3\_odp\_02

Type: string

Default: nil

Визначено контрольовані зони, де носії інформації звільняються від маркування

## 10.4. ЗБЕРІГАННЯ НОСІЇВ ІНФОРМАЦІЇ (МР-4)

а. Фізично контролювати та безпечно зберігати [Призначення: визначені організацією типи цифрових та/або нецифрових носіїв інформації] в межах [Призначення: визначених організацією контрольованих зон].

б. Захищати системні носії, які визначені в МР-4 до того часу, як носії знищуються або очищаються, з використанням затвердженого обладнання, методів та процедур.

No: 1

Name: mp\_4\_a\_01

Type: string

Default: nil

Типи цифрових носіїв контролюються фізично

No: 2

Name: mp\_4\_a\_02

Type: string

Default: nil

Типи нецифрових носіїв контролюються фізично

No: 3

Name: mp\_4\_a\_03

Type: string

Default: nil

Типи цифрових носіїв безпечно зберігаються в контрольованих зонах

No: 4

Name: mp\_4\_a\_04

Type: string

Default: nil

Типи нецифрових носіїв безпечно зберігаються в контрольованих зонах

No: 5

Name: mp\_4\_b

Type: string

Default: nil

Типи носіїв інформації (визначені в МР-04\_ODP[01], МР04\_ODP[02], МР-04\_ODP[03], МР-04\_ODP[04]) захищені доти, доки носії інформації не будуть знищені або очищені за допомогою визначеного обладнання, методик та процедур

No: 6

Name: mp\_4\_odp\_01

Type: string

Default: nil

Визначено типи цифрових носіїв інформації, які підлягають фізичному контролю (якщо вибрано)

No: 7

Name: mp\_4\_odp\_02

Type: string

Default: nil

Визначено типи нецифрових носіїв інформації, які підлягають фізичному контролю (якщо вибрано)

No: 8

Name: mp\_4\_odp\_03

Type: string

Default: nil

Визначено типи цифрових носіїв інформації для безпечного зберігання (якщо вибрано)

No: 9

Name: mp\_4\_odp\_04

Type: string

Default: nil

Визначено типи нецифрових носіїв інформації для безпечного зберігання (якщо вибрано)

No: 10

Name: mp\_4\_odp\_05

Type: string

Default: nil

Визначено контрольовані зони, в яких можна безпечно зберігати цифрові носії інформації; MP-04\_ODP[06]  
 визначено контрольовані зони, в яких можна безпечно зберігати нецифрові носії інформації

## 10.5. Транспортування носіїв інформації (MP-5)

- a. Захищати та контролювати [Призначення: визначені організацією типи носіїв системи] під час транспортування за межами контрольованих зон, використовуючи [Призначення: визначені організацією заходи безпеки].
- b. Вести облік носіїв системи інформації під час транспортування за межами контрольованих зон.
- c. Документувати дії, пов'язані з транспортуванням носіїв системи.
- d. Обмежити діяльність уповноваженого персоналу, пов'язану з транспортуванням носіїв системи.

No: 1

Name: mp\_5\_a\_01

Type: integer

Default: 30

Типи носіїв інформації системи захищаються під час транспортування за межі контрольованих зон за допомогою заходів безпеки

No: 2

Name: mp\_5\_a\_02

Type: integer

Default: 30



Типи носіїв інформації системи контролюються під час транспортування за межі контрольованих зон за допомогою заходів безпеки

No: 3  
Name: mp\_5\_b  
Type: integer  
Default: 30

Під час транспортування за межі контрольованих зон ведеться облік носіїв інформації системи

No: 4  
Name: mp\_5\_c  
Type: string  
Default: nil

Діяльність, пов'язана з транспортуванням носіїв інформації системи, задокументована

No: 5  
Name: mp\_5\_d\_01  
Type: list  
Default: ["admin", "security\_officer"]

Визначено персонал, уповноважений здійснювати діяльність з транспортування носіїв інформації

No: 6  
Name: mp\_5\_d\_02  
Type: list  
Default: ["admin", "security\_officer"]

Діяльність, пов'язана з транспортуванням носіїв інформації системи, обмежується визначеним уповноваженим персоналом

No: 7  
Name: mp\_5\_odp\_01  
Type: integer  
Default: 30

Визначено типи носіїв інформації системи для захисту та контролю під час транспортування за межі контрольованих зон

No: 8  
Name: mp\_5\_odp\_02  
Type: string  
Default: nil

Визначено заходи безпеки, що використовуються для захисту носіїв інформації системи поза контрольованими зонами

No: 9  
Name: mp\_5\_odp\_03  
Type: string  
Default: nil

Визначено заходи безпеки, що використовуються для контролю носіїв інформації системи за межами контрольованих зон

## 10.6. ЗНИЩЕННЯ ІНФОРМАЦІЇ НА НОСІЯХ ІНФОРМАЦІЇ (МР-6)

а. Очищувати [Призначення: визначені організацією системні носії] перед утилізацією, випуском за межі організаційного контролю, або перед повторним використанням [Призначення:

методами та процедурами очищення, визначеними організацією].

b. Використовувати механізми очищення зі стійкістю та цілісністю, що відповідає категорії безпеки або рівню секретності інформації.

No: 1

Name: mp\_6\_a\_01

Type: string

Default: nil

Носії інформації системи перед утилізацією піддаються очищенню за допомогою методів та процедур очищення

No: 2

Name: mp\_6\_a\_02

Type: string

Default: nil

Носії інформації системи очищаються за допомогою методів та процедур очищення перед випуском за межі контрольованої зони

No: 3

Name: mp\_6\_a\_03

Type: string

Default: nil

Носії інформації системи очищуються за допомогою методів і процедур очищення перед повторним використанням

No: 4

Name: mp\_6\_b

Type: string

Default: "автоматизований засіб моніторингу"

Застосовуються механізми очищення, надійність і цілісність яких відповідає категорії безпеки або рівню секретності інформації

No: 5

Name: mp\_6\_odp\_01

Type: string

Default: nil

Визначено носії інформації системи, які підлягають очищенню перед утилізацією

No: 6

Name: mp\_6\_odp\_02

Type: string

Default: nil

Визначено носії інформації системи, які підлягають очищенню перед випуском за межі контрольованої зони

No: 7

Name: mp\_6\_odp\_03

Type: string

Default: nil

Визначені носії інформації системи, що підлягають очищенню перед повторним використанням

No: 8

Name: mp\_6\_odp\_04

Type: string

Default: nil

Визначено методи та процедури очищення, які слід використовувати для очищення перед утилізацією

No: 9

Name: mp\_6\_odp\_05

Type: string

Default: nil

Визначено методи та процедури очищення, які слід використовувати для очищення перед випуском за межі контрольованої зони

No: 10

Name: mp\_6\_odp\_06

Type: string

Default: nil

Визначено методи та процедури очищення, які слід використовувати для очищення перед повторним використанням

## 10.7. ВИКОРИСТАННЯ НОСІЇВ ІНФОРМАЦІЇ (МР-7)

- a. [Вибір: обмежити; заборонити] використання [Призначення: визначених організацією типів носіїв системи] на [Призначення: визначені організацією системи або компоненти системи], використовуючи [Призначення: визначені організацією заходи безпеки].
- b. Заборонити використання портативних пристроїв зберігання даних в системах організації, якщо такі пристрої не мають визначеного власника.

No: 1

Name: mp\_7\_01

Type: string

Default: nil

ВИКОРИСТАННЯ НОСІЇВ ІНФОРМАЦІЇ МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: mp\_7\_b

Type: string

Default: nil

Використання зовнішніх носіїв інформації в системах організації заборонено, якщо такі пристрої не мають власника, якого можна ідентифікувати

No: 3

Name: mp\_7\_odp\_01

Type: string

Default: nil

Визначено типи носіїв інформації, які мають бути обмежені або заборонені до використання в системі або компонентах системи

No: 4

Name: mp\_7\_odp\_02

Type: string

Default: nil

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРА: {обмежити; заборонити}

No: 5

Name: mp\_7\_odp\_03

Type: string

Default: nil

Системи або компоненти системи, для яких визначено використання певних типів носіїв інформації, що підлягають обмеженню або забороні

No: 6

Name: mp\_7\_odp\_04

Type: string

Default: nil

Визначено заходи безпеки для обмеження або заборони використання певних типів носіїв інформації в системах або компонентах системи

## 11. PE

Клас заходів захисту PE — ФІЗИЧНИЙ ЗАХИСТ І ЗАХИСТ РОБОЧОГО

Цей клас охоплює заходи контролю фізичного доступу до об'єктів організації та захисту обладнання від загроз навколишнього середовища.

Перелік заходів захисту: Pe-1 фізичного захисту та захисту робочого середовища авторизація фізичного (PE-1); Pe-2 доступу (PE-2); ФІЗИЧНИЙ ДОСТУП ДО СИСТЕМИ; Pe-4 ліній електроживлення (PE-4); КОНТРОЛЬ ДОСТУПУ В ПРИМІЩЕННЯ ДЛЯ ВІДОБРАЖЕННЯ ІНФОРМАЦІЇ; МОНІТОРИНГ ФІЗИЧНОГО ДОСТУПУ; Альтернативне робоче місце (PE-17).

### 11.1. PE-1 фізичного захисту та захисту робочого середовища Авторизація фізичного (PE-1)

No: 1

Name: pe\_1\_a\_01

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Розроблено та задокументовано політику фізичного захисту та захисту робочого середовища

No: 2

Name: pe\_1\_a\_02

Type: list

Default: ["admin", "security\_officer"]

Політика фізичного захисту та захисту робочого середовища розповсюджується серед персоналу або ролей

No: 3

Name: pe\_1\_b

Type: list

Default: ["admin", "security\_officer"]

Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур фізичного захисту та захисту робочого середовища; PE-01(c)[01][01] переглядається та оновлюється поточна політика фізичного захисту та захисту робочого середовища частота; PE-01(c)[01][02] поточна політика фізичного захисту та захисту робочого середовища переглядається та оновлюється після подій; PE-01(c)[02][01] переглядаються та оновлюються поточні процедури фізичного захисту та захисту робочого середовища частота; поточні процедури фізичного та екологічного захисту переглядаються та оновлюються після подій. PE-01(c)[02][02]

No: 4

Name: pe\_1\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, до яких має бути доведена політика фізичного захисту та захисту робочого середовища

No: 5

Name: pe\_1\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на які поширюються процедури фізичного захисту та захисту робочого середовища

No: 6

Name: pe\_1\_odp\_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 7

Name: pe\_1\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами фізичного захисту та захисту робочого середовища

No: 8

Name: pe\_1\_odp\_05

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика фізичного захисту та захисту робочого середовища

No: 9

Name: pe\_1\_odp\_06

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено події, які потребують перегляду та оновлення поточної політики фізичного захисту та захисту робочого середовища

No: 10

Name: pe\_1\_odp\_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури фізичного захисту та захисту робочого середовища

No: 11

Name: pe\_1\_odp\_08

Type: list

Default: ["login", "logout", "failed\_attempt"]

Визначено події, які потребують перегляду та оновлення процедур фізичного захисту та захисту робочого середовища

## 11.2. РЕ-2 доступу (РЕ-2)

No: 1

Name: pe\_2\_a\_01

Type: list

Default: []

Розроблено перелік осіб, які мають право авторизованого доступу до об'єкта, де перебуває система

No: 2

Name: pe\_2\_a\_02

Type: list

Default: []

Затверджено перелік осіб, які мають право авторизованого доступу до об'єкта, де перебуває система

No: 3

Name: pe\_2\_a\_03

Type: list

Default: []

Ведеться перелік осіб, які мають право авторизованого доступу до об'єкта, де перебуває система

No: 4

Name: pe\_2\_b

Type: string

Default: nil

Для доступу до об'єкта надаються повноваження

No: 5

Name: pe\_2\_c

Type: list

Default: ["admin", "security\_officer"]

Переглядається список доступу, у якому закріплений перелік персоналу або ролей, яким дозволений санкціонований доступ до об'єкта частота

No: 6

Name: pe\_2\_d

Type: list

Default: ["admin", "security\_officer"]

Особи видаляються зі списку доступу до об'єкта, коли доступ більше не потрібен

No: 7

Name: pe\_2\_odp

Type: list

Default: ["admin", "security\_officer"]

Визначено періодичність перегляду списку доступу, у якому закріплений перелік персоналу або ролей, яким дозволений санкціонований доступ до об'єкта

## 11.3. ФІЗИЧНИЙ ДОСТУП ДО СИСТЕМИ

No: 1

Name: pe\_3\_a\_01

Type: string

Default: nil

Авторизація фізичного доступу забезпечується в пунктах входу і виходу шляхом перевірки індивідуальних дозволів доступу

No: 2

Name: pe\_3\_b

Type: string

Default: nil

Журнали контролю фізичного доступу ведуться для 03\_ODP[04] точок входу або виходу>

No: 3

Name: pe\_3\_c

Type: string

Default: nil

Доступ в зоні всередині об'єкту, визначені як загальнодоступні, підтримується шляхом впровадження заходів захисту

No: 4

Name: pe\_3\_d\_01

Type: string

Default: nil

Відвідувачів супроводжують

No: 5

Name: pe\_3\_d\_02

Type: list

Default: []

Активність відвідувачів контролюється умови

No: 6

Name: pe\_3\_e\_01

Type: string

Default: nil

Ключі захищені

No: 7

Name: pe\_3\_e\_02

Type: string

Default: nil

Коди доступу захищені

No: 8

Name: pe\_3\_e\_03

Type: string

Default: nil

Інші пристрої фізичного доступу захищені

No: 9

Name: pe\_3\_f

Type: string

Default: "щорічно"

Пристрої фізичного доступу інвентаризуються частота

No: 10

Name: pe\_3\_g\_01

Type: list

Default: ["admin", "security\_officer"]

Коди доступу змінюється частота, коли код скомпрометовано, або коли особи, які володіють кодом, переводяться або звільняються; <PE- PE-03(g)[02] ключі змінюються частота, коли ключі втрачено, або коли особи, що володіють ключами, переводяться або звільняються

No: 11  
Name: pe\_3\_odp\_01  
Type: string  
Default: nil

Визначено точки входу та виходу в об'єкт, в якому знаходиться система

No: 12  
Name: pe\_3\_odp\_02  
Type: string  
Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {системи або пристрої; охоронці}

No: 13  
Name: pe\_3\_odp\_03  
Type: string  
Default: nil

Визначено фізичні системи або пристрої контролю доступу, що використовуються для контролю входу та виходу на об'єкт (якщо вибрано); PE-03\_ODP[04] визначено точки входу або виходу, для яких ведуться журнали контролю фізичного доступу

No: 14  
Name: pe\_3\_odp\_05  
Type: string  
Default: nil

Визначено заходи захисту для контролю доступу в зони всередині об'єкту, позначені як загальнодоступні

No: 15  
Name: pe\_3\_odp\_06  
Type: list  
Default: []

Визначено умови, що вимагають супроводу відвідувачів та моніторингу активності відвідувачів

No: 16  
Name: pe\_3\_odp\_07  
Type: string  
Default: nil

Визначені пристрої фізичного доступу, що підлягають інвентаризації

No: 17  
Name: pe\_3\_odp\_08  
Type: integer  
Default: 30

Визначено частоту проведення інвентаризації пристроїв фізичного доступу

No: 18  
Name: pe\_3\_odp\_09  
Type: integer  
Default: 30

Визначено частоту, з якою потрібно змінювати коди доступу

No: 19  
Name: pe\_3\_odp\_10



Type: integer

Default: 30

Визначено частоту, з якою потрібно змінювати ключі

## 11.4. РЕ-4 ліній електроживлення (РЕ-4)

No: 1

Name: pe\_4\_01

Type: string

Default: nil

Фізичний доступ до систем розподілу та постачання живлення в межах об'єктів організації контролюється за допомогою заходів захисту

No: 2

Name: pe\_4\_odp\_01

Type: string

Default: nil

Визначені системи розподілу та постачання живлення, які потребують фізичного контролю доступу

No: 3

Name: pe\_4\_odp\_02

Type: string

Default: nil

Визначено заходи захисту, які необхідно впровадити для контролю фізичного доступу до систем розподілу та постачання живлення в межах об'єкту організації

## 11.5. КОНТРОЛЬ ДОСТУПУ В ПРИМІЩЕННЯ ДЛЯ ВІДОБРАЖЕННЯ ІНФОРМАЦІЇ

No: 1

Name: pe\_5\_odp

Type: string

Default: nil

Визначено пристрої для виведення інформації над якими необхідний контроль над фізичним доступом до вихідних даних

## 11.6. МОНІТОРИНГ ФІЗИЧНОГО ДОСТУПУ

No: 1

Name: pe\_6\_a

Type: string

Default: nil

Фізичний доступ до об'єкту, де знаходиться система, моніториться з метою виявлення та реагування на інциденти фізичної безпеки

No: 2

Name: pe\_6\_b\_01

Type: string  
Default: "щорічно"

Переглядаються журнали фізичного доступу частота

No: 3  
Name: pe\_6\_b\_02  
Type: string  
Default: nil

Журнали фізичного доступу переглядаються при виникненні подій

No: 4  
Name: pe\_6\_c\_01  
Type: string  
Default: nil

Результати переглядів узгоджуються з можливостями організації щодо реагування на інциденти

No: 5  
Name: pe\_6\_c\_02  
Type: string  
Default: nil

Результати розслідувань узгоджуються з можливостями організації щодо реагування на інциденти

No: 6  
Name: pe\_6\_odp\_01  
Type: integer  
Default: 30

Визначено частоту перегляду журналів фізичного доступу

No: 7  
Name: pe\_6\_odp\_02  
Type: list  
Default: ["login", "logout", "failed\_attempt"]

Визначено події або потенційні ознаки подій, що вимагають перегляду журналів фізичного доступу

## 11.7. АЛЬТЕРНАТИВНЕ РОБОЧЕ МІСЦЕ (PE-17)

No: 1  
Name: pe\_17\_odp\_01  
Type: string  
Default: nil

Визначені альтернативні робочі місця, дозволені для використання працівниками

No: 2  
Name: pe\_17\_odp\_02  
Type: list  
Default: ["admin", "security\_officer"]

Визначаються заходи захисту, які будуть застосовуватися на альтернативних робочих місцях; PE-17(a) альтернативні робочі місця визначені та задокументовані; PE-17(b) заходи захисту впроваджені на альтернативних робочих місцях; PE-17(c) оцінюється ефективність заходів захисту на альтернативних робочих місцях; PE-17(d) працівникам надаються засоби комунікації з персоналом служби інформаційної безпеки на випадок інцидентів

## 12. PL

Клас заходів захисту PL — ПЛАНУВАННЯ БЕЗПЕКИ

Цей клас регламентує розробку, документування та регулярне оновлення планів захисту інформації, архітектури безпеки та приватності.

Перелік заходів захисту: Політики та процедури планування безпеки (PL-1); Плани захисту інформації та персональних даних (PL-2); Правила поведінки (PL-4).

### 12.1. ПОЛІТИКИ ТА ПРОЦЕДУРИ ПЛАНУВАННЯ БЕЗПЕКИ (PL-1)

а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або ролей]:

1. 2. [вибір (один або декілька): рівень організації; рівень місії/бізнес процесу; рівень системи] політику планування, яка:

(а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та системою контролю (compliance);

(b) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам та керівним принципам; процедури, що полегшують здійснення планування політики безпеки та приватності й пов'язані з ними заходи.

б. Призначити [Призначення: визначену організацією посадову особу] для управління політикою та процедурами планування політики безпеки та приватності.

с. Переглядати та оновлювати поточне планування:

1. політики планування безпеки та приватності [Призначення: з визначеною організацією частотою] та наступні [Призначення: визначені організацією події];

2. поточні процедури планування політики [Призначення: з визначеною організацією [Призначення: визначені організацією події]. безпеки та приватності частотою] та наступні

No: 1

Name: pl\_1\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, до яких має бути доведена політика планування безпеки

No: 2

Name: pl\_1\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на які поширюватимуться процедури планування безпеки

No: 3

Name: pl\_1\_odp\_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнеспроцесу; рівень системи}

No: 4

Name: pl\_1\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами планування безпеки

No: 5

Name: pl\_1\_odp\_05

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено періодичність перегляду та оновлення поточної політики планування безпеки

No: 6

Name: pl\_1\_odp\_06

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Є події, які потребують перегляду та оновлення поточної політики планування безпеки

No: 7

Name: pl\_1\_odp\_07

Type: string

Default: "щорічно"

Визначена частота, з якою переглядаються та оновлюються поточні процедури планування безпеки

## 12.2. ПЛАНИ ЗАХИСТУ ІНФОРМАЦІЇ ТА ПЕРСОНАЛЬНИХ ДАНИХ (PL-2)

а. Розробити план захисту інформації та персональних даних для інформаційної системи, який:

1. узгоджується з архітектурою підприємства організації;
2. чітко визначає складові компоненти системи;
3. описує оперативний контекст інформаційної системи з точки зору завдань та процесів;
4. визначає осіб, які виконують системні ролі та обов'язки;
5. визначає тип інформації, яка обробляється, зберігається та передається системою;
6. надає огляд вимог безпеки та приватності інформаційної системи;
7. описує будь які конкретні загрози системи, які викликають стурбованість організації;
8. надає результати оцінки ризику конфіденційності для систем, в яких обробляються персональні дані;
9. описує робоче середовище інформаційної системи та будь які залежності від систем або компонентів систем або підключень до таких систем та їх компонентів;
10. надає огляд вимог безпеки та конфіденційності системи;
11. визначає будь які відповідні контрольні базові рівні або накладання, якщо вони застосовуються;
12. описує чинні або заплановані заходи щодо забезпечення безпеки та приватності, включно з обґрунтуванням рішень щодо налаштування
13. включає виявлення ризиків для архітектури безпеки і приватності, а також проектних рішень;
14. включає дії, пов'язані з безпекою та конфіденційністю, які впливають на систему, виконання яких вимагає планування та координацію з [Призначення: визначені організацією окремі особи або групи];
15. розглядається та затверджується уповноваженою посадовою особою або призначеним представником до початку реалізації плану.

b. Поширити копії планів захисту інформації та персональних даних і повідомляти про подальші зміни планів серед [Призначення: визначеного організацією персоналу або ролей].

c. Переглядати плани захисту інформації та персональних даних [Призначення: з визначеною організацією частотою].

d. Оновлювати плани захисту інформації та персональних даних для врахування змін в інформаційній системі й робочому середовищі або проблем, виявлених у ході реалізації або

оцінювання заходів безпеки та приватності.

е. забезпечити захист планів захисту інформації та персональних даних від несанкціонованого розголошення та змін.

No: 1

Name: pl\_2\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Призначені особи або групи, з якими пов'язана діяльність з безпекою та конфіденційністю, що впливає на систему, яка потребує планування та координації

No: 2

Name: pl\_2\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Призначено персонал або ролі для отримання розповсюджуваних копій планів захисту інформації та конфіденційності системи

No: 3

Name: pl\_2\_odp\_03

Type: list

Default: ["admin", "security\_officer"]

Визначено періодичність перегляду інформації та конфіденційності системи; планів захисту PL-02a.01[01] розроблено план захисту інформації, архітектурі підприємства організації; який відповідає PL-02a.01[02] розроблено план конфіденційності для системи, відповідає архітектурі підприємства організації; який PL-02a.02[01] розроблено план захисту інформації, який чітко визначає складові компоненти системи; PL-02a.02[02] розроблено для системи план забезпечення конфіденційності, який чітко визначає складові компоненти системи; PL-02a.03[01] розроблено план захисту інформації системи, який описує операційний контекст системи з точки зору місії та бізнеспроцесів; PL-02a.03[02] розроблено для системи план забезпечення конфіденційності, який описує операційний контекст системи з точки зору місії та бізнес-процесів; PL-02a.04[01] розроблено план захисту інформації, який визначає осіб, що виконують системні ролі та обов'язки; PL-02a.04[02] розроблено для системи план забезпечення конфіденційності, який визначає осіб, що виконують ролі та обов'язки в системі; PL-02a.05[01] розроблено план захисту інформації, який визначає типи інформації, що обробляється, зберігається та передається системою; PL-02a.05[02] розроблено план конфіденційності для системи, який визначає типи інформації, що обробляється, зберігається та передається системою; PL-02a.06[01] розроблено план захисту інформації, який передбачає категоризацію безпеки системи, включаючи відповідне обґрунтування; PL-02a.06[02] розроблено для системи план забезпечення конфіденційності, який передбачає категоризацію системи за рівнем безпеки, включаючи обґрунтування; PL-02a.07[01] розроблено план захисту інформації, який описує будь-які конкретні загрози для системи, що викликають потенційні ризики для організації; PL-02a.07[02] розроблено план конфіденційності для системи, який описує будь-які конкретні загрози для системи, що викликають потенційні ризики для організації; PL-02a.08[01] розроблено план захисту інформації, який містить результати оцінки ризиків конфіденційності для систем, що обробляють інформацію, яка ідентифікує особу; PL-02a.08[02] розроблено для системи план забезпечення конфіденційності, який містить результати оцінки ризиків конфіденційності для систем, що обробляють інформацію, яка ідентифікує особу; PL-02a.09[01] розроблено план захисту інформації, який описує операційне середовище системи та будь-які залежності або зв'язки з іншими системами чи компонентами системи; PL-02a.09[02] розроблено для системи план забезпечення конфіденційності, який описує робоче середовище системи та будь-які залежності або зв'язки з іншими системами чи компонентами системи; PL-02a.10[01] розроблено план захисту інформації, який містить огляд вимог до безпеки системи; PL-02a.10[02] розроблено для системи план забезпечення конфіденційності, який містить огляд вимог до конфіденційності системи; PL-02a.11[01] розроблено план захисту інформації, який визначає будь-які відповідні базові рівні контролю або обмеження, якщо такі є; PL-02a.11[02] розроблено для системи план забезпечення конфіденційності, який визначає будь-які відповідні базові рівні контролю або обмеження, якщо такі є; PL-02a.12[01] розроблено план захисту інформації, який описує наявні або заплановані засоби контролю для виконання вимог безпеки, включаючи обґрунтування будь-яких рішень щодо адаптації; PL-02a.12[02] розроблено для системи план забезпечення конфіденційності, який описує наявні або заплановані

засоби контролю для виконання вимог щодо конфіденційності, включаючи обґрунтування будь-яких рішень, пов'язаних з адаптацією; PL-02a.13[01] розроблено план захисту інформації, який включає визначення ризиків для архітектури безпеки та проектних рішень; PL-02a.13[02] розроблено план забезпечення конфіденційності для системи, який включає визначення ризиків для архітектури конфіденційності та проектних рішень; PL-02a.14[01] розроблено захисту інформації, який включає діяльність, пов'язану з безпекою, що впливає на систему і потребує планування та координації з окремими особами або групами; PL-02a.14[02] розроблено для системи план забезпечення конфіденційності, який включає діяльність, пов'язану з конфіденційністю, що впливає на систему і потребує планування та координації з окремими особами або групами; PL-02a.15[01] розроблено план захисту інформації, який розглядається та затверджується уповноваженою посадовою особою або призначеним представником до початку реалізації плану; PL-02a.15[02] розроблено план забезпечення конфіденційності для системи, який перевіряється та затверджується уповноваженою посадовою особою або призначеним представником перед впровадженням плану. PL-02b.[01] розповсюджуються копії персонал або ролі>; PL-02b.[02] повідомляються наступні зміни до планів персонал або ролі; PL-02c. переглядаються плани частота; планів серед <PL-02 \_ODP[02] PL-02d.[01] оновлюються плани відповідно до змін у системі та середовищі діяльності; PL-02d.[02] оновлюються плани для вирішення проблем, виявлених під час реалізації плану; PL-02d.[03] оновлюються плани для вирішення проблем, виявлених під час контрольних оцінок; PL-02e.[01] захищені плани від несанкціонованого розголошення; PL-02e.[02] захищені плани від несанкціонованої модифікації

### 12.3. ПРАВИЛА ПОВЕДІНКИ (PL-4)

- a. Створити та надати особам, що потребують доступу до інформаційної системи, правила, які описують їхні обов'язки й очікувану поведінку щодо інформації та використання інформаційної системи, безпеки та приватності.
- b. Отримати документальне підтвердження від таких осіб про те, що вони прочитали, зрозуміли та погодилися дотримуватися правил поведінки, перш ніж дозволяти доступ до інформації та інформаційної системи.
- c. Переглядати й оновлювати правила поведінки [Призначення: з визначеною організацією частотою].
- d. Вимагати від осіб, які підписали попередню версію правил поведінки, перечитати та повторно підписати правила [Вибір (один або декілька): [Призначення: з визначеною організацією частотою]; коли правила переглядаються чи оновлюються].

No: 1

Name: pl\_4\_odp\_01

Type: string

Default: "щорічно"

Визначено періодичність перегляду та оновлення правил поведінки

No: 2

Name: pl\_4\_odp\_02

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРА:{частота; коли правила переглядаються або оновлюються}

No: 3

Name: pl\_4\_odp\_03

Type: list

Default: ["admin", "security\_officer"]

Визначена періодичність перегляду та повторного підтвердження правил поведінки (якщо вибрано); PL-04a.[01] встановлені правила, які описують обов'язки та очікувану поведінку щодо використання інформації та системи, безпеки та конфіденційності для осіб, яким потрібен доступ до системи; PL-04a.[02] надаються правила, які описують обов'язки та очікувану поведінку щодо використання інформації та системи, безпеки та

конфіденційності, особам, які отримують доступ до системи; PL-04b. отримано перед наданням доступу до інформації та системи задокументоване підтвердження від таких осіб про те, що вони прочитали, зрозуміли та згодні дотримуватися правил поведінки; PL-04c. переглядаються та оновлюються правила поведінки частота; PL-04d. потрібно особам, які визнали попередню версію правил поведінки, прочитати та повторно визнати ЗНАЧЕННЯ ВИБРАНОВОГО ПАРАМЕТРА(ів)

## 13. PS

Клас заходів захисту PS — КАДРОВА БЕЗПЕКА

Цей клас встановлює вимоги до перевірки, надання повноважень та звільнення персоналу з метою мінімізації ризиків інсайдерських загроз.

Перелік заходів захисту: Політика та процедури кадрової безпеки (PS-1); Перевірка персоналу (PS-3); Звільнення персоналу (PS-4); Переведення персоналу (PS-5).

### 13.1. Політика та процедури кадрової безпеки (PS-1)

No: 1

Name: ps\_1\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на які поширюється політика кадрової безпеки

No: 2

Name: ps\_1\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на які поширюються процедури кадрової безпеки

No: 3

Name: ps\_1\_odp\_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнеспроцесу; рівень системи}

No: 4

Name: ps\_1\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами кадрової безпеки

No: 5

Name: ps\_1\_odp\_05

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначена періодичність перегляду та оновлення поточної політики кадрової безпеки

No: 6

Name: ps\_1\_odp\_06

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Є події, які вимагають перегляду та оновлення поточної політики кадрової безпеки

No: 7

Name: ps\_1\_odp\_07

Type: string

Default: "щорічно"

Визначено періодичність перегляду та оновлення поточних процедур кадрової безпеки

## 13.2. Перевірка персоналу (PS-3)

No: 1

Name: ps\_3\_odp\_01

Type: list

Default: []

Визначені умови, що вимагають повторної перевірки осіб

No: 2

Name: ps\_3\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначена частота повторної перевірки осіб, для яких це показано; PS-03a. проходять особи перевірку перед тим, як надати їм доступ до системи; PS-03b.[01] проходять особи повторну перевірку відповідно до умови, що вимагають повторної перевірки; PS-03b.[02] проводиться повторна перевірка у випадках, коли це зазначено, частота

## 13.3. Звільнення персоналу (PS-4)

No: 1

Name: ps\_4\_odp\_01

Type: integer

Default: 30

Визначено період часу, протягом якого забороняється доступ до системи

No: 2

Name: ps\_4\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначені теми інформаційної безпеки для обговорення під час проведення співбесід; PS-04a. при звільненні працівника доступ до системи вимикається протягом часового періоду; PS-04b. припиняють дію або анулюють будь-які автентифікатори та облікові дані після припинення трудових відносин з окремими особами; PS-04c. проводяться при звільненні окремих працівників співбесіди, які включають обговорення питань інформаційної безпеки; PS-04d. отримується після звільнення особи все майно, пов'язане з безпекою організаційної системи; PS-04e. зберігається доступ до організаційної інформації та систем, які раніше перебували під контролем особи, що звільняється, після припинення нею трудових відносин



## 13.4. Переведення персоналу (PS-5)

No: 1

Name: ps\_5\_odp\_01

Type: list

Default: ["login", "logout", "failed\_attempt"]

Визначені дії, які мають бути ініційовані після переведення або перепризначення

No: 2

Name: ps\_5\_odp\_02

Type: list

Default: ["login", "logout", "failed\_attempt"]

Визначено період часу, протягом якого мають бути здійснені дії з переведення або перепризначення після переведення або перепризначення

No: 3

Name: ps\_5\_odp\_03

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, про які необхідно повідомляти, коли осіб призначають на інші посади або переводять на інші посади в організації

No: 4

Name: ps\_5\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Визначено період часу, протягом якого необхідно повідомляти визначений організацією персонал або ролі, коли осіб перепризначають або переводять на інші посади в межах організації; PS-05a. переглядаються та підтверджуються поточні потреби в логічних та фізичних дозволах на доступ до систем та об'єктів при перепризначенні або переведенні осіб на інші посади в організації; PS-05b. були ініційовані дії з переведення або перепризначення протягом періоду часу після формальної дії з переведення; PS-05c. змінюється авторизація доступу за необхідності, щоб відповідати будь-яким змінам в оперативних потребах у зв'язку з перепризначенням або переведенням; PS-05d. було повідомлено персонал або ролі протягом часового періоду

## 14. RA

Клас заходів захисту RA — ОЦІНЮВАННЯ РИЗИКУ

Цей клас забезпечує систематичний підхід до виявлення, аналізу та реагування на ризики, пов'язані з обробкою інформації та функціонуванням системи.

Перелік заходів захисту: Політика та процедури оцінювання ризику (RA-1); Оцінювання ризику (RA-3); Оцінювання постачання (RA-3(1)); Сканування вразливостей (RA-5); Оновлення за частотою, перед новим скануванням або при ідентифікації (RA-5(2)); Реагування на ризик (RA-7).

## 14.1. ПОЛІТИКА ТА ПРОЦЕДУРИ ОЦІНЮВАННЯ РИЗИКУ (RA-1)

а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або посадових осіб]:

1. 2. Політику оцінювання ризику, яка:

(а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance);

(b) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам і керівним принципам. Процедури, що сприяють здійсненню політики оцінювання ризику та пов'язаних з ними заходів оцінювання ризику.

б. Призначити [Призначення: визначена організацією посадову особу] для управління політикою та процедурами оцінювання ризику.

с. Переглядати й оновлювати:

1. Поточну політику оцінювання організацією частотою]. ризику [Призначення: з визначеною

2. Поточні процедури оцінювання ризику [Призначення: з визначеною організацією частотою].

No: 1

Name: ra\_1\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на які поширюється політика оцінювання ризику

No: 2

Name: ra\_1\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на які поширюються процедури, що сприяють здійсненню політики оцінювання ризику

No: 3

Name: ra\_1\_odp\_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнеспроцесу; рівень системи}

No: 4

Name: ra\_1\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Визначена посадова особа, відповідальна за управління політикою та процедурами оцінювання ризику

No: 5

Name: ra\_1\_odp\_05

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначена періодичність перегляду та оновлення поточної політики оцінювання ризику

No: 6

Name: ra\_1\_odp\_06

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Є події, які вимагають перегляду та оновлення поточної політики оцінювання ризику

No: 7  
 Name: ra\_1\_odp\_07  
 Type: string  
 Default: "щорічно"

Визначено періодичність перегляду поточних процедур оцінювання ризику

## 14.2. ОЦІНЮВАННЯ РИЗИКУ (RA-3)

No: 1  
 Name: ra\_3\_odp\_01  
 Type: string  
 Default: nil

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {плани безпеки та приватності; звіт про оцінювання ризику; документ}

No: 2  
 Name: ra\_3\_odp\_02  
 Type: string  
 Default: nil

Визначено документ, в якому мають бути задокументовані результати оцінювання ризику (якщо вони не задокументовані в планах безпеки та приватності або в звіті про оцінювання ризику) (якщо вибрано)

No: 3  
 Name: ra\_3\_odp\_03  
 Type: string  
 Default: "щорічно"

Визначено періодичність оцінювання ризику

No: 4  
 Name: ra\_3\_odp\_04  
 Type: list  
 Default: ["admin", "security\_officer"]

Визначено персонал або ролі, до яких мають бути доведені результати оцінювання ризику

No: 5  
 Name: ra\_3\_odp\_05  
 Type: list  
 Default: ["admin", "security\_officer"]

Визначена періодичність оновлення оцінювання ризику; перегляду результатів RA-03a.01 проводиться оцінювання ризику для виявлення загроз і вразливостей у системі; RA-03a.02 проводиться оцінювання ризику для визначення ймовірності та розміру шкоди від несанкціонованого доступу, використання, розкриття, порушення, модифікації або знищення системи; інформації, яку вона обробляє, зберігає або передає; а також будь-якої пов'язаної з нею інформації; RA-03a.03 проводиться оцінювання ризику для визначення ймовірності та впливу несприятливих наслідків для фізичних осіб, що виникають у зв'язку з обробкою інформації, яка ідентифікує особу; RA-03b. інтегровані результати оцінювання ризику та рішення з управління ризиками з точки зору організації та місії або бізнес-процесів з оцінкою ризиків на системному рівні; RA-03c. результати оцінювання ризику задокументовані в ЗНАЧЕННЯ ВИБРАНОГО ПАРАМЕТРА; RA-03d. переглядаються результати 03\_ODP[03] частота>; RA-03e. поширюються результати оцінювання ризику серед персоналу або ролей; RA-03f. оновлюється оцінювання ризику частота або коли відбуваються значні зміни в системі, середовищі її функціонування або інших умовах, які можуть вплинути на стан безпеки або приватності системи оцінювання ризику <RA-

### 14.2.1. ОЦІНЮВАННЯ ПОСТАЧАННЯ (RA-3(1))

No: 1

Name: ra\_3\_1\_a

Type: string

Default: nil

Оцінювання ризику ланцюга постачання, пов'язані з системами, системними компонентами та системними послугами

No: 2

Name: ra\_3\_1\_b

Type: string

Default: nil

Потрібно оновлювати оцінювання ризику ланцюга постачання, коли відбуваються значні зміни у відповідному ланцюгу постачання, або коли зміни в системі, середовищі функціонування чи інших умовах можуть вимагати змін у ланцюгу постачання

## 14.3. СКАНУВАННЯ ВРАЗЛИВОСТЕЙ (RA-5)

Використовувати заходи ПДТР за [Призначення: визначені організацією місця] [Вибір (один або кілька): [Призначення: з визначеною організацією частотою]; [Призначення: за визначеними організацією подіями або показниками]].

No: 1

Name: ra\_5\_odp\_01

Type: string

Default: nil

Визначена необхідність моніторингу систем та розміщених застосунків на наявність вразливостей

No: 2

Name: ra\_5\_odp\_02

Type: string

Default: "щорічно"

Визначена періодичність перевірки систем та розміщених на них застосунків на наявність вразливостей

No: 3

Name: ra\_5\_odp\_03

Type: integer

Default: 30

Визначено час реагування на усунення законних вразливостей відповідно до організаційної оцінки ризику

No: 4

Name: ra\_5\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Потрібно ділитися інформацією, отриманою в процесі сканування вразливостей та оцінок контролю, з персоналом або ролями, з якими потрібно ділитися; RA-05a.[01] здійснюється моніторинг систем та розміщених застосунків на наявність вразливостей частота та/або випадковість відповідно до визначеного організацією процесу, а також коли виявляються та повідомляються нові вразливості, що потенційно можуть вплинути на систему; RA-05a.[02] перевіряються системи та розміщені застосунки на наявність вразливостей частота та/або випадковим чином відповідно до визначеного організацією процесу, а також коли виявляються та повідомляються нові вразливості, що потенційно можуть вплинути на систему; RA-05b. застосовуються інструменти та методи моніторингу вразливостей для забезпечення сумісності між інструментами; RA-05b.01

застосовуються інструменти та методи моніторингу вразливостей для автоматизації частини процесу управління вразливостями, використовуючи стандарти для переліку платформ, недоліків програмного забезпечення та неправильних конфігурацій; RA-05b.02 застосовуються інструменти та методи моніторингу вразливостей для полегшення взаємодії між інструментами та автоматизації частини процесу управління вразливостями шляхом використання стандартів для формування контрольних списків та процедур тестування; RA-05b.03 застосовуються інструменти та методи моніторингу вразливостей для полегшення взаємодії між інструментами та автоматизації частин процесу управління вразливостями шляхом використання стандартів для вимірювання впливу вразливостей; RA-05c. аналізуються звіти про сканування вразливостей та результати моніторингу вразливостей; RA-05d. усуваються легітимні вразливості час реагування відповідно до організаційної оцінки ризиків; RA-05e. надається інформація, отримана в процесі моніторингу вразливостей та оцінки контролю, персонал або ролі, щоб допомогти усунути подібні вразливості в інших системах; RA-05f. використовуються інструменти моніторингу вразливостей, які передбачають можливість швидкого оновлення вразливостей, що підлягають скануванню

### 14.3.1. ОНОВЛЕННЯ ЗА ЧАСТОТОЮ, ПЕРЕД НОВИМ СКАНУВАННЯМ АБО ПРИ ІДЕНТИФІКАЦІЇ (RA-5(2))

No: 1  
 Name: ra\_5\_2\_01  
 Type: integer  
 Default: 30

Визначено час реагування на усунення законних вразливостей відповідно до організаційної оцінки ризику

## 14.4. РЕАГУВАННЯ НА РИЗИК (RA-7)

Реагувати на результати оцінювання, моніторингу й аудиту безпеки та приватності.

No: 1  
 Name: ra\_7\_01  
 Type: string  
 Default: nil

Вживаються заходи реагування на результати оцінок безпеки відповідно до організаційної толерантності до ризиків

No: 2  
 Name: ra\_7\_02  
 Type: string  
 Default: nil

Вживаються заходи реагування на результати оцінювання приватності відповідно до організаційної толерантності до ризиків

No: 3  
 Name: ra\_7\_03  
 Type: string  
 Default: nil

Вживаються заходи реагування на результати моніторингу відповідно до організаційної толерантності до ризиків

No: 4  
 Name: ra\_7\_04  
 Type: string  
 Default: nil

Вживаються заходи реагування на висновки аудиту відповідно до організаційної толерантності до ризиків

## 15. SA

Клас заходів захисту SA — ПРИДБАННЯ СИСТЕМИ ТА ПОСЛУГ

Цей клас зосереджується на інтеграції вимог безпеки на всіх етапах життєвого циклу розробки та закупівлі ІТ-продуктів чи послуг.

Перелік заходів захисту: Політики та процедури придбання систем та послуг (SA-1); Безпека та приватність принципів інжинірингу (SA-8); Зовнішні послуги для системи (SA-9); Компоненти системи, що не підтримуються (SA-22).

### 15.1. ПОЛІТИКИ ТА ПРОЦЕДУРИ ПРИДБАННЯ СИСТЕМ ТА ПОСЛУГ (SA-1)

а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або ролей]:

1. 2.

б. [Вибір (один або декілька): рівень організації; рівень місії/бізнес-процесу; рівень системи] політики придбання систем і послуг, яка:

(а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю (compliance);

(б) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам і рекомендаціям. Процедури, що полегшують впровадження політики та заходів придбання систем і послуг. Призначити [Призначення: визначену організацією посадову особу] для управління політикою та процедурами придбання системи та послуг.

с. Переглядати й оновлювати поточні політику та процедури придбання систем та послуг:

1. Поточну політику придбання системи та послуг [Призначення: з визначеною організацією частотою].

2. Поточні процедури придбання системи та послуг [Призначення: з визначеною організацією частотою] та наступні [Призначення: події, визначені організацією].

No: 1

Name: sa\_1\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на які поширюватиметься політика придбання систем і послуг

No: 2

Name: sa\_1\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на які поширюються процедури придбання систем і послуг

No: 3

Name: sa\_1\_odp\_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнеспроцесу; рівень системи}

No: 4

Name: sa\_1\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами придбання систем і послуг

No: 5

Name: sa\_1\_odp\_05

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено періодичність перегляду та оновлення поточної політики придбання систем і послуг

No: 6

Name: sa\_1\_odp\_06

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Є події, які вимагають перегляду та оновлення поточної політики придбання систем і послуг

No: 7

Name: sa\_1\_odp\_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури придбання систем і послуг

## 15.2. БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ ІНЖИНІРИНГУ (SA-8)

Застосовувати [Призначення: визначені організацією принципи інжинірингу безпеки та конфіденційності системи] в специфікації, проектуванні, розробці, впровадженні та зміні системи й компонентів системи.

No: 1

Name: sa\_8\_01

Type: string

Default: nil

Застосовуються принципи інжинірингу безпеки систем у специфікації системи та компонентів системи

No: 2

Name: sa\_8\_02

Type: string

Default: nil

Застосовуються принципи інжинірингу безпеки систем при розробці системи та її компонентів

No: 3

Name: sa\_8\_03

Type: string

Default: nil

Були застосовані принципи інжинірингу безпеки систем при розробці системи та компонентів систем

No: 4

Name: sa\_8\_04

Type: string

Default: nil

Застосовуються принципи інжинірингу безпеки систем при реалізації системи та компонентів систем

No: 5

Name: sa\_8\_05

Type: string

Default: nil

Застосовуються принципи інжинірингу безпеки систем при модифікації системи та компонентів систем

No: 6

Name: sa\_8\_06

Type: string

Default: nil

Застосовуються принципи інжинірингу конфіденційності у специфікації системи та компонентів систем;  
 принципи інжинірингу конфіденційності SA-08[07] застосовуються принципи інжинірингу конфіденційності  
 при розробці системи та компонентів систем

No: 7

Name: sa\_8\_08

Type: string

Default: nil

Застосовуються принципи інжинірингу конфіденційності при розробці системи та компонентів систем

No: 8

Name: sa\_8\_09

Type: string

Default: nil

Застосовуються принципи інжинірингу конфіденційності при реалізації системи та компонентів систем

No: 9

Name: sa\_8\_10

Type: string

Default: nil

Застосовуються принципи інжинірингу конфіденційності при модифікації системи та компонентів систем

No: 10

Name: sa\_8\_odp\_01

Type: string

Default: nil

Визначені принципи інжинірингу безпеки систем

No: 11

Name: sa\_8\_odp\_02

Type: string

Default: nil

Визначені системи

## 15.3. ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ (SA-9)

а. Вимагати, щоб постачальники зовнішніх послуг для системи відповідали вимогам безпеки та приватності в організації та застосовували такі заходи захисту [Призначення: встановлені]



організацією заходи безпеки та приватності].

b. Визначити та задокументувати нагляд організаціїповноваження та обов'язки користувачів щодо зовнішніх послуг для системи.

c. Використовувати наступні процеси, методи та техніки для постійного моніторингу дотримання контролю зовнішніми постачальниками послуг: [Призначення: визначені організацією процеси, методи та техніки].

No: 1

Name: sa\_9\_odp\_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначені засоби контролю, які будуть застосовуватися зовнішніми постачальниками системних послуг

No: 2

Name: sa\_9\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначені процеси, методи та техніки, що застосовуються для моніторингу дотримання вимог контролю зовнішніми постачальниками послуг; SA-09a.[01] дотримуються постачальники зовнішніх системних послуг вимог організаційної безпеки; SA-09a.[02] дотримуються постачальники зовнішніх системних послуг вимог приватності організації; SA-09a.[03] використовують постачальники зовнішніх системних послуг елементи керування; SA-09b.[01] визначено та задокументовано організаційний нагляд за зовнішніми системними послугами; SA-09b.[02] визначені та задокументовані ролі та обов'язки користувачів щодо зовнішніх системних сервісів; SA-09c. визначені та задокументовані ролі та обов'язки користувачів щодо зовнішніх системних послуг

## 15.4. КОМПОНЕНТИ СИСТЕМИ, ЩО НЕ ПІДТРИМУЮТЬСЯ (SA-22)

a. Замінювати компоненти системи, якщо підтримка компонентів більше не доступна розробнику, постачальнику або виробнику.

b. Надавати такі варіанти альтернативних джерел для подальшої підтримки непідтримуваних компонентів [Вибір (один або більше): внутрішня підтримка; [Призначення: підтримка, визначена організацією від зовнішніх постачальників]].

No: 1

Name: sa\_22\_odp\_01

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {внутрішня підтримка; підтримка від зовнішніх постачальників}

## 16. SC

Клас заходів захисту SC — ЗАХИСТ ІНФОРМАЦІЙНОЇ СИСТЕМИ ТА

Цей клас охоплює механізми захисту інформації під час її передачі мережами зв'язку, криптографічний захист та ізоляцію критичних компонентів.

Перелік заходів захисту: Політика та процедури захисту системи та комунікацій (SC-1); Ін-

формація в загальних системних ресурсах (SC-4); Доступність ресурсів (SC-7); Відмова за замовчуванням - дозвіл за винятком (SC-7(5)); Конфіденційність та цілісність передачі (SC-8); Конфіденційність та криптографічний захист (SC-8(1)); Відключення мережі (SC-10); Встановлення ключами (SC-12); Криптографічний захист (SC-13); Спільні обчислювальні пристрої та застосунки (SC-15); Мобільний код (SC-18); Автентифікація сесії (SC-23); Захист інформації в стані спокою (SC-28); ЗАХИСТ ІНФОРМАЦІЇ В СТАНІ СПОКОЮ | КРИПТОГРАФІЧНИЙ ЗАХИСТ.

## 16.1. ПОЛІТИКА ТА ПРОЦЕДУРИ ЗАХИСТУ СИСТЕМИ ТА КОМУНІКАЦІЙ (SC-1)

а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або посадових осіб]:

1. 2. Політику захисту системи та комунікацій, яка:

(а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance);

(б) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам та керівним принципам. Процедури для сприяння впровадженню політики в області захисту систем і комунікацій, а також пов'язаних з ними систем і засобів захисту зв'язку.

б. Призначити [Призначення: визначена організацією посадову особу] для управління політикою та процедурами захисту системи та комунікацій.

с. Переглядати та оновлювати:

1. поточну політику захисту системи та комунікацій [Призначення: визначена організацією частота];

2. поточні процедури захисту системи та комунікацій [Призначення: визначена організацією частота].

No: 1

Name: sc\_1\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, до яких має бути доведена політика захисту системи та комунікацій

No: 2

Name: sc\_1\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на які поширюються процедури захисту системи та комунікацій

No: 3

Name: sc\_1\_odp\_03

Type: string

Default: nil

Вибрано жодне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнеспроцесу; рівень системи}

No: 4

Name: sc\_1\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами захисту системи та комунікацій

No: 5

Name: sc\_1\_odp\_05

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначена періодичність перегляду та оновлення поточної політики захисту системи та комунікацій

No: 6

Name: sc\_1\_odp\_06

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Є події, які вимагають перегляду та оновлення поточної політики захисту системи та комунікацій

No: 7

Name: sc\_1\_odp\_07

Type: string

Default: "щорічно"

Визначена періодичність перегляду та оновлення поточних процедур захисту системи та засобів зв'язку

## 16.2. ІНФОРМАЦІЯ В ЗАГАЛЬНИХ СИСТЕМНИХ РЕСУРСАХ (SC-4)

Запобігати несанкціонованій та ненавмисній передачі інформації через спільні системні ресурси.

No: 1

Name: sc\_4\_01

Type: string

Default: nil

Запобігається несанкціонована передача інформації через спільні системні ресурси

No: 2

Name: sc\_4\_02

Type: string

Default: nil

Запобігається ненавмисна передача інформації через спільні системні ресурси. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

## 16.3. ДОСТУПНІСТЬ РЕСУРСІВ (SC-7)

- a. Контролювати та управляти зв'язком на зовнішньому периметрі системи та на ключових внутрішніх периметрах всередині системи.
- b. Реалізувати підмережі для загальнодоступних компонентів системи, які є [Вибір: фізично; логічно] відділені від внутрішніх мереж організації.
- c. Підключатися до зовнішніх мереж або систем тільки через керовані інтерфейси, що складаються з пристроїв захисту периметру, і розташованих відповідно до архітектури безпеки та приватності організації.

Немає параметрів для цього контролю.

### 16.3.1. ВІДМОВА ЗА ЗАМОВЧУВАННЯМ - ДОЗВІЛ ЗА ВИНЯТКОМ (SC-7(5))

Немає параметрів для цього контролю.

## 16.4. КОНФІДЕНЦІЙНІСТЬ ТА ЦІЛІСНІСТЬ ПЕРЕДАЧІ (SC-8)

Забезпечити [Вибір (один або кілька): конфіденційність; цілісність] інформації, що передається.

Немає параметрів для цього контролю.

### 16.4.1. КОНФІДЕНЦІЙНІСТЬ ТА КРИПТОГРАФІЧНИЙ ЗАХИСТ (SC-8(1))

No: 1

Name: sc\_8\_1\_odp

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {запобігти несанкціонованому розголошенню інформації; виявити зміни в інформації}

## 16.5. ВІДКЛЮЧЕННЯ МЕРЕЖІ (SC-10)

Завершити з'єднання з мережею, яке пов'язане із сеансом зв'язку в кінці сеансу або після [Призначення: визначений організацією період часу] бездіяльності.

No: 1

Name: sc\_10\_odp

Type: integer

Default: 30

Визначено період бездіяльності, після якого система розриває мережеве з'єднання, пов'язане з сеансом зв'язку; SC08(05)\_ODP[02] мережеве з'єднання, пов'язане з сеансом зв'язку, розірвано в кінці сеансу або після період часу бездіяльності

## 16.6. ВСТАНОВЛЕННЯ КЛЮЧАМИ (SC-12)

Встановити та управляти криптографічними ключами для криптографічних засобів, які використовуються в системі відповідно до [Призначення: визначені організацією вимоги до генерації, поширення, зберігання, доступу та знищення ключів].

No: 1

Name: sc\_12\_01

Type: string

Default: "AES-256-GCM"

Встановлюються криптографічні ключі, коли в системі використовується криптографія відповідно до < SC-12\_ODP вимог >

No: 2

Name: sc\_12\_02

Type: string

Default: "AES-256-GCM"

Здійснюється управління криптографічними ключами, коли в системі використовується криптографія, відповідно до вимог

No: 3

Name: sc\_12\_odp

Type: string

Default: nil

Визначені вимоги до генерації, розповсюдження, зберігання, доступу та знищення ключів

## 16.7. КРИПТОГРАФІЧНИЙ ЗАХИСТ (SC-13)

- a. Визначити [Призначення: використання криптографічних засобів, визначених організацією];
- b. Впровадити [Завдання: визначені організацією види криптографії для кожного визначеного криптографічного використання].

No: 1

Name: sc\_13\_01

Type: string

Default: "AES-256-GCM"

КРИПТОГРАФІЧНИЙ ЗАХИСТ МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: sc\_13\_odp\_01

Type: string

Default: "AES-256-GCM"

Визначено використання криптографічних засобів

No: 3

Name: sc\_13\_odp\_02

Type: string

Default: "AES-256-GCM"

Визначено типи криптографії для кожного вказаного криптографічного використання; SC-13a. ідентифіковано використання>; SC-13b. реалізовано типи криптографії для кожного вказаного криптографічного використання (визначеного в SC-13\_ODP[01]). криптографічне <SC-13\_ODP[01]

## 16.8. СПІЛЬНІ ОБЧИСЛЮВАЛЬНІ ПРИСТРОЇ ТА ЗАСТОСУНКИ (SC-15)

- a. Заборонити віддалену активацію спільних обчислювальних пристроїв (хмар) та застосунків з такими виключеннями: [Призначення: визначені організацією виключення, у яких дозволена віддалена активація].
- b. Надати явну вказівку щодо використання користувачами фізично присутніми пристроями.

Немає параметрів для цього контролю.

## 16.9. МОБІЛЬНИЙ КОД (SC-18)

- а. Визначати прийнятні та неприйнятні мобільні коди та технології мобільних кодів.
- б. Проводити авторизацію, відстежувати та контролювати використання мобільного коду всередині системи.

Немає параметрів для цього контролю.

## 16.10. АВТЕНТИФІКАЦІЯ СЕСІЇ (SC-23)

Забезпечити автентифікацію сеансів зв'язку.

No: 1

Name: sc\_23\_01

Type: string

Default: nil

Захищено автентифікацію сеансів зв'язку

## 16.11. ЗАХИСТ ІНФОРМАЦІЇ В СТАНІ СПОКОЮ (SC-28)

Забезпечити [Вибір (один або кілька): конфіденційність; цілісність] [Призначення: визначена організацією інформація] в стані спокою.

No: 1

Name: sc\_28\_odp

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {конфіденційність; цілісність}

No: 2

Name: sc\_28\_odp\_02

Type: string

Default: nil

Є інформація в стані спокою, яка потребує захисту

### 16.11.1. ЗАХИСТ ІНФОРМАЦІЇ В СТАНІ СПОКОЮ | КРИПТОГРАФІЧНИЙ ЗАХИСТ

No: 1

Name: sc\_28\_1\_01

Type: string

Default: "AES-256-GCM"

Реалізовані криптографічні механізми для запобігання несанкціонованому розкриттю інформації, що знаходиться в стані спокою на системних компонентах або носіях

No: 2

Name: sc\_28\_1\_02

Type: string

Default: "AES-256-GCM"

Реалізовані криптографічні механізми для запобігання несанкціонованій модифікації інформації, що знаходиться в стані спокою на системних компонентах або носіях

## 17. SI

Клас заходів захисту SI — ЦІЛІСНІСТЬ СИСТЕМИ ТА ІНФОРМАЦІЇ

Цей клас спрямований на захист системи від шкідливого коду, виявлення вразливостей та запобігання несанкціонованим змінам інформації.

Перелік заходів захисту: Політика і процедури цілісності інформації (SI-1); Виправлення дефектів (SI-2); Захист від шкідливого коду (SI-3); Моніторинг системи (SI-4); Моніторинг системи комунікацій (SI-4(4)); Попередження, рекомендації та директиви з безпеки (SI-5); Управління та збереження інформації (SI-12).

### 17.1. ПОЛІТИКА І ПРОЦЕДУРИ ЦІЛІСНОСТІ ІНФОРМАЦІЇ (SI-1)

No: 1

Name: si\_1\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, до яких має бути доведена політика цілісності системи та інформації

No: 2

Name: si\_1\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на які поширюються процедури цілісності системи та інформації

No: 3

Name: si\_1\_odp\_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнеспроцесу; рівень системи}

No: 4

Name: si\_1\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Визначено посадову особу, відповідальну за управління системою та політикою і процедурами цілісності інформації

No: 5

Name: si\_1\_odp\_05

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначено періодичність перегляду та оновлення поточної політики цілісності системи та інформації

No: 6

Name: si\_1\_odp\_06

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Є події, які вимагають перегляду та оновлення поточної політики цілісності системи та інформації

No: 7

Name: si\_1\_odp\_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні цілісності системи та інформації

## 17.2. ВИПРАВЛЕННЯ ДЕФЕКТІВ (SI-2)

No: 1

Name: si\_2\_odp

Type: integer

Default: 30

Визначено період часу, протягом якого необхідно встановити оновлення програмного забезпечення, пов'язані з безпекою, після виходу оновлень; SI-02a.[01] виявлено недоліки системи; SI-02a.[02] повідомляється про недоліки системи; SI-02a.[03] виправлені недоліки системи; SI-02b.[01] перевіряються оновлення програмного забезпечення, пов'язані з усуненням недоліків, на ефективність перед встановленням; SI-02b.[02] перевіряються оновлення програмного забезпечення, пов'язані з виправленням дефектів, на наявність потенційних побічних ефектів перед встановленням; SI-02b.[03] перевіряються оновлення прошивки, пов'язані з усуненням недоліків, на ефективність перед встановленням; SI-02b.[04] перевіряються оновлення прошивки, пов'язані з усуненням недоліків, на наявність потенційних побічних ефектів перед встановленням; SI-02c.[01] встановлено оновлення програмного забезпечення, що стосуються безпеки, протягом часовий проміжок з моменту випуску оновлень; SI-02c.[02] встановлено оновлення мікропрограми, що стосуються безпеки, протягом часового періоду з моменту випуску оновлень; SI-02d. включено відновлення порушених прав у процес управління організаційною конфігурацією

## 17.3. ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ (SI-3)

No: 1

Name: si\_3\_odp\_01

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {підписаний; непідписаний}

No: 2

Name: si\_3\_odp\_02

Type: integer

Default: 30

Визначено частоту, з якою механізми шкідливого коду виконують сканування

No: 3

Name: si\_3\_odp\_03

Type: string

Default: nil



Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {кінцева точка; точки входу та виходу з мережі}

No: 4

Name: si\_3\_odp\_04

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {block malicious code; quarantitne malicious code; take action}

No: 5

Name: si\_3\_odp\_05

Type: list

Default: ["login", "logout", "failed\_attempt"]

Визначено дії, яких слід вжити у відповідь на виявлення шкідливого коду (якщо вибрано)

## 17.4. МОНІТОРИНГ СИСТЕМИ (SI-4)

No: 1

Name: si\_4\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначені методи та способи, що використовуються для виявлення несанкціонованого використання системи

No: 2

Name: si\_4\_odp\_03

Type: list

Default: ["admin", "security\_officer"]

Визначена інформація про моніторинг системи, яка повинна надаватися персоналу або ролям

No: 3

Name: si\_4\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, яким має надаватися інформація про моніторинг системи

No: 4

Name: si\_4\_odp\_05

Type: string

Default: "щорічно"

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {за потребою; частота}

### 17.4.1. МОНІТОРИНГ СИСТЕМИ КОМУНІКАЦІЙ (SI-4(4))

No: 1

Name: si\_4\_4\_a\_01

Type: list

Default: []

Визначені критерії незвичної або несанкціонованої діяльності або умови для вхідного трафіку зв'язку

No: 2

Name: si\_4\_4\_a\_02

Type: list

Default: []

Визначені критерії незвичайної або несанкціонованої діяльності або умови для вихідного трафіку зв'язку

No: 3

Name: si\_4\_4\_b\_01

Type: string

Default: "щорічно"

Здійснюється моніторинг вхідного комунікаційного трафіку частота на предмет незвичних або несанкціонованих дій або умов

No: 4

Name: si\_4\_4\_b\_02

Type: string

Default: "щорічно"

Контролюється вихідний трафік зв'язку частота на предмет незвичних або несанкціонованих дій або умов. вихідного виявлення

## 17.5. ПОПЕРЕДЖЕННЯ, РЕКОМЕНДАЦІЇ ТА ДИРЕКТИВИ З БЕЗПЕКИ (SI-5)

No: 1

Name: si\_5\_odp\_01

Type: string

Default: nil

Визначені зовнішні організації, від яких необхідно постійно отримувати оповіщення, поради та директиви щодо безпеки системи

No: 2

Name: si\_5\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {персонал або ролі; елементи; зовнішні організації}

No: 3

Name: si\_5\_odp\_03

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, до яких мають бути доведені попередження, поради та директиви з безпеки (якщо визначено)

No: 4

Name: si\_5\_odp\_04

Type: string

Default: nil

Визначені елементи в організації, до яких мають надсилатися оповіщення, поради та директиви з безпеки (якщо вони були обрані)

## 17.6. УПРАВЛІННЯ ТА ЗБЕРЕЖЕННЯ ІНФОРМАЦІЇ (SI-12)

Управляти та зберігати інформацію всередині системи та виводити інформацію із системи відповідно до чинного законодавства, виконавчих наказів, директив, правил, політик, стандартів, керівних принципів та експлуатаційних вимог.

No: 1

Name: si\_12\_01

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Здійснюється управління інформацією в системі відповідно до чинних законів, наказів, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог

No: 2

Name: si\_12\_02

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Зберігається інформація в системі відповідно до чинних законів, указів Президента, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог

No: 3

Name: si\_12\_03

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Управління інформацією, що виводиться з системи, здійснюється відповідно до чинних законів, указів Президента, директив, положень, політик, стандартів, інструкцій та операційних вимог

No: 4

Name: si\_12\_04

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Зберігається інформація, що виводиться з системи, відповідно до чинних законів, наказів, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог

## 18. SR

Клас заходів захисту SR — УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА

Цей клас встановлює вимоги для виявлення та мінімізації загроз, що виникають через зовнішніх постачальників продуктів та послуг.

Перелік заходів захисту: Політика та процедури управління ризиками ланцюга постачання (SR-1); План управління ризиками ланцюга постачання (SR-2); Контроль ланцюга постачання і процесів (SR-3); Стратегії придбання, інструменти і методи (SR-5); Оцінка постачальників (SR-6).

## 18.1. ПОЛІТИКА ТА ПРОЦЕДУРИ УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ (SR-1)

а. Розробіть, задокументуйте та поширте [Призначення: персонал або ролі, визначені організацією]:

1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політика управління ризиками ланцюга постачання, яка: а) Розглядає мету, сферу діяльності, ролі, відповідальність, зобов'язання керівництва, координацію між організаційними підрозділами та відповідність; б) Відповідає чинним законам, виконавчим наказам, директивам, положенням, політикам, стандартам і вказівкам;

2. Процедури для сприяння впровадженню політики управління ризиками ланцюга постачання та відповідних засобів контролю управління ризиками ланцюга постачання;

б. Призначити [Призначення: посадова особа, визначена організацією] для управління розробкою, документуванням і розповсюдженням політики та процедур управління ризиками ланцюга постачання;

с. Перегляньте та оновіть поточне управління ризиками ланцюга постачання:

1. Політика [Призначення: частота, визначена організацією] та наступне [Призначення: події, визначені організацією];

2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією].

No: 1

Name: sr\_1\_odp\_01

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на які поширюється політика управління ризиками ланцюга постачання

No: 2

Name: sr\_1\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал або ролі, на які поширюються процедури управління ризиками ланцюга постачання

No: 3

Name: sr\_1\_odp\_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень завдань/бізнеспроцесу; рівень системи}

No: 4

Name: sr\_1\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Визначена посадова особа, відповідальна за розробку, документування та розповсюдження політики та процедур управління ризиками ланцюга постачання

No: 5

Name: sr\_1\_odp\_05

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Визначена періодичність перегляду та оновлення поточної політики управління ризиками ланцюга постачання

No: 6

Name: sr\_1\_odp\_06

Type: list

Default: ["default\_deny\_rule", "abac\_rule\_1"]

Є події, які вимагають перегляду та оновлення поточної політики управління ризиками ланцюга постачання

No: 7

Name: sr\_1\_odp\_07

Type: string

Default: "щорічно"

Визначена періодичність перегляду та оновлення поточної процедури управління ризиками ланцюга постачання

## 18.2. ПЛАН УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ (SR-2)

а. Розробіть план управління ризиками ланцюга постачання, пов'язаними з дослідженнями та розробкою, проектуванням, виробництвом, придбанням, доставкою, інтеграцією, експлуатацією та обслуговуванням, а також утилізацією таких систем, компонентів системи або послуг для системи: [Призначення: системи, визначені організацією, системні компоненти або системні служби];

б. Перегляньте та оновіть план управління ризиками ланцюга постачання [Призначення: частота, визначена організацією] або за потреби для усунення загроз;

с. Захистіть план управління ризиками ланцюга постачання від несанкціонованого розголошення та модифікації.

No: 1

Name: sr\_2\_odp\_01

Type: string

Default: nil

Визначені системи, компоненти системи або системні послуги, для яких розробляється план управління ризиками ланцюга постачання

## 18.3. КОНТРОЛЬ ЛАНЦЮГА ПОСТАЧАННЯ І ПРОЦЕСІВ (SR-3)

а. Встановлення процесу або процесів для виявлення та усунення слабких місць або недоліків в елементах і процесах ланцюга постачання [Призначення: визначена організацією система або компонент системи] у координації з [Завдання: персонал ланцюга постачання, визначений організацією];

б. Використовуйте такі заходи захисту, щоб захистити систему, компонент системи або системну службу від ризиків ланцюга постачання та обмежити шкоду чи наслідки від подій, пов'язаних із ланцюгом постачання: [Призначення: заходи захисту ланцюга постачання, визначені організацією];

с. Задокументуйте обрані та впроваджені процеси та заходи захисту ланцюгом постачання у [Вибір: плани безпеки та приватності; план управління ризиками ланцюга постачання; [Призначення: документ, визначений організацією]].

No: 1

Name: sr\_3\_odp\_01

Type: string

Default: nil

Визначено систему або компонент системи, який потребує процесу або процесів для виявлення та усунення слабких місць або недоліків

No: 2

Name: sr\_3\_odp\_02

Type: list

Default: ["admin", "security\_officer"]

Визначено персонал ланцюга поставок, з яким необхідно координувати процес або процеси виявлення та усунення слабких місць або недоліків в елементах і процесах ланцюга постачання

No: 3

Name: sr\_3\_odp\_03

Type: string

Default: "автоматизований засіб моніторингу"

Визначені засоби контролю ланцюга постачання, що застосовуються для захисту від ризиків ланцюга постачання для системи, системного компонента або системної послуги, а також для обмеження шкоди або наслідків від подій, пов'язаних з ланцюгом постачання

No: 4

Name: sr\_3\_odp\_04

Type: list

Default: ["admin", "security\_officer"]

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {плани безпеки та конфіденційності; план управління ризиками ланцюга постачання; документ}; SR-03\_ODP[05] визначено документ, що ідентифікує обрані та впроваджені процеси та засоби контролю ланцюга постачання (якщо обрано); SR-03a.[01] запроваджено процес або процеси для виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання; SR-03a.[02] процес або процеси виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання системи або компонента системи координується/координуються з персоналом ланцюга постачання; SR-03b. застосовуються засоби контролю ланцюга постачання для захисту від ризиків ланцюга постачання для системи, системного компонента або системної послуги, а також для обмеження шкоди або наслідків від подій, пов'язаних з ланцюгом постачання; SR-03c. задокументовані обрані та впроваджені процеси та засоби контролю ланцюга постачання в ЗНАЧЕННЯ ВИБІРКОВОГО ПАРАМЕТРА(ів)

No: 5

Name: sr\_3\_odp\_05

Type: list

Default: ["admin", "security\_officer"]

Визначено документ, що ідентифікує обрані та впроваджені процеси та засоби контролю ланцюга постачання (якщо обрано); SR-03a.[01] запроваджено процес або процеси для виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання; SR-03a.[02] процес або процеси виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання системи або компонента системи координується/координуються з персоналом ланцюга постачання; SR-03b. застосовуються засоби контролю ланцюга постачання для захисту від ризиків ланцюга постачання для системи, системного компонента або системної послуги, а також для обмеження шкоди або наслідків від подій, пов'язаних з ланцюгом постачання; SR-03c. задокументовані обрані та впроваджені процеси та засоби контролю ланцюга постачання в ЗНАЧЕННЯ ВИБІРКОВОГО ПАРАМЕТРА(ів)

## 18.4. СТРАТЕГІЇ ПРИДБАННЯ, ІНСТРУМЕНТИ І МЕТОДИ (SR-5)

Використовуйте наступні стратегії придбання, контрактні інструменти та методи закупівель, щоб захистити від ризиків ланцюга постачання, визначити та пом'якшити їх: [Призначення:

визначені організацією стратегії придбання, контрактні інструменти та методи закупівель].

No: 1

Name: sr\_5\_01

Type: string

Default: nil

Застосовуються стратегії, інструменти та методи для захисту від ризиків ланцюга постачання

No: 2

Name: sr\_5\_02

Type: string

Default: nil

Застосовуються стратегії, інструменти та методи для виявлення ризиків ланцюга постачання

No: 3

Name: sr\_5\_03

Type: string

Default: nil

Застосовуються стратегії, інструменти та методи для зменшення ризиків ланцюга постачання

No: 4

Name: sr\_5\_odp

Type: string

Default: nil

Визначені стратегії закупівель, контрактні інструменти та методи закупівель для захисту, виявлення та пом'якшення ризиків ланцюга постачання

## 18.5. ОЦІНКА ПОСТАЧАЛЬНИКІВ (SR-6)

Оцініть і перегляньте ризики ланцюга постачання, пов'язані з постачальниками або підрядниками, системою, системним компонентом або системною послугою, яку вони надають [Призначення: частота, визначена організацією].

No: 1

Name: sr\_6\_01

Type: string

Default: "щорічно"

Оцінюються та аналізуються ризики, пов'язані з ланцюгом постачання, які стосуються постачальників або підрядників та систем, компонентів системи або системних послуг, які вони надають < SR-06\_ODP частота >

No: 2

Name: sr\_6\_odp

Type: string

Default: "щорічно"

Визначена періодичність оцінки та аналізу ризиків, пов'язаних з ланцюгом постачання, що стосуються постачальників або підрядників, а також систем, компонентів системи або системних послуг, які вони надають